

	DIN EN 50742 (VDE 0113-742)	DIN
	Diese Norm ist zugleich eine VDE-Bestimmung im Sinne von VDE 0022. Sie ist nach Durchführung des vom VDE-Präsidium beschlossenen Genehmigungsverfahrens unter der oben angeführten Nummer in das VDE-Vorschriftenwerk aufgenommen und in der „etz Elektrotechnik + Automation“ bekannt gegeben worden.	VDE

Vervielfältigung – auch für innerbetriebliche Zwecke – nicht gestattet.

Einsprüche bis 2026-04-20

ICS 13.110

Entwurf

Sicherheit von Maschinen –
Schutz vor Korruption;
Deutsche und Englische Fassung prEN 50742:2025

Safety of machinery –
Protection against corruption;
German and English version prEN 50742:2025

Sécurité des machines –
Protection contre la corruption;
Version allemande et anglaise prEN 50742:2025

Anwendungswarnvermerk

Dieser Entwurf mit Erscheinungsdatum 2026-02-20 wird der Öffentlichkeit zur Prüfung und Stellungnahme vorgelegt. Weil das beabsichtigte Dokument von der vorliegenden Fassung abweichen kann, ist die Anwendung dieses Entwurfs besonders zu vereinbaren.

Stellungnahmen werden erbeten

- vorzugsweise online im Norm-Entwurfs-Portal von DIN unter www.din.de/go/entwuerfe bzw. für Norm-Entwürfe der DKE auch im Norm-Entwurfs-Portal der DKE unter www.entwuerfe.normenbibliothek.de, sofern dort wiedergegeben;
- oder als Datei per E-Mail an dke@vde.com möglichst in Form einer Tabelle. Die Vorlage dieser Tabelle kann im Internet unter www.din.de/go/stellungnahmen-norm-entwuerfe oder für Stellungnahmen zu Norm-Entwürfen der DKE unter www.dke.de/stellungnahme abgerufen werden;
- oder in Papierform an die DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE, Merianstraße 28, 63069 Offenbach am Main.

Es wird gebeten, mit den Kommentaren zu diesem Entwurf jegliche relevanten Patentrechte, die bekannt sind, mitzuteilen und unterstützende Dokumentationen zur Verfügung zu stellen.

Gesamtumfang 138 Seiten

DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE

Anwendungsbeginn

Anwendungsbeginn dieser Norm ist ...

Nationales Vorwort

Die Deutsche Fassung des europäischen Dokuments prEN 50742:2025-12 „Sicherheit von Maschinen – Schutz vor Korruption“ (Entwurf in der Umfrage) ist unverändert in diesen Norm-Entwurf übernommen worden.

Da die Deutsche Fassung noch nicht endgültig mit der Englischen und der Französischen Fassung abgeglichen ist, ist die englische Originalfassung der prEN 50742:2025-12 beigefügt. Die Nutzungsbedingungen für den deutschen Text des Norm-Entwurfes gelten gleichermaßen auch für den englischen Text.

Das europäische Dokument prEN 50742:2025-12 „Safety of machinery – Protection against corruption“ wurde vom CLC/TC 44X „Safety of machinery electrotechnical aspects“ des Europäischen Komitees für Elektrotechnische Normung (CENELEC) erarbeitet und von CENELEC den Nationalen Komitees zur Stellungnahme vorgelegt.

Dokumente, die bei CENELEC als Europäische Norm angenommen und ratifiziert werden, sind unverändert als Deutsche Normen zu übernehmen.

Da der Abstimmungszeitraum für einen späteren „Schluss-Entwurf“ FprEN nur 8 Wochen beträgt und zum „Schluss-Entwurf“ FprEN keine sachlichen Stellungnahmen mehr abgegeben werden können, sondern nur noch eine „JA/NEIN“-Entscheidung möglich ist, wobei eine „NEIN“-Entscheidung fundiert begründet werden muss, wird bereits der „Entwurf“ prEN als Deutscher Norm-Entwurf veröffentlicht, um die Stellungnahmen aus der Öffentlichkeit noch vor der formellen Abstimmung berücksichtigen zu können.

Für dieses Dokument ist das nationale Arbeitsgremium DKE/K 225 „Elektrotechnische Ausrüstung und Sicherheit von Maschinen und maschinellen Anlagen“ der DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE (www.dke.de) zuständig.

Aktuelle Informationen zu diesem Dokument können über die Internetseiten von DKE (www.dke.de) und DIN (www.din.de) durch eine Suche nach der Dokumentennummer aufgerufen werden.

Für die in diesem Dokument zitierten Dokumente können die entsprechenden deutschen Dokumente kostenlos auf der DIN-Media-Homepage recherchiert werden.

Es wird auf die Möglichkeit hingewiesen, dass einige Elemente dieses Dokuments Patentrechte berühren können. CENELEC ist nicht dafür verantwortlich, einige oder alle diesbezüglichen Patentrechte zu identifizieren.

Das Original-Dokument enthält Bilder in Farbe, die in der Papierversion in einer Graustufen-Darstellung wiedergegeben werden. Elektronische Versionen dieses Dokuments enthalten die Bilder in der originalen Farbdarstellung.

EUROPÄISCHE NORM
EUROPEAN STANDARD
NORME EUROPÉENNE

Entwurf
prEN 50742

Dezember 2025

ICS 13.110

Deutsche Fassung

Sicherheit von Maschinen – Schutz vor Korruption

Safety of machinery – Protection against corruption

Sécurité des machines – Protection contre la corruption

Dieser Entwurf für eine Europäische Norm wird den CENELEC-Mitgliedern zur CENELEC-Umfrage vorgelegt.
CENELEC Termin: 2026-02-27.

Er wurde von CLC/TC 44X erstellt.

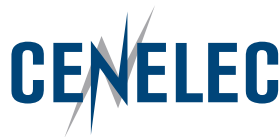
Wenn aus diesem Entwurf eine Europäische Norm wird, sind die CENELEC-Mitglieder gehalten, die CEN/CENELEC-Geschäftsordnung zu erfüllen, in der die Bedingungen festgelegt sind, unter denen dieser Europäischen Norm ohne jede Änderung der Status einer nationalen Norm zu geben ist.

Dieser Entwurf für eine Europäische Norm wurde von CENELEC in drei offiziellen Fassungen (Deutsch, Englisch, Französisch) erstellt. Eine Fassung in einer anderen Sprache, die von einem CENELEC-Mitglied in eigener Verantwortung durch Übersetzung in seine Landessprache gemacht und dem CEN-CENELEC Management Centre mitgeteilt worden ist, hat den gleichen Status wie die offiziellen Fassungen.

CENELEC-Mitglieder sind die nationalen elektrotechnischen Komitees von Belgien, Bulgarien, Dänemark, Deutschland, Estland, Finnland, Frankreich, Griechenland, Irland, Island, Italien, Kroatien, Lettland, Litauen, Luxemburg, Malta, den Niederlanden, Norwegen, Österreich, Polen, Portugal, der Republik Nordmazedonien, Rumänien, Schweden, der Schweiz, Serbien, der Slowakei, Slowenien, Spanien, der Tschechischen Republik, der Türkei, Ungarn, dem Vereinigten Königreich und Zypern.

Die Empfänger dieses Norm-Entwurfs werden gebeten, mit ihren Kommentaren jegliche relevanten Patentrechte, die sie kennen, mitzuteilen und unterstützende Dokumentationen zur Verfügung zu stellen.

Warnvermerk: Dieses Schriftstück hat noch nicht den Status einer Europäischen Norm. Es wird zur Prüfung und Stellungnahme vorgelegt. Es kann sich noch ohne Ankündigung ändern und darf nicht als Europäische Norm in Bezug genommen werden.



Europäisches Komitee für Elektrotechnische Normung
European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brüssel

© 2025 CENELEC

Alle Rechte der Verwertung, gleich in welcher Form und in welchem Verfahren,
sind weltweit den Mitgliedern von CENELEC vorbehalten.

Projekt: 77624

Ref. Nr. prEN 50742:2025 D

Inhalt

	Seite
Europäisches Vorwort.....	8
Einleitung.....	9
1 Anwendungsbereich.....	10
2 Normative Verweisungen.....	10
3 Begriffe.....	11
4 Schutz gegen Verfälschungen.....	13
4.1 Allgemeines.....	13
4.2 Anschluss von Maschinen.....	13
4.3 Allgemeine Verfahrensanforderungen.....	13
5 Prozessanforderungen.....	16
5.1 Einleitung.....	16
6 Prozessanforderungen nach Ansatz B.....	16
7 Produktanforderungen.....	16
7.1 Schnittstellen.....	16
7.2 Sicherheitsmaßnahmen.....	17
7.2.1 Allgemeines.....	17
7.2.2 Kryptographie.....	17
7.3 Erfassung von Informationen.....	18
7.3.1 Arten von Eingriffen.....	18
7.3.2 Zu erfassende Nachweise von Eingriffen.....	18
7.3.3 Anforderungen an die Protokollierung.....	18
7.3.4 Anforderungen an die Speicherdauer.....	19
7.3.5 Anforderungen an die Speichersicherheit.....	19
7.4 Schutzmaßnahmen gegen Verfälschungen.....	19
7.4.1 Allgemeines.....	19
7.4.2 Sicherheitsbezogene Sicherheitsstufen.....	19
7.4.3 Anforderungen an die Aufrechterhaltung der Sicherheit.....	20
7.5 Identifikation von Software-Versionen und Konfigurationen.....	23
8 Prozessanforderungen nach Ansatz B.....	23
8.1 Allgemeines.....	23
8.2 Maschinensysteme.....	24
8.3 Maschinenkomponenten.....	24
8.4 Identifikation.....	25
8.5 Persistenz.....	25
9 Anwenderinformation.....	25
Anhang A (informativ) Beispiele für Protokollformate.....	26
Anhang B (informativ) Beurteilung von Bedrohungen.....	27
Anhang C (informativ) Bedrohungsmodellierung für Sicherheitssysteme.....	33

C.1 Allgemeines..... 33

C.2 Risikobezogene Sicherheitsbewertung..... 33

C.3 Einführung in die Beispiele..... 34

C.3.1 Allgemeines..... 34

C.3.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 35

C.3.3 Beispiel 2: Funksteuerung für Ladekran..... 37

C.3.4 Beispiel 3: Sicherheitssensor..... 39

C.3.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 39

C.4 Vermögenswerte..... 39

C.4.1 Allgemeines..... 39

C.4.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 39

C.4.3 Beispiel 2: Funksteuerung für Ladekran..... 40

C.4.4 Beispiel 3: Sicherheitssensor..... 40

C.4.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 40

C.5 Sicherheitsumfeld..... 40

C.5.1 Allgemeines..... 40

C.5.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 41

C.5.3 Beispiel 2: Funksteuerung für Ladekran..... 42

C.5.4 Beispiel 3: Sicherheitssensor..... 42

C.5.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 42

C.6 Datenflussdiagramme..... 42

C.6.1 Allgemeines..... 42

C.6.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 43

C.6.3 Beispiel 2: Funksteuerung für Ladekran..... 44

C.6.4 Beispiel 3: Sicherheitssensor..... 45

C.6.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 45

C.7 Vertrauensgrenzen..... 45

C.7.1 Allgemeines..... 45

C.7.2 Beispiel 1: Einfache Maschine..... 46

C.7.3 Beispiel 2: Ladekran mit kabelloser Steuerung..... 48

C.7.4 Beispiel 3: Sicherheitssensor..... 49

C.7.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 49

C.8 STRIDE-Analyse..... 49

C.8.1 Allgemeines..... 49

C.8.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 50

C.8.3 Beispiel 2: Funksteuerung für Ladekran..... 54

C.8.4 Beispiel 3: Sicherheitssensor..... 55

C.8.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 55

C.9 Bedrohungsklassifizierung..... 55

C.9.1 Allgemeines..... 55

C.9.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine..... 56

C.9.3 Beispiel 2: Ladekran mit kabelloser Steuerung..... 62

C.9.4 Beispiel 3: Sicherheitssensor..... 65

C.9.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion..... 65

Anhang D (informativ) Liste der Bedrohungen und Schadensbegrenzungsmaßnahmen..... 66

D.1 Allgemeines..... 66

D.2 Voraussetzungen für die Ausnutzung, Arten von Bedrohungen und Schadensbegrenzungsmaßnahmen..... 66

D.2.1 Voraussetzungen für die Ausnutzung..... 66

D.2.2 „Arten von Bedrohungen“..... 68

Anhang ZZ (informativ) Zusammenhang zwischen dieser Europäischen Norm und den grundlegenden Anforderungen der abzudeckenden Verordnung (EU) 2023/1230..... 70

Literaturhinweise..... 71

Bilder

Bild 1 – Risikobeurteilung einschließlich Sicherheitsaspekten..... 16

Bild 2 – Beispiel für Maschinenschnittstellen..... 17

Bild B.1 – Beispiel für die Zuordnung des Expositionspegels zu einer Maschine..... 29

Bild C.1..... 34

Bild C.2 – Beispiel für eine branchenübliche vertikale Form-, Füll- und Verschleißmaschine..... 35

Bild C.3..... 36

Bild C.4 – Beispiel für die Funksteuerung eines Ladekrans..... 37

Bild C.5..... 38

Bild C.6..... 39

Bild C.7..... 43

Bild C.8..... 44

Bild C.9..... 46

Bild C.10..... 47

Bild C.11..... 48

Bild C.12..... 49

Tabellen

Tabelle 1 – Übersicht über die Prozessanforderungen..... 15

Tabelle 2 – SRSL-Beschreibung..... 20

Tabelle 3..... 24

Tabelle 4..... 24

Tabelle B.1 – Expositionspegel..... 27

Tabelle B.2 – Einstufung der Fähigkeiten des Angreifers..... 30

Tabelle B.3 – Einstufung des Zeitfensters..... 30

Tabelle B.4 – Einstufung des Expositionspegels..... 31

Tabelle B.5 – Einstufung des Angriffspotenzials..... 31

Tabelle B.6 – Festlegung der Zuordnung von SRSLs nach Sicherheitsfunktionen und Angriffspotenzial..... 32

Tabelle C.1..... 51

Tabelle C.2..... 54

Tabelle C.3..... 56

Tabelle D.1 – Voraussetzungen für die Ausnutzung..... 66

Tabelle D.2 – Arten von Bedrohungen..... 68

Tabelle ZZ.1 – Zusammenhang zwischen dieser Europäischen Norm und der Verordnung
(EU) 2023/1230, Anhang III..... 70

Europäisches Vorwort

Dieses Dokument (prEN 50742:2025) wurde vom CLC/TC 44X „Sicherheit von Maschinen und Anlagen: elektrotechnische Aspekte“.

Dieses Dokument wird derzeit zur Umfrage vorgelegt.

Nachstehende Daten wurden vorgeschlagen:

- spätestes Datum, zu dem dieses Dokument auf nationaler Ebene angekündigt werden muss (doa) dav + 6 Monate
- spätestes Datum, zu dem dieses Dokument auf nationaler Ebene durch Veröffentlichung einer identischen nationalen Norm oder durch Anerkennung übernommen werden muss (dop) dav + 12 Monate
- spätestes Datum, zu dem nationale Normen, die diesem Dokument entgegenstehen, zurückgezogen werden müssen (dow) dav + 36 Monate
(bei der Abstimmung zu bestätigen oder zu ändern)

Dieses Dokument wurde im Rahmen eines Normungsauftrages erarbeitet, der von der Europäischen Kommission an CENELEC gegeben wurde. Diese Normungsaufträge werden anschließend durch das Ständige Komitee der EFTA-Länder für diese Mitgliedsländer angenommen.

Zum Zusammenhang mit den Rechtsvorschriften der EU siehe den informativen Anhang ZZ, der Bestandteil dieses Dokuments ist.

Einleitung

Maschinen müssen sicher sein, um Verletzungen und Todesfälle zu vermeiden.

Die Kommunikation mit der Maschine darf nicht zu Gefährdungssituationen führen.

Der Hersteller führt eine Risikobeurteilung nach EN ISO 12100 durch, um alle potenziellen Gefahren zu identifizieren.

Anfälligkeiten können zu einer **Verfälschung** des Steuerungssystems der Maschine führen, und Gefahren können zu Gefährdungssituationen führen.

Durch Ausnutzung von Anfälligkeiten über die Kommunikation mit der Maschine könnten Maschinen außerhalb sicherer Parameter betrieben oder Sicherheitsfunktionen beeinträchtigt werden.

Anfälligkeiten können keine neuen Gefährdungen schaffen.

Die Wahrscheinlichkeit, dass jemand eine **Anfälligkeit** für einen böswilligen Versuch ausnutzt, kann nicht vorhergesagt werden.

Das Risiko kann nur im Hinblick auf die Auswirkungen auf die funktionale Sicherheit beurteilt werden.

Anfälligkeiten werden in verschiedene Typen unterteilt.

Dieses Dokument stellt zwei Ansätze bereit:

- Ansatz A (**Abschnitt 5** und **Abschnitt 7**) wurde entwickelt, um leichter die Übereinstimmung von Maschinen zu erreichen, die ohne Bezugnahme auf die Normenreihe EN IEC 62443 entwickelt wurden.
- Ansatz B (**Abschnitt 6** und **Abschnitt 8**) wurde bereitgestellt, um leichter die Übereinstimmung von Maschinen zu erreichen, die mit Bezugnahme auf die Normen EN IEC 62443-3-3:2019, EN IEC 62443-4-1:2018 und EN IEC 62443-4-2:2019 entwickelt wurden.

ANMERKUNG 1 Die Normenreihe EN IEC 62443 stellt Informationen und eine Methodik zum Umgang mit Cybersicherheit bereit.

Dieses Dokument ist für die Anwendung durch Maschinenkonstruktoren, Hersteller von Steuerungssystemen und Integratoren sowie andere an der Spezifikation, Gestaltung und Validierung eines sicherheitsbezogenen Steuerungssystems Beteiligte vorgesehen.

ANMERKUNG 2 Siehe EN IEC 62443-4-1:2018. Der Hersteller kann ein Lieferant oder ein Systemintegrator sein.

Dieses Dokument befasst sich nicht mit der Rolle des Anwenders.

1 Anwendungsbereich

Dieses Dokument stellt Anforderungen und Empfehlungen zum Schutz vor Korruption für Maschinen, zugehörige Produkte und unvollständige Maschinen, die in diesem Dokument als „Maschinen“ bezeichnet werden.

Dieses Dokument stellt Anforderungen und Empfehlungen zur Verhinderung von unbeabsichtigten und vorsätzlichen (einschließlich böswilligen) Verfälschungen von Maschinen bereit, die zu gefährlichen Situationen führen können.

Dieses Dokument gilt für:

- Hardware-Komponenten, einschließlich Schnittstellen zu entfernten Geräten und Steuerungssystemen, die Signale oder Daten übertragen können;
- Software und Daten;

sofern diese die Sicherheit der Maschinen beeinflussen könnten.

ANMERKUNG 1 Die Themen können sich mit dem Themenbereich Cybersicherheit überschneiden, sind jedoch nicht unbedingt identisch in ihrer Funktionsabdeckung.

ANMERKUNG 2 Dieses Dokument beschreibt keine funktionalen Sicherheitsanforderungen an Steuerungssysteme in Maschinen.

Es gibt allerdings Anforderungen an die zugehörigen Risiken in allen Lebenszyklusphasen vor.

Maschinenschnittstellen zu externen Systemen und Diensten fallen ebenfalls in den Anwendungsbereich dieses Dokuments. Externe Systeme und Dienste fallen dagegen nicht in den Anwendungsbereich dieses Dokuments.

Dieses Dokument ist nicht anwendbar auf Maschinen, die vor dem Datum seiner Veröffentlichung installiert wurden.

Dieses Dokument legt Anforderungen zum Schutz vor zugehörigen Verfälschungsrisiken in allen Lebenszyklusphasen fest, darunter:

- Entwicklung;
- Fertigung;
- Inbetriebsetzung;
- Betrieb;
- Instandhaltung/Wartung;
- Außerbetriebsetzung.

2 Normative Verweisungen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

EN ISO 12100:2010, *Sicherheit von Maschinen - Allgemeine Gestaltungsleitsätze - Risikobeurteilung und Risikominderung (ISO 12100:2010)*

EN IEC 62443-3-3:2019¹, *Industrielle Kommunikationsnetze - IT-Sicherheit für Netze und Systeme - Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level*

¹ Aktualisiert durch EN IEC 62443-3-3:2019/AC:2019.

EN IEC 62443-4-1:2018, *IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung*

EN IEC 62443-4-2:2019², *IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-2: Technische Sicherheitsanforderungen an Komponenten industrieller Automatisierungssysteme (IACS)*

3 Begriffe

Für die Anwendung dieses Dokuments gelten die folgenden Begriffe.

ISO und IEC stellen terminologische Datenbanken für die Verwendung in der Normung unter den folgenden Adressen bereit:

- ISO Online Browsing Platform: verfügbar unter <https://www.iso.org/obp>
- IEC Electropedia: verfügbar unter <https://www.electropedia.org/>

3.1

Steuerungssystem

System, das auf Eingangssignale von Bauteilen der Maschine, von Bedienern, von externen Steuerungseinrichtungen oder einer beliebigen Kombination davon reagiert und entsprechende Ausgangssignale an die Bedienteile der Maschine generiert, wodurch die Maschine die beabsichtigte Leistung erbringt

3.2

Eingriff

legitime(s) oder illegitime(s) Aktion oder Ereignis, die/das die Software oder Daten ändert und dadurch das Verhalten, den Zustand oder den Betrieb der Maschine vorübergehend oder dauerhaft modifiziert oder unterbricht

Anmerkung 1 zum Begriff: Aktionen zur Umsetzungen von Sicherheitsroutinen, Sicherheitsvariablen, Kalibrierungsdaten und Firmware-Updates sicherheitsbezogener Bauteile der Software gelten als Eingriffe im Sinn dieses Dokuments.

Anmerkung 2 zum Begriff: Üblicherweise betrieblich veranlasste Änderungen an Variablen, wie z. B. zum Öffnen einer Sicherheitstür, stellen keine Eingriffe im Sinn einer Datenänderung dar.

BEISPIEL 1) Modifizierung der auf der Maschine installierten Software aufgrund einer Aktualisierung oder Konfigurationsänderung(en).

2) Modulare SPS: Wenn ein SPS-Modul gegen ein identisches Ersatzteil ausgetauscht wird, gilt dies nicht als Eingriff; wenn dagegen ein zusätzliches Bauteil eingebaut wird, so gilt dies als Modifizierung.

3.3

Modifizierung

durch einen **Eingriff** verursachte Änderung

Anmerkung 1 zum Begriff: **Einschließlich Software-Version, Sensorkalibrierung, Konfigurationsdaten usw.**

BEISPIEL Aktualisierung von sicherheitsbezogener Software.

3.4

Nachweis

alles, was die Erkennung ermöglicht, dass ein Ereignis oder eine Aktion stattgefunden hat

BEISPIEL Protokollaufzeichnungen, beschädigte Sicherheitssiegel (Manipulationsschutzsiegel) und Kratzspuren, Beschädigungen an Schnittstellenabdeckungen, z. B. RJ45-Abdeckung.

² Aktualisiert durch EN IEC 62443-4-2:2019/AC:2022-09.

3.5

Verfälschung

unbeabsichtigte oder unzulässige Änderung von Maschinendaten, die unter Umständen zu gefährlichen Situationen führt

3.6

Sicherheitsumfeld

Sicherheit, die der Maschine durch die Umgebung geboten wird, in der die Maschine eingesetzt werden soll

Anmerkung 1 zum Begriff: Die Sicherheit, die der Maschine durch die vorgesehene Umgebung geboten wird, kann die für die Maschine zutreffenden Bedrohungen wirksam einschränken.

Anmerkung 2 zum Begriff: Siehe [Abschnitt C.5](#).

[QUELLE: EN IEC 62443-4-1:2018, 3.1.23, modifiziert – Das Wort „Produkt“ wurde durch das Wort „Maschine“ ersetzt]

3.7

Maßnahme

Tätigkeit, Gerät, Prozedur oder Verfahren, durch die eine Bedrohung, eine [Anfälligkeit](#) oder die Folgen eines Angriffs verringert werden, und zwar durch die Verringerung des möglichen Schadens oder durch Entdeckung und Bericht, so dass Korrekturmaßnahmen eingeleitet werden können

[QUELLE: EN IEC 62443-4-2:2019, 3.1.15]

3.8

Ausgleichsmaßnahme

[Maßnahme](#), die anstelle von oder zusätzlich zu inhärenten Sicherheitsfähigkeiten eingesetzt wird, um einer oder mehreren Sicherheitsanforderung(en) zu genügen

[QUELLE: EN IEC 62443-4-2:2019, 3.1.9]

3.9

vernünftigerweise praktikabel

unter Abwägung der Risikominderung gegen Zeit, Geld und Aufwand

3.10

Verfolgungsprotokoll

erfasste Daten, die Eingriffe betreffen, die sich auf das sicherheitsbezogene [Steuerungssystem](#) auswirken

3.11

Anfälligkeit

Fehler oder Angriffsmöglichkeiten in der Gestaltung, der Implementierung oder dem Betrieb und Management eines Systems, der/die ausgenutzt werden könnte, um die Integrität des Systems zu verfälschen

3.12

kritische Daten

Daten, deren Manipulation zu einer Erhöhung der Gefährdung führen kann

3.13

sicherheitsbezogene Anwendungs-Software SRASW

anwendungsspezifische Software, die im Allgemeinen logische Sequenzen, Grenzwerte und Ausdrücke enthält, die die entsprechenden Eingaben, Ausgaben, Berechnungen und Entscheidungen steuern, die zur Erfüllung der funktionalen Anforderungen an das sicherheitsbezogene Teil einer Steuerung (SRP/CS) erforderlich sind

[QUELLE: EN ISO 13849-1:2023, 3.1.41]

3.14**sicherheitsbezogene Embedded-Software****SRESW**

Software, die Teil des vom Hersteller gelieferten Systems und nicht für Änderungen durch den Endanwender vorgesehen ist

[QUELLE: EN ISO 13849-1:2023, 3.1.42, modifiziert – Anmerkung 1 zum Begriff wurde gestrichen]

3.15**SRSL****Sicherheitsbezogene Sicherheitsanforderung**

Parameter, der die Gesamtheit der Sicherheitsanforderungen darstellt, die zu einer bestimmten sicherheitsbezogenen Funktion gehören, um diese vor Datenverfälschungen zu schützen

4 Schutz gegen Verfälschungen**4.1 Allgemeines**

Es muss entweder Ansatz A ([Abschnitt 5](#) und [Abschnitt 7](#)) oder Ansatz B ([Abschnitt 6](#) und [Abschnitt 8](#)) angewendet werden.

4.2 Anschluss von Maschinen

Auslegung und Konstruktion der Maschinen dürfen keine Gefährdungssituationen aufgrund anhand der Anschlüsse dieser Maschinen zulassen.

Anschlüsse ([physisch](#), [logisch](#) und [indirekt](#)) sind dabei Verbindungen, über die Informationen ausgetauscht werden können, wie zum Beispiel:

- Netz-Übertragungsleitungen,
- WLAN-Verbindungen,
- einzelne Drähte,
- Drähte für die Stromversorgung,
- optische Verbindungen,
- Kartenleser-Schnittstellen,
- Verbindungen zwischen Maschinen und externen Systemen:
 - Hausnetze
 - Cloud-Dienste
 - Dienstwerkzeuge

ANMERKUNG 1 Die Konnektivität kann über eine Ausrüstung hergestellt werden, die dauerhaft vor Ort verfügbar ist, oder über eine Ausrüstung, die vorübergehend während der Installation, des Betriebs und der Instandhaltung oder für die Außerbetriebnahme an den Standort verbracht wird.

ANMERKUNG 2 Ein Beispiel für eine Maschine, die hier nicht berücksichtigt werden soll, ist beispielsweise eine einfache Bohrmaschine ohne jegliche Anschlussmöglichkeit.

4.3 Allgemeine Verfahrensanforderungen

Nach einer Risikobeurteilung nach EN ISO 12100:2010, bei der zuvor alle potenziellen Gefährdungen identifiziert wurden, muss der Konstrukteur eine Gefährdungsbeurteilung durchführen.

Der Inhalt der Gefährdungsbeurteilung kann sich auf zusätzliche Gefährdungen beschränken, die nicht durch die Mindestsicherheitsmaßnahmen abgedeckt sind.

Der Konstrukteur muss den Sicherheitskontext für die Maschine festlegen.

Die folgenden Grundsätze müssen angewendet werden, um eine Maschine vor Bedrohungen zu schützen, die zu Gefährdungssituationen führen können:

- a) Sofern Anfälligkeiten vorhanden sind, sind diejenigen zu beseitigen, die zu Gefährdungssituationen führen können.

BEISPIEL 1 Beseitigung aller unnötigen Schnittstellen, so dass die Bedrohungen diese Anfälligkeiten nicht ausgenutzt werden können.

BEISPIEL 2 Spätere Deaktivierung von während der Entwicklung verwendeten JTAG-Schnittstellen.

BEISPIEL 3 Die Beseitigung kann das Ergebnis einer Neukonstruktion mit anderen Komponenten (möglicherweise vom gleichen Anbieter) sein.

- b) Wenn es nicht möglich ist, Anfälligkeiten zu beseitigen, muss der Entwickler diese mindern.

BEISPIEL Schadensbegrenzung, Einrichtung einer Anwenderauthentifizierung auf einer Schnittstelle.

- c) Für alle Anfälligkeiten, die nach den Schritten a) und b) noch bestehen, muss die Anwenderinformation alle notwendigen Angaben bereitstellen, damit der Anwender Ausgleichsmaßnahmen ergreifen kann. Siehe [Anhang C](#).

BEISPIEL Der Hersteller gibt in der Anwenderinformation an, dass die Feldbusverbindung der Maschine nur für interne (lokale) Verbindungen zu einer anderen Maschine in einem vertrauenswürdigen Netzwerk ausgelegt ist und nicht an ein nicht vertrauenswürdiges Netzwerk angeschlossen werden darf.

Anfälligkeiten können keine neuen Gefährdungen verursachen, aber ihre Ausnutzung kann die Schutzmaßnahmen gefährden. Daher muss eine Beurteilung durchgeführt werden.

ANMERKUNG Durch Ausnutzung von Anfälligkeiten über die Kommunikation mit der Maschine könnten Maschinen außerhalb sicherer Parameter betrieben oder Sicherheitsfunktionen beeinträchtigt werden. Das Risiko kann nur im Hinblick auf die Auswirkungen auf die funktionale Sicherheit beurteilt werden.

Gegenmaßnahmen dürfen die funktionale Sicherheit der Maschine nicht beeinträchtigen.

BEISPIEL Bei der Implementierung einer kryptographischen Funktion wird überprüft, dass diese nicht aufgrund einer erhöhten Reaktionszeit der Sicherheitsfunktion zu Gefährdungen führt.

Die Wahrscheinlichkeit, dass jemand versucht, eine bestimmte [Anfälligkeit](#) für einen böswilligen Versuch auszunutzen, kann nicht vorhergesagt werden. Daher darf die Wahrscheinlichkeit, Ziel bzw. Opfer eines solchen Versuchs zu werden, für die Beurteilung einer Bedrohung nicht relevant sein.

Um die grundlegenden Anforderungen und Empfehlungen zur Verhinderung einer zufälligen und vorsätzlichen (einschließlich böswilligen) [Verfälschung](#) von Maschinen, die zu gefährlichen Situationen führt, zu erfüllen, müssen Entwickler dem Ansatz A in der folgenden Tabelle folgen.

Wenn sie dagegen vorziehen, für die Sicherheitsanforderungen ihrer Maschinen eher die Normen EN IEC 62443-3-3:2019, EN IEC 62443-4-1:2018 oder EN IEC 62443-4-2:2019 zu befolgen, muss Ansatz B in Betracht kommen.

[Tabelle 1](#) enthält einen Überblick über beide Ansätze.

Tabelle 1 – Übersicht über die Prozessanforderungen

Zu beachtende allgemeine Abschnitte:	
– Risikobeurteilung nach EN ISO 12100:2010 – Abschnitt 4: Schutz gegen Verfälschungen – Abschnitt 9: Anwenderinformation	
Zu beachtende spezifische Abschnitte:	
Ansatz A	Ansatz B
– Abschnitt 5 zu Prozessanforderungen – Abschnitt 7 zu Produktanforderungen	– Abschnitt 6 zu Prozessanforderungen – Abschnitt 8 zu Produktanforderungen

ANMERKUNG Beide Wege sind gleichermaßen zulässig. Die Wahl des Wegs hängt vom Aufwand ab, den der Hersteller zu erfüllen hat, sowie vom Wert für den Hersteller, aber auch von dessen Wissen, Anwendungsbereich usw.

5 Prozessanforderungen

5.1 Einleitung

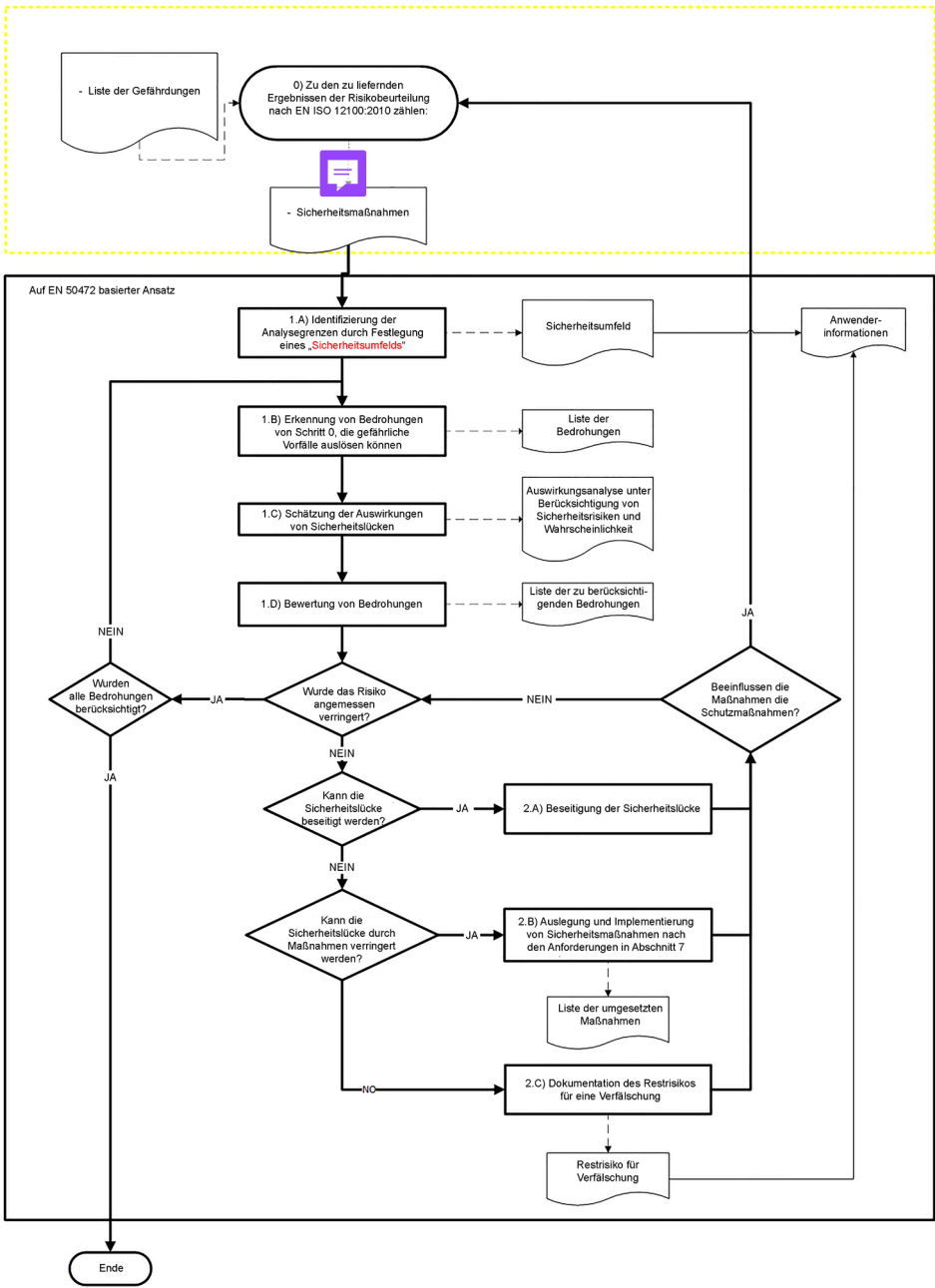


Bild 1 – Risikobeurteilung einschließlich Sicherheitsaspekten

6 Prozessanforderungen nach Ansatz B

Es müssen die Anforderungen nach EN IEC 62443-4-1:2018 gelten.

7 Produktanforderungen

7.1 Schnittstellen

Alle Maschinen-Schnittstellen, die zugänglich sind und die Sicherheit der Maschine beeinträchtigen können, müssen identifiziert und durch Ausgleichs- oder Gegenmaßnahmen geschützt werden.

Bild 2 zeigt ein Beispiel für Maschinenschnittstellen, die einem Angriff ausgesetzt sein können.

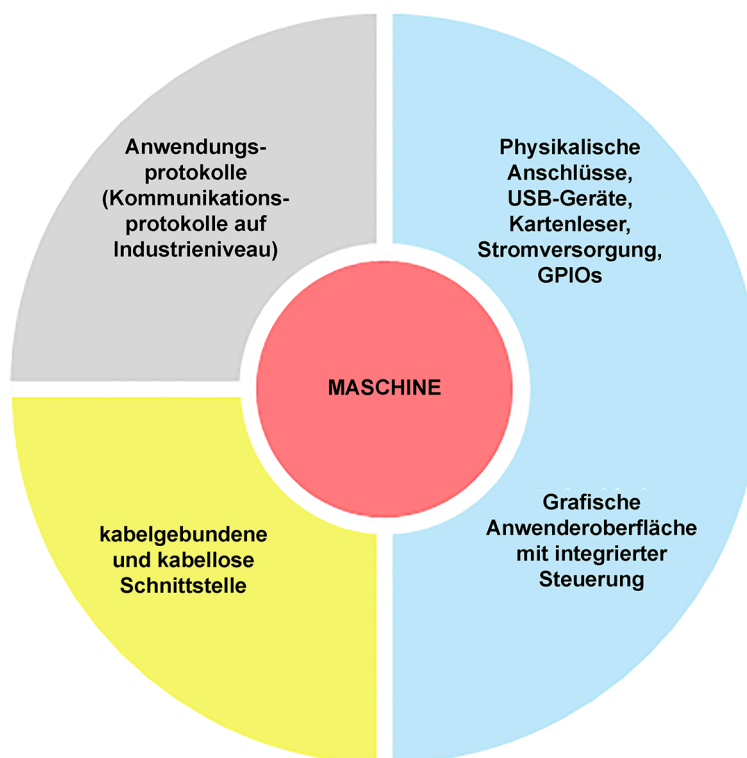


Bild 2 – Beispiel für Maschinenschnittstellen

Leitfäden zu Angriffen zweiter Ordnung sind in [Anhang C](#) enthalten.

7.2 Sicherheitsmaßnahmen

7.2.1 Allgemeines

Sicherheitsmaßnahmen zum Schutz vor Verfälschungen der Maschine, die zu Gefährdungssituationen führen können, müssen auf der Grundlage eines risikobasierten Ansatzes ausgewählt werden, um angemessen zu sein.

Dieser risikobasierte Ansatz muss im Zusammenhang mit dem bestimmungsgemäßen Gebrauch und dem Sicherheitskontext der Maschine sowohl Sicherheitsrisiken als auch Bedrohungsrisiken berücksichtigen.

Sicherheitsmaßnahmen dürfen die funktionale Sicherheit nicht beeinträchtigen.

7.2.2 Kryptographie

Bei der Verwendung kryptographischer Verfahren sollten nur Algorithmen auf dem neuesten Stand der Technik ausgewählt werden.

ANMERKUNG 1 Informationen zu Algorithmen auf dem neuesten Stand der Technik sind bei Organisationen wie ENISA www.enisa.europa.eu erhältlich. Eine Liste mit Beispielen kann der Bibliografie unter [\[2\]](#)[\[3\]](#)[\[4\]](#) entnommen werden.

ANMERKUNG 2 Bei der Implementierung einer kryptographischen Funktion kann geprüft werden, dass diese nicht aufgrund einer erhöhten Reaktionszeit der Sicherheitsfunktion zu Gefährdungen führt.

7.3 Erfassung von Informationen

7.3.1 Arten von Eingriffen

Die folgende Liste stellt die Arten von Eingriffen vor, die berücksichtigt werden müssen:

- a. Sicherheitsparametrierung/Konfigurationsparameter (über Identifikationsmittel wie CRC usw.),
BEISPIEL Anschließen oder Trennen eines Flash-Laufwerks oder einer SD-Karte, wenn diese zur Speicherung von Konfigurationsdaten und zur Protokollierung von Daten verwendet werden, die für die Konformität von Maschinen relevant sind.
- b. Aktualisierung/Änderung der SRESW (nur über Identifikationsmittel wie Versionsnummer, CRC usw.),
- c. Aktualisierung/Änderung der SRASW (nur über Identifikationsmittel wie Versionsnummer, CRC usw.),
- d. Parametrierung von Mensch-Maschine-Schnittstellen, wenn dadurch Gefährdungen entstehen können,
- e. Software, die für die Anzeige von Sicherheitsanweisungen relevant ist.

ANMERKUNG 1 Eingriffe, die keine Änderungen der oben aufgeführten Daten zur Folge haben, brauchen nicht protokolliert zu werden (z. B. erfolgreiche/erfolglose autorisierte Eingriffe).

ANMERKUNG 2 Aktionen an der Maschine, die einen sicheren Zustand der Maschine auslösen, z. B. das Auslösen eines Lichtvorhangs, fallen nicht in den Anwendungsbereich.

ANMERKUNG 3 Die Versionen der SRASW- oder SRESW-Binärdateien brauchen nicht im Nachverfolgungsprotokoll gespeichert zu werden.

7.3.2 Zu erfassende Nachweise von Eingriffen

Digitale Nachweise für legitime oder illegitime Aktionen oder Ereignisse, die das Verhalten, den Zustand oder den Betrieb der Maschine vorübergehend oder dauerhaft verändern oder unterbrechen und die Software oder Daten verändern, müssen aufgezeichnet werden und mindestens die folgenden Daten enthalten:

- a. Angabe der Art des Eingriffs, der sich auf die Software auswirkt, auf die nach der Risikobewertung zur Risikominderung zurückgegriffen wird,
- b. Mittel zur Korrelation protokollierter Ereignisse (z. B. Zeitstempel mit Bezug auf die absolute oder relative Systemzeit), Boot-Zähler, Systemzeiten, laufende Zähler,
- c. Löschung der Protokolldatei.

ANMERKUNG Der Zeitstempel kann vom Gerät, das das Protokollereignis erstellt, oder von einem entfernten Protokollierer bereitgestellt werden.

7.3.3 Anforderungen an die Protokollierung

Die Maschine muss digitale oder physische Mittel zur Rückverfolgbarkeit von Eingriffen bereitstellen.

Digitale Nachweise von Eingriffen müssen lesbar und zugänglich sein.

Die Dokumentation muss Angaben bereitstellen, wie auf die aufgezeichneten Nachweise zugänglich sind und interpretiert werden können.

Wenn ein binäres Format verwendet wird, sollte dessen Format als Teil der Anwenderinformation dokumentiert werden, so dass alle Beteiligten einen Konverter programmieren können, um diese Protokolle verständlich zu machen.

Wenn die Sammlung digitaler Nachweise nicht angemessen praktikabel ist, müssen physische Nachweise (z. B. von der Manipulation eines Siegels) verwendet werden.

Die Zusammenstellung von Nachweisen für Eingriffe ist erforderlich und muss automatisch durch die Maschine oder das zugehörige Produkt erfolgen.

ANMERKUNG Beispiele für anerkannte Branchenpraktiken zu Protokollnormen können [Anhang A](#) entnommen werden.

Die Protokollaufzeichnungen dürfen im [Steuerungssystem](#), in den Komponenten innerhalb der Maschine oder in einer Komponente zur Speicherung der Daten außerhalb der Maschine (z. B. in einem NAS (en: Network Attached Storage), auf einer lokalen Festplatte usw.) gespeichert werden.

7.3.4 Anforderungen an die Speicherdauer

Das Protokoll muss mindestens die Nachweise der letzten Intervention jeder Art enthalten.

Die Protokollaufzeichnungen jeder Intervention müssen mindestens fünf Jahre lang aufbewahrt werden.

Das Protokoll muss spätestens ab dem Zeitpunkt, zu dem die Maschine in Betrieb genommen wird, aktiviert sein.

7.3.5 Anforderungen an die Speichersicherheit

Protokolle müssen ordnungsgemäß gesichert werden, um sie vor Manipulationen zu schützen.

Das Löschen von Protokollen, sofern zutreffend, darf nur durch ein autorisiertes Verfahren möglich sein.

7.4 Schutzmaßnahmen gegen Verfälschungen

7.4.1 Allgemeines

Verfälschungen können die Integrität und Wirksamkeit der Maßnahmen zur Risikominderung beeinträchtigen und zu potenziell gefährlichen Folgen führen.

Um sich vor solchen Risiken zu schützen, muss zunächst das erforderliche Schutzniveau festgelegt werden.

Dazu müssen die Anfälligkeiten und die spezifischen Erfordernisse der jeweiligen Anwendung identifiziert und sicherheitsbezogene Sicherheitsstufen ([SRSL](#)) für die einzelnen Maßnahmen zur Risikominderung festgelegt werden.

Sobald das angemessene Schutzniveau ermittelt ist, können geeignete Maßnahmen zur wirksamen Minderung der Gefährdungen ergriffen werden.

Diese Maßnahmen dienen dazu, die Integrität und die Zuverlässigkeit des Steuerungssystems sicherzustellen.

7.4.2 Sicherheitsbezogene Sicherheitsstufen

Für jede identifizierte Sicherheitsfunktion muss eine sicherheitsbezogene Sicherheitsstufe ([SRSL](#)) bestimmt und dokumentiert werden.

Die Bestimmung des [SRSL](#) muss auf dem Ergebnis der Bedrohungsbeurteilung basieren und mit der durch die Schutzmaßnahme erzielten Risikominderung und der Wahrscheinlichkeit einer erfolgreichen Ausnutzung der Bedrohung in Beziehung gesetzt werden.

Es sind vier SRSLs festgelegt, wobei SRSL0 keine spezifischen zusätzlichen Anforderungen stellt und SRSL1 bis SRSL3 einer niedrigen bis hohen Sicherheitsstufe entsprechen.

ANMERKUNG [Anhang B](#) stellt eine Orientierungshilfe für die Bestimmung der [SRSL](#) bereit. Die Wahrscheinlichkeit einer erfolgreichen Ausnutzung einer Bedrohung kann als Angriffspotenzial (AP) ausgedrückt werden, das eine Funktion

mehrerer Parameter wie der Fähigkeiten des Angreifers (AC, en: Attacker Capability), des Zeitfensters (WoO, en: Window of Opportunity) und des Expositionspegels (EL, en: Exposure Level) ist.

Die mit einer angemessenen Sicherheitsstufe (SRSL) verbundenen Maßnahmen müssen so gewählt werden, dass die Sicherheitsfunktionen geschützt sind.

Tabelle 2 – SRSL-Beschreibung

SRSL	Beschreibung
SRSL0	Diese Stufe muss für vollständig isolierte Sicherheitssysteme verwendet werden. (Z. B. vollständig isolierte Netzwerke innerhalb der Maschine oder wenn Sicherheitsfunktionen keine externen Schnittstellen haben).
SRSL1	Diese Stufe (oder höher) muss zum Schutz von Sicherheitsfunktionen gewählt werden, wenn das Angriffspotenzial gering ist und ein Angriff nur unter ganz bestimmten Umständen erfolgen kann. Wenn die Schwere des Schadens umkehrbar ist, kann diese Stufe auch bei einem moderaten Angriffspotenzial ausgewählt werden, bei dem ein Angriff mit hinreichender Wahrscheinlichkeit erfolgen kann.
SRSL2	Diese Stufe (oder höher) muss zum Schutz von Sicherheitsfunktionen gewählt werden, wenn das Angriffspotenzial moderat ist und ein Angriff mit hinreichender Wahrscheinlichkeit erfolgen kann. Wenn die Schwere des Schadens umkehrbar ist, kann diese Stufe auch bei einem erheblichen Angriffspotenzial gewählt werden, bei dem ein Angriff mit hoher Wahrscheinlichkeit erfolgen kann.
SRSL3	Diese Stufe (oder höher) muss zum Schutz der Sicherheitsfunktionen gewählt werden, wenn das Angriffspotenzial erheblich oder kritisch ist und ein Angriff mit hoher Wahrscheinlichkeit oder nahezu mit Bestimmtheit erfolgen kann. Dies kann für die Verbindung zu nicht vertrauenswürdigen Netzwerken verwendet werden, z. B. für die Verbindung zum Internet.

7.4.3 Anforderungen an die Aufrechterhaltung der Sicherheit

7.4.3.1 Allgemeines

Die Maschinen müssen mindestens die unten aufgeführten Sicherheitsanforderungen erfüllen, die der festgelegten SRSL entsprechen.

Die Sicherheitsanforderungen müssen für ihre jeweiligen Sicherheitsfunktionen und ihre zugehörigen Schnittstellen gelten.

ANMERKUNG Schnittstellen können „logische Schnittstellen“ (Modbus/TCP, Webserver...) auf „physischen Schnittstellen“ (RJ45, USB) sein.

7.4.3.2 Anforderungen an die Authentifizierung

7.4.3.2.1 Authentifizierung

SRSL0:

Keine.

SRSL1:

Einheiten müssen authentifiziert sein.

SRSL2:

Einheiten müssen authentifiziert sein.

SRSL3:

Einheiten müssen eindeutig authentifiziert sein.

ANMERKUNG 1 In diesem Zusammenhang bezieht sich das Wort „Einheiten“ auf menschliche Anwender, auf Software-Prozesse oder auf Geräte, die in der Lage sind, in einen Prozess einzugreifen.

ANMERKUNG 2 Zu den Authentifizierungsmethoden gehören unter anderem: Kennwörter, PINs, Dongles, Biometriedaten, Zertifikate, RFIDs, NFCs, logische Identifikatoren (z. B. UID, HID, Cookies usw.) oder kryptographische Authentifizierungsmechanismen wie Random Challenge, TLS-Handshake, X509-Zertifikat usw.

7.4.3.3 Anforderungen an die Autorisierung**7.4.3.3.1 Sicherstellung der Autorisierung****SRSL0:**

Keine.

SRSL1:

Eingriffe müssen eine Autorisierung erfordern.

SRSL2:

Eingriffe müssen eine Autorisierung erfordern.

SRSL3:

Eingriffe müssen eine Autorisierung mit besonderen Privilegien erfordern (z. B. aufgabenbasierte Zugangskontrolle).

7.4.3.4 Anforderungen an die Integrität**7.4.3.4.1 Software- und Informationsintegrität****SRSL0:**

Keine.

SRSL1:

Die Integrität der Software und anderer kritischer Informationen, wie sicherheitsbezogene Konfigurationen, muss beim Anlaufen der Maschine geprüft werden (z. B. durch Verwendung von Prüfsummen).

SRSL2:

Die Integrität der Software und anderer kritischer Informationen, wie sicherheitsbezogene Konfigurationen, muss beim Anlaufen der Maschine und danach regelmäßig geprüft werden (z. B. durch Verwendung von Prüfsummen).

SRSL3:

Die Integrität der Software und anderer kritischer Informationen muss beim Anlaufen der Maschine und danach regelmäßig während des Betriebs kryptographisch geprüft werden (z. B. durch kryptographische Hashs, HMACs und/oder CMACs).

7.4.3.4.2 Integrität des Boot-Prozesses**SRSL0:**

Keine.

SRSL1:

Die Integrität des Boot-Vorgangs muss geschützt und beim Anlaufen verifiziert werden (z. B. durch Prüfsummen).

SRSL2:

Die Integrität des Boot-Vorgangs muss geschützt und beim Anlaufen verifiziert werden.

SRSL3:

Ein sicherer Boot-Vorgang muss implementiert werden (z. B. durch kryptographische Signaturprüfung mit vertrauenswürdigen Roots, durch ein Rollback-Verfahren oder durch Rückführung in einen sicheren Zustand bei fehlgeschlagener Verifizierung).

7.4.3.4.3 Integrität des Informationsaustauschs

SRSL0:

Keine.

SRSL1:

Die Integrität der ausgetauschten Informationen muss verifiziert werden.

SRSL2:

Die Integrität der ausgetauschten Informationen muss verifiziert werden.

SRSL3:

Die Integrität der ausgetauschten Informationen muss durch die Implementierung sicherer kryptographischer Protokolle gewährleistet werden, die veränderte oder wiederholte Nachrichten erkennen und zurückweisen.

7.4.3.4.4 Validierung der Eingabedaten

SRSL0:

Keine.

SRSL1:

Die Eingabedaten müssen anhand festgelegter Grenzen validiert werden.

Ungültige Eingabedaten müssen zurückgewiesen werden.

SRSL2:

Die Eingabedaten müssen streng validiert werden, einschließlich Syntax, Semantik, korrektes Format und Verifizierung des Datentyps.

Ungültige Eingabedaten müssen zurückgewiesen werden.

SRSL3:

Die Eingabedaten müssen einer strengen, umfeldbezogenen Validierung unterzogen werden, einschließlich syntaktischer, semantischer, grenzbezogener und protokollspezifischer Einschränkungen.

Ungültige Eingabedaten müssen zurückgewiesen werden.

7.4.3.4.5 Physische Manipulation

SRSL0:

Keine.

SRSL1:

Physische Manipulation muss beispielsweise durch ein gebrochenes Siegel erkannt werden.

SRSL2:

Physische Manipulation muss beispielsweise durch ein gebrochenes Siegel erkannt werden.

SRSL3:

Physische Manipulation muss beispielsweise durch ein gebrochenes Siegel erkannt werden.

7.4.3.5 Anforderungen an die Authentizität**7.4.3.5.1 Authentizität von SRESW bzw. SRASW****SRSL0:**

Keine.

SRSL1:

Keine.

SRSL2:

Die Authentizität kritischer Daten (z. B. SRESW bzw. SRASW und kritische Konfigurationsdaten) muss zum Zeitpunkt der Installation z. B. durch kryptographische Signaturen oder gleichwertige Maßnahmen überprüft werden.

SRSL3:

Die Authentizität kritischer Daten (z. B. SRESW bzw. SRASW und kritische Konfigurationsdaten) muss zum Zeitpunkt der Installation z. B. durch kryptographische Signaturen oder gleichwertige Maßnahmen überprüft werden.

7.5 Identifikation von Software-Versionen und Konfigurationen

Die Identifikation von Software-Versionen und Konfigurationsdaten, die für den Schutz vor Verfälschung relevant sind, muss auf Anfrage verfügbar sein. Software-Identifizierungen und Konfigurationsdaten müssen in lesbarer Form verfügbar sein, entweder über ein integriertes System oder über ein externes Tool.

ANMERKUNG 1 Ein Laptop oder ein Mobiltelefon mit einer leicht zugänglichen Anwendung kann als Beispiel für ein allgemein verfügbares Tool angesehen werden.

ANMERKUNG 2 Für die Identifizierung von Maschinen und zugehörigen Produkten über die Hardware des Systems ist eine Unterscheidung erforderlich.

8 Prozessanforderungen nach Ansatz B**8.1 Allgemeines**

Maschinen (nach der Festlegung im Anwendungsbereich dieses Dokuments) sind Systeme, die aus Komponenten bestehen. Die Normenreihe EN IEC 62443 legt die Anforderungen an Systeme und Komponenten sowie an die jeweiligen Rollen von Systemintegratoren und Lieferanten fest. Die Struktur der Normenreihe EN IEC 62443 stellt die Übereinstimmung zwischen System- und Komponentenanforderungen sicher. Dieser Abschnitt legt die Anforderungen sowohl an Maschinensysteme als auch an Maschinenkomponenten fest.

8.2 Maschinensysteme

Maschinensysteme müssen der Norm EN IEC 62443-3-3:2019 entsprechen und die in [Tabelle 3](#) aufgeführten Sicherheitsanforderungen für ihre Sicherheitsfunktion(en) erfüllen.

Tabelle 3

Grundlegende Anforderungen	Sicherheitsstufe	Sicherheitsanforderungen
FR 1 – Identifizierung und Authentifizierung (IAC)	SL-C2	SR1.1
FR 2 – Nutzungskontrolle (UC)	SL-C2	SR2.1, SR2.8, SR2.9
FR 3 – Systemintegrität (SI)	SL-C2	SR3.1, SR3.4, SR3.5, SR3.6
FR 4 – Vertraulichkeit der Daten	Keine.	Keine.
FR 5 – Eingeschränkter Datenfluss (RDF)	SL-C1	SR5.1
FR 6 – Rechtzeitige Reaktion auf Ereignisse (TRE)	SL-C1	SR6.1
FR 7 – Ressourcenverfügbarkeit (RA)	SL-C2	SR7.1, SR7.2

ANMERKUNG 1 In [Tabelle 3](#) sind für jede grundlegende Anforderung (FR, en: Foundational Requirement) die aufgeführten Sicherheitsanforderungen die erforderliche Teilmenge der Anforderungen, die nach der Festlegung in der Sicherheitsstufe festgelegt sind.

ANMERKUNG 2 Die wesentlichen Funktionen nach EN IEC 62443-3-3:2019 schließen Sicherheitsfunktionen von Maschinen ein.

8.3 Maschinenkomponenten

Maschinensysteme müssen der Norm EN IEC 62443-4-2:2019 entsprechen und die in [Tabelle 4](#) aufgeführten Sicherheitsanforderungen für ihre Sicherheitsfunktion(en) erfüllen.

Tabelle 4

Grundlegende Anforderungen	Sicherheitsstufe	Sicherheitsanforderungen
FR 1 – Identifizierung und Authentifizierung (IAC)	SL-C2	CR1.1, CR1.2
FR 2 – Nutzungskontrolle (UC)	SL-C2	CR2.1, CR2.6, CR2.8, CR2.9, CR2.12, EDR 2.13
FR 3 – Systemintegrität (SI)	SL-C2	CR3.1, CR3.4, CR3.5, CR3.6, EDR3.2, EDR3.11, EDR3.14
FR 4 – Vertraulichkeit der Daten	Keine.	
FR 5 – Eingeschränkter Datenfluss (RDF)	SL-C1	CR 5.1
FR 6 – Rechtzeitige Reaktion auf Ereignisse (TRE)	SL-C1	CR 6,1
FR 7 – Ressourcenverfügbarkeit (RA)	SL-C2	CR 7.1 , CR7.2

ANMERKUNG 1 In [Tabelle 4](#) sind für jede grundlegende Anforderung (FR) die aufgeführten Sicherheitsanforderungen die erforderliche Teilmenge der Anforderungen, die nach der Festlegung in der Sicherheitsstufe festgelegt sind.

ANMERKUNG 2 Die wesentlichen Funktionen nach EN IEC 62443-4-2:2019 umfassen die Sicherheitsfunktionen der Maschine.

Maschinenkomponenten müssen EN IEC 62443-4-2:2019, 4.2 „Unterstützung wesentlicher Funktionen“ ([CCSC 1](#)) und 4.4 „Minimal erforderliche Rechte“ ([CCSC 3](#)) entsprechen.

Ausgleichsmaßnahmen, die im Maschinensystem implementiert sind, dürfen zur Erfüllung der Sicherheitsanforderungen an Maschinenkomponenten nach EEN IEC 62443-4-2:2019, 4.3 (CCSC 2) berücksichtigt werden. Eine Maschinenkomponente darf einen niedrigeren SL-C-Wert als in [Tabelle 4](#) gefordert aufweisen, wenn diese Maschinenkomponente ein Teil eines Maschinensystems ist, das Ausgleichsmaßnahmen bereitstellt, die sicherstellen, dass dieses System den in [Tabelle 3](#) geforderten SL-C-Wert erfüllt. In diesem Fall müssen in der Anwenderinformation der Komponente die Erfordernisse von Ausgleichsmaßnahmen festgelegt und darüber hinaus angegeben werden, welche Sicherheitsanforderungen die Maschinenkomponente nicht erfüllt.

Maschinenkomponenten, die **sowohl für Sicherheitsfunktionen als auch für Nicht-Sicherheitsfunktionen** verwendet werden, müssen ebenfalls den Sicherheitsstufen oder Sicherheitsanforderungen der [Tabelle 4](#) entsprechen.

8.4 Identifikation

Die Identifikation von Software-Versionen und Konfigurationsdaten, die für Sicherheitsfunktionen relevant sind, muss auf Anfrage verfügbar sein. Software-Identifizierungen und Konfigurationsdaten müssen in lesbarer Form verfügbar sein, entweder über ein integriertes System oder über ein externes Tool.

ANMERKUNG Übliche externe Werkzeuge sind Laptops, tragbare Geräte oder Mobiltelefone mit einer leicht zugänglichen Anwendung.

8.5 Persistenz

Auditaufzeichnungen je nach EN IEC 62443-4-2:2019, 6.10 (CR 2.8 – „Prüfbare Ereignisse“) müssen mindestens 5 Jahre lang aufbewahrt werden.

ANMERKUNG Nach Festlegung des Anwendungsbereichs gilt die Anforderung der Persistenz nur für Sicherheitsfunktionen.

9 Anwenderinformation

Die Anwenderinformation muss Folgendes umfassen:

- Informationen über den Sicherheitskontext der Maschine,
- Identifikation von Software-Versionen und Konfigurationsdaten, die für Sicherheitsfunktionen relevant sind,
- Anweisungen für den Zugang zu Informationen über die für die Sicherheitsfunktionen relevanten Software-Versionen und Konfigurationsdaten sowie deren Änderungen,
- Informationen über die Erlaubnis und/oder das Verbot von Änderungen.

Anhang A (informativ)

Beispiele für Protokollformate

Dies ist ein informativer Anhang, der dem Leser der Norm weitere Informationen zu Protokollformaten bereitstellt.

Es ist jedoch nicht erforderlich, diese Beispiele zu befolgen, um die in diesem Dokument dargelegten grundlegenden Anforderungen zu erfüllen.

Allgemeines Protokollformat (CLF, en: Common Log Format): Das allgemeine Protokollformat ist ein Dateiformat, das zur Protokollierung von Webserver-Anfragen verwendet wird.

ANMERKUNG 1 Siehe auch RFC 6872. Für Beispiele siehe <https://www.rfc-editor.org/rfc/rfc6872>.

Syslog: Syslog ist ein Protokoll zum Aufzeichnen und Übertragen von Protokollmeldungen. Es ist auf einer Vielzahl von Systemen verbreitet. Viele Arten von Netzwerkgeräten, IoT-Systemen, Desktops und Servern unterstützen das Protokoll, und sein genormtes Klartextformat macht die Meldungen für Maschinen und Menschen leicht lesbar.

ANMERKUNG 2 Siehe auch RFC 5424.

Erweitertes W3C-Protokolldateiformat: Das erweiterte Protokolldateiformat wurde entwickelt, um folgende Erfordernisse zu erfüllen:

- Kontrolle über die aufgezeichneten Daten,
- Unterstützung von Proxys, Clients und Servern in einem gemeinsamen Format,
- Bereitstellung robuster Handhabung von Zeichen-Escape-Problemen,
- Austausch von demografischen Daten,
- Ausdruck von Zusammenfassungsdaten,

Das beschriebene Logdateiformat ermöglicht die Aufzeichnung anwenderdefinierter Protokolldateien in einem Format, das von generischen Analysewerkzeugen gelesen werden kann.

ANMERKUNG 3 Beispiele können hier eingesehen werden: <https://www.w3.org/TR/WD-logfile>

Allgemeines Ereignisformat (CEF, en: Common Event Format): Das allgemeine Ereignisformat ist ein Format nach Industriestandard, das von vielen Sicherheitsanbietern in Verbindung mit Syslog-Meldungen verwendet wird, um die Interoperabilität von Ereignissen zwischen verschiedenen Plattformen zu ermöglichen.

Das CEF ist ein standardisiertes Protokollformat, das von ArcSight (jetzt Teil von Micro Focus), einem Anbieter von Lösungen für Sicherheitsinformationen und Ereignismanagement (SIEM, en: Security Information and Event Management), entwickelt wurde. Es wurde entwickelt, um die Protokollierung sicherheitsbezogener Ereignisse zu vereinfachen und die Integration von Protokollen aus verschiedenen Quellen in einem zentralen System zu erleichtern. CEF basiert auf dem Syslog-Format, einem Standard für die Protokollierung von Meldungen, der von den meisten Netzwerkgeräten und Betriebssystemen unterstützt wird.

BSI-Mindeststandard für die Protokollierung und Erkennung von Cyberangriffen: Mit diesem Mindeststandard legt das BSI einen einheitlichen Ansatz zur Erkennung von Cyberangriffen fest, wie dies im Umsetzungsplan 2017 gefordert wird. Er schafft gleichzeitig eine Grundlage für die Festlegung und Implementierung organisatorischer und technischer Maßnahmen.

Anhang B
(informativ)

Beurteilung von Bedrohungen

Um angemessene und geeignete Anforderungen objektiv zu bestimmen, müssen zunächst die Vermögenswerte, der Sicherheitskontext und die Vertrauensgrenzen festgelegt und das System modelliert werden (z. B. mithilfe eines Datenflussdiagramms). Siehe hierzu z. B. die Beschreibungen in den entsprechenden Abschnitten in [Anhang C](#).

Die sicherheitsbezogene Sicherheitsstufe (SRSL) ist die wichtigste Eigenschaft, anhand der über die Angemessenheit und Eignung von Schutzmaßnahmen entschieden werden kann. Die Stufe bestimmt auch, welche böswilligen Versuche vernünftigerweise vorhersehbar sind und vor denen die Maschinen geschützt werden müssen.

Der erste zu festlegende Parameter ist der Expositionspegel, der proportional zur Angriffsfläche der betrachteten Schnittstelle und Verbindung ist.

Eine wirksame Strategie zur Verringerung des Expositionspegels von Sicherheitsfunktionen besteht darin, eine [Netzwerktrennung](#) zwischen sicherheitsbezogenen und nicht sicherheitsbezogenen Netzwerkteilen vorzunehmen.

Alle Verbindungen zu Sicherheitsfunktionen unterliegen der Bewertung.

Wenn eine Verbindung Vertrauensgrenzen ([C.6](#)) überschreitet, [gilt der höhere Expositionspegel](#). So wird eine Verbindung zwischen EL1 und EL2 als EL2 betrachtet.

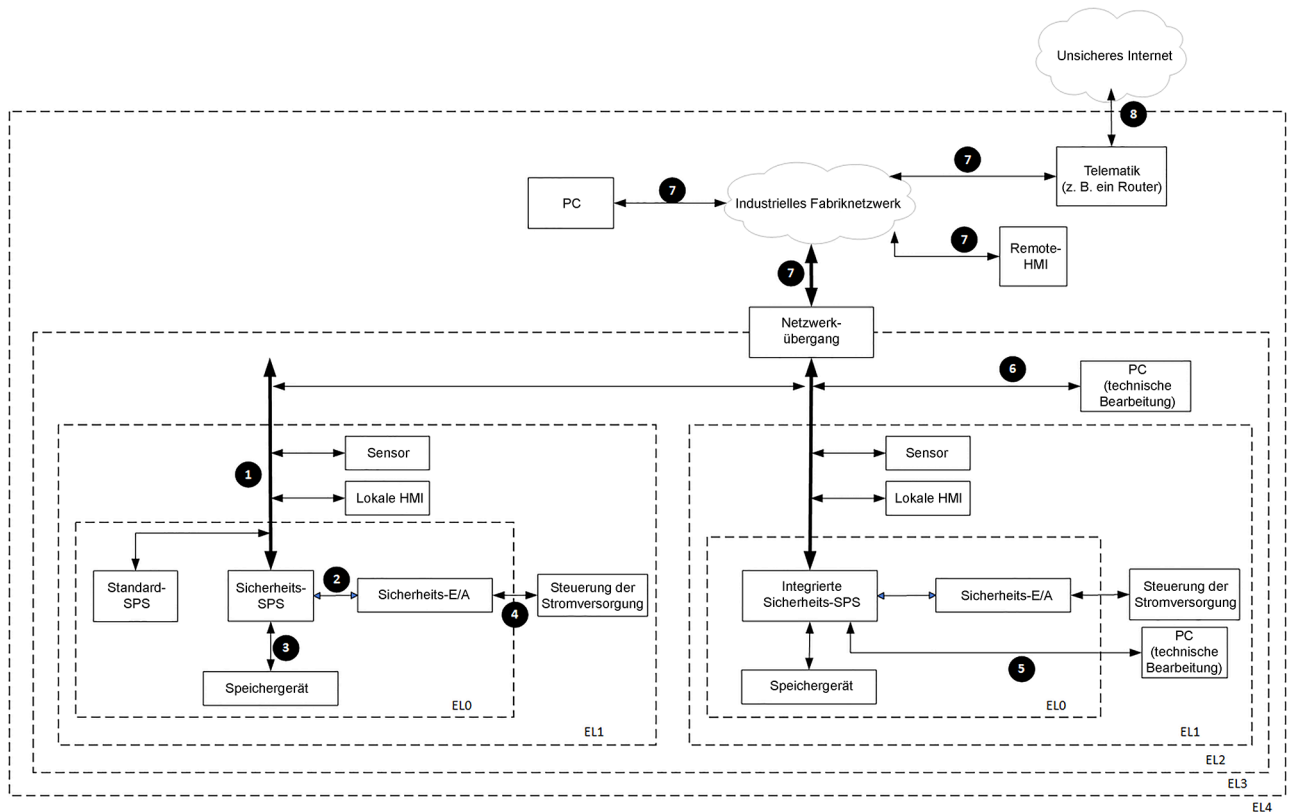
ANMERKUNG Eine weitere Netzwerksegmentierung innerhalb jeder EL-Stufe ist zulässig.

Tabelle B.1 – [Expositionspegel](#)

Art der Exposition	Expositionspegel	Beschreibung	Leitfaden
Intern	EL0	Vollständig vertrauenswürdige Umgebung	Komponenten und Netzwerke, die von außerhalb der Maschine nur mit einem Schlüssel oder Werkzeugen zugänglich sind.
Physisch	EL1	Physischer Zugang zur vertrauenswürdigen Umgebung	Jede Verbindungsschnittstelle, die sich an der Grenze der EL0-Umgebung befindet und eine physische Berührung oder Manipulation des Systems erfordert. Diese Ebene darf ungefähr den Ebenen 0 bis 1 des Purdue-Referenzmodells entsprechen. Beispiele: RJ45-Anschlüsse, USB-Schnittstellen, Displays und Tasten an der Maschine.

Art der Exposition	Expositionspegel	Beschreibung	Leitfaden
Lokal	EL2	Lokaler OT-Netzwerkzugang für die Fertigungssteuerung	Bus oder jede Art von industriellem Netzwerk, das zum Austausch von Daten zwischen Maschinen verwendet wird (z. B. zur Steuerung der physikalischen Prozesse). Ähnlich wie Stufe 2 des Purdue-Referenzmodells (Beispiel: Überwachungssteuerung durch SCADA-Systeme).
Benachbart	EL3	Erweitertes industrielles Fabriknetzwerk mit vielfältigen Sicherheitseigenschaften, das auf einen lokalen Standort begrenzt ist.	Entspricht Fertigungsbetriebssystemen, die Stufe 3 des Purdue-Modells ähneln. Diese Stufe entspricht der Grenze zwischen OT und IT.
Öffentlich	EL4	Fernzugang zur Maschine über ein nicht vertrauenswürdiges Netzwerk (z. B. das Internet)	Netzwerkübergangssysteme zum Herstellen eines Fernzugangs zu den Räumlichkeiten (EL3) zu/von einem nicht vertrauenswürdigen Netzwerk fallen in diese Kategorie.

Im Beispiel muss eine Prüfung für eine übliche Maschine erfolgen:



Legende

- 1 z. B. Ethernet-basiertes industrielles Netzwerk oder ein Feldbus
- 2 interne Rückplatte zwischen SPS und E/A-Modulen
- 3 Verbindung zwischen SPS und Speichergerät, z. B. SD-Kartenschnittstelle
- 4 Verbindung zwischen SPS und Speichergerät, z. B. SD-Kartenschnittstelle
- 5 z. B. USB (vorübergehend für technische Zwecke angeschlossen)
- 6 z. B. Ethernet (vorübergehend für technische Zwecke angeschlossen)
- 7 z. B. Ethernet-basiertes OT-Netzwerk
- 8 Verbindung zu anderen IT-Systemen

Bild B.1 – Beispiel für die Zuordnung des Expositionspegels zu einer Maschine

Die Wahrscheinlichkeit von Angriffen kann durch das Angriffspotenzial angegeben werden, das sowohl statische als auch dynamische Kennzahlen umfasst.

EL ist ein Indikator für die Angriffsfläche und somit eine statische Messzahl, während Beispiele für dynamische Messzahlen die Fähigkeiten des Angreifers und das Zeitfenster für einen Angriff sind.

Die Fähigkeiten des Angreifers sind die Fähigkeit, geeignete Mittel einzusetzen, um eine **Anfälligkeit** des betreffenden Systems auszunutzen, und hängen sowohl von den technischen Kenntnissen (Fähigkeiten) des Angreifers als auch von der richtigen Anwendung der erforderlichen Kenntnisse und Werkzeuge ab.

Die Kenntnisse des Angreifers können sich aufgrund schwerwiegender Sicherheitsvorfälle, wie z. B. der Weitergabe vertraulicher Informationen aus dem Inneren des Herstellerunternehmens, (sogar drastisch) ändern. In diesem Fall sollte der Hersteller die Gefährdungs-Risiko-Analyse aktualisieren, wenn die Maschine weiterhin auf den Markt gebracht wird (z. B. Serienfertigung), da sich die Randbedingungen der Analyse geändert haben.

Tabelle B.2 – Einstufung der Fähigkeiten des Angreifers

Fähigkeiten des Angreifers (AC)	Beschreibung	Beispiele	Wert
Umfassende Kenntnisse und fortgeschrittene Fähigkeiten	Verfügt über fortgeschrittene Fähigkeiten und ist in der Lage, umfassende und spezialisierte Kenntnisse des Systems (z. B. vollständige Produktspezifikationen, Systemarchitektur) abzurufen und anzuwenden.	Beispiel: böswilliger privilegierter Anwender, hochqualifizierter Hacker.	1
Mittlere Kenntnisse und spezifische Fähigkeiten	Verfügt über fortgeschrittene technische Fähigkeiten; kann verschiedene Werkzeuge für den Angriff einsetzen und Informationen abrufen oder verfügt über gute Systemkenntnisse.	Beispiel: ausgebildeter Techniker/Hacker mit gutem Zugang zu sensiblen Informationen.	2
Mittlere Kenntnisse und mittlere Fähigkeiten	Verfügt über mittlere technische Fähigkeiten; kann gängige Angriffswerkzeuge und öffentlich zugängliche Informationen nutzen oder verfügt über mittlere Kenntnisse des Systems.	Beispiel: erfahrener Hacker.	3
Geringe Kenntnisse und grundlegende Fähigkeiten	Verfügt nur über geringfügige Fähigkeiten, wie die Nutzung grundlegender Tools und über grundlegende Kenntnisse (z. B. übliche Arbeitsanweisungen).	Beispiel: Scriptkiddies, weniger erfahrene Hacker mit allgemeinen Kenntnissen.	4

Der Entwickler legt einen Sicherheitskontext ([Abschnitt 5](#), zusätzliche Informationen in [Anhang C, C.5](#)) fest, der sowohl die Gültigkeitsgrenzen der Analyse vorgibt als auch dem Anwender Empfehlungen für eine sichere Verwendung der Maschine bereitstellt.

Es ist möglich, ein Maß für das Zeitfenster (a-priori-Wahrscheinlichkeit) abzuleiten, in dem ein Angreifer einen erfolgreichen Angriff durchführen kann, d. h. ein Maß für die Ausnutzbarkeit in Verbindung mit der zeitlichen Verfügbarkeit.

Das Zeitfenster wird für die gesamte Maschine geschätzt und darf davon abhängen, wie und wie oft Wartungsarbeiten während der Lebensdauer der Maschine durchgeführt werden und wie vorhersehbar diese sind:

Tabelle B.3 – Einstufung des Zeitfensters

Zeitfenster (WoO)	Beschreibung	Multiplikator
Sehr eingeschränkt	Selten zugänglich oder unter ständiger Überwachung; sehr eingeschränkter praktischer Zugang.	0,6
Mäßig eingeschränkt	Gelegentliche, vorhersehbare Gelegenheiten (z. B. monatliche Instandhaltungsfenster mit moderater Zugangskontrolle).	0,8
Eingeschränkt	Regelmäßige Gelegenheiten (wöchentlicher/täglicher planmäßiger Zugang mit geringer Zugangskontrolle).	0,9
Nicht eingeschränkt	Offene Systeme mit häufigen Gelegenheiten oder ohne Zugangskontrolle.	1

Expositionspegel (EL) nach der Festlegung oben:

Tabelle B.4 – Einstufung des Expositionspegels

Art der Exposition	Wert
EL0 – Intern	0
EL1 – Physisch	2
EL2 – Lokal	5
EL3 – Benachbart	16
EL4 – Öffentlich	24

Die durch die **Verfälschung** einer **Maßnahme** zur Risikominderung verursachten Auswirkungen auf die Sicherheit, multipliziert mit dem Angriffspotenzial, ergeben das erforderliche sicherheitsbezogene Sicherheitsniveau, das auf die **Maßnahme** selbst anzuwenden ist.

ANMERKUNG 1 Für Maschinen werden üblicherweise SILs und PLrs verwendet, die das vom **Steuerungssystem** anzuwendende Maß der Risikominderung festlegen. Da die Analyse bereits in einer separaten Sicherheitsrisikobewertung durchgeführt wurde, ist es möglich, PLrs zu verwenden, um die Auswirkungen auf die Sicherheit, einschließlich der Beziehung zur Gesundheit und Sicherheit des Anwenders, auszudrücken (für die Zuordnung zwischen SIL und PLr siehe EN ISO 13849, Anhang A).

ANMERKUNG 2 Zur Festlegung des richtigen Niveaus der Sicherheitsfunktionen können auch andere Normen herangezogen werden, z. B. unter Bezugnahme auf ISO 25119.

Bei der Durchführung der Bedrohungsmodellierung nach **Anhang C**, Abschnitt A.4 müssen alle sicherheitsbezogenen Vermögenswerte aufgelistet werden. Die SRSls gelten je nach Sicherheitsfunktion und je nach Schnittstelle.

$$AP = (EL * WoO) + AC$$

Dabei ist

- EL der Expositionspegel (je Schnittstelle, je Verbindung)
- WoO das Zeitfenster (für die gesamte Maschine in Abhängigkeit vom Sicherheitskontext)
- AC die Fähigkeit des Angreifers

Tabelle B.5 – Einstufung des Angriffspotenzials

Einstufung des Angriffs- potenzials	Bezeich- nung	Beschreibung	Bedeutung
0 bis 5	AP0	Sehr gering	Minimales Angriffspotenzial, Angriff sehr unwahr- scheinlich
5,1 bis 10	AP1	Gering	Geringes Angriffspotenzial, Angriff nur unter ganz bestimmten Bedingungen wahrscheinlich
10,1 bis 15	AP2	Mittel	Mäßiges Angriffspotenzial, Angriff unter bestimm- ten Bedingungen wahrscheinlich
15,1 bis 20	AP3	Hoch	Erhebliches Angriffspotenzial, Angriff sehr wahr- scheinlich
> 20	AP4	Sehr hoch	Kritisches Angriffspotenzial, Angriff nahezu be- stimmt

BEISPIEL

(Darstellung einer einfachen Maschine im Bild oben)

Angenommen, der Zugang zur Maschine ist mäßig eingeschränkt → WoO-Multiplikator = 0,8

Unter Berücksichtigung der Busverbindung zwischen der Sicherheits-SPS und den normalen SPS/HMI/Sensoren, die zwischen EL1 und EL2 liegt → EL2 wird ausgewählt

Unter Berücksichtigung minimaler Kenntnisse und grundlegender Fähigkeiten zur Ausnutzung der Anfälligkeit (4)

$AP = (5 \cdot 0,8) + 4 = 8 \rightarrow AP11$

Tabelle B.6 – Festlegung der Zuordnung von SRSLs nach Sicherheitsfunktionen und Angriffspotenzial

		Angriffspotenzial (AP)				
		AP0	AP1	AP2	AP3	AP4
Grad des Schadensausmaßes	Niedrig, z. B. umkehrbar	SRSL0	SRSL1	SRSL1	SRSL2	SRSL3
	Hoch, z. B. unumkehrbar	SRSL0	SRSL1	SRSL2	SRSL3	SRSL3

Anhang C (informativ)

Bedrohungsmodellierung für Sicherheitssysteme

C.1 Allgemeines

Dieser Anhang stellt Beispiele für einen Prozess zur Ermittlung geeigneter und angemessener Maßnahmen zum Schutz einer Maschine vor [Verfälschung](#) bereit.

C.2 Risikobezogene Sicherheitsbewertung

[Bild C.1](#) unten erläutert den Prozess der risikobezogenen Sicherheitsbewertung unter Verwendung der STRIDE-Methodik zur Bedrohungsmodellierung. Andere Methoden zur Bedrohungsmodellierung sind ebenfalls gültig.

Risikobezogene Sicherheitsbewertung

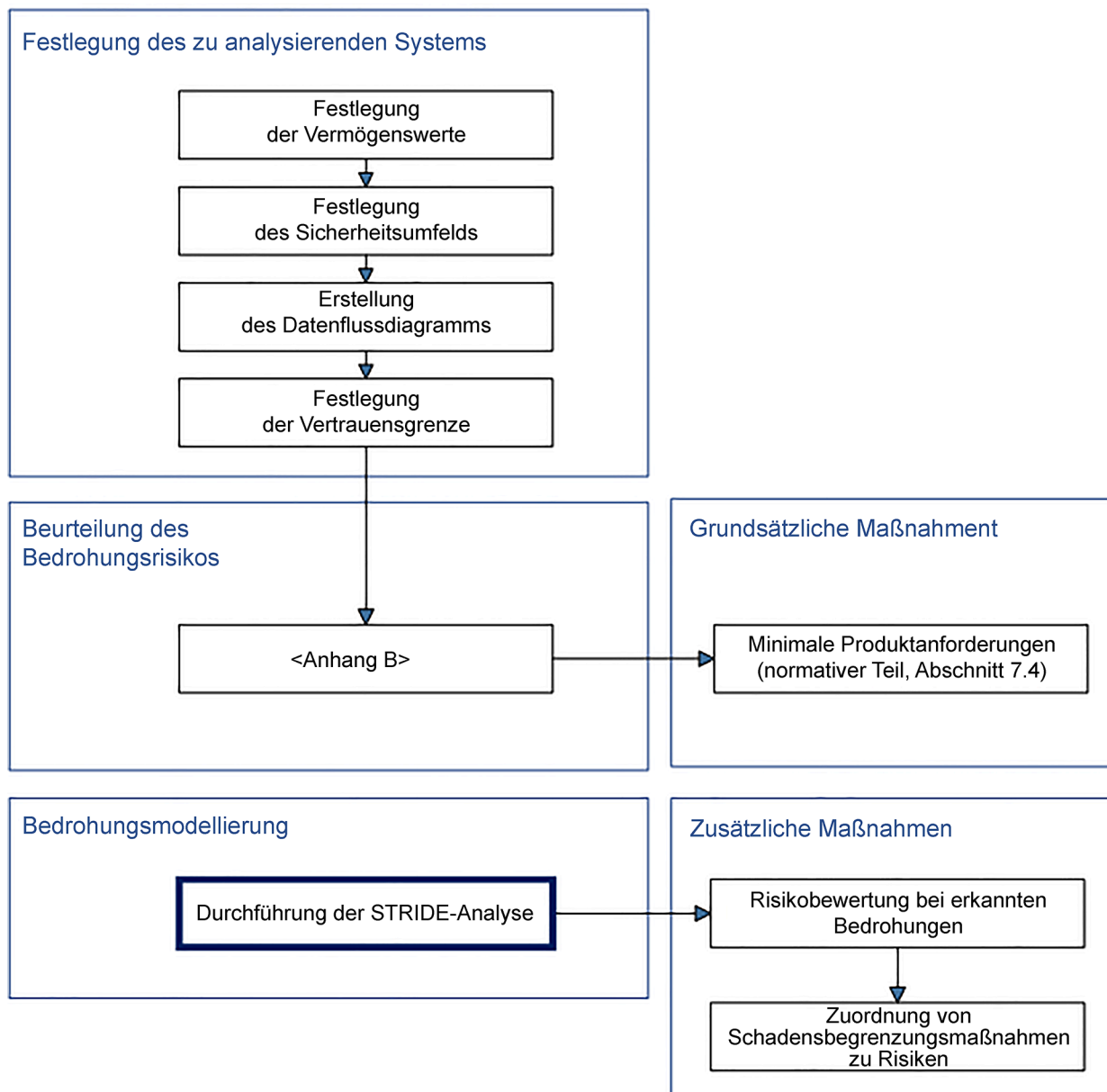


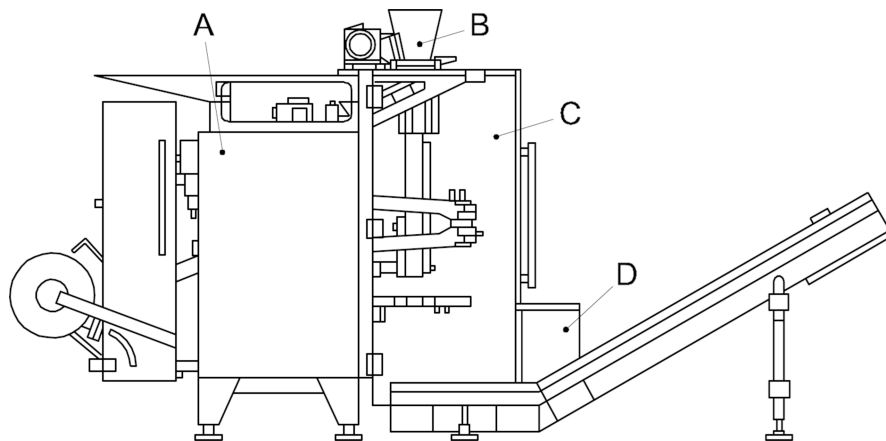
Bild C.1

Der hervorgehobene Kasten in Bild C.1 bezieht sich speziell auf die Verwendung des in diesem Anhang beschriebenen STRIDE-Ansatzes. Dies darf durch andere geeignetere Methoden als STRIDE ausgetauscht werden, um Bedrohungen zu identifizieren und die gleichen Ziele zu erreichen.

C.3 Einführung in die Beispiele

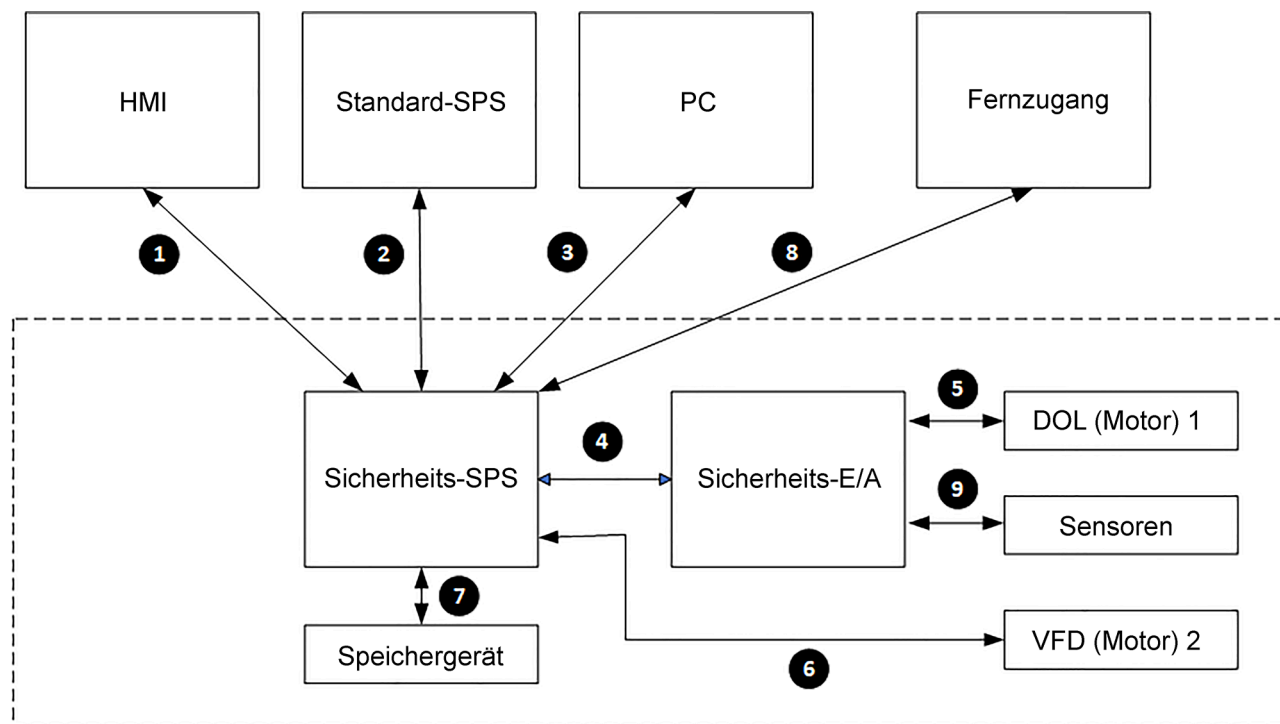
C.3.1 Allgemeines

Dieses Verfahren wird anhand von zwei verschiedenen Beispielen für Maschinen veranschaulicht, wobei der Schwerpunkt auf der Verhinderung der Verfälschung von Sicherheitsfunktionen liegt.

C.3.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine**Bild C.2 – Beispiel für eine branchenübliche vertikale Form-, Füll- und Verschleißmaschine**

Quelle: EN 415-3:2022, Bild 21.

Eine einfache Form-, Füll- und Verschleißmaschine, bestehend aus einer Sicherheits-SPS und einem Motor, die in Innenräumen in einer Industrieanlage eingesetzt wird.



Legende

- 1 z. B. Industrial Ethernet oder intern
- 2 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 3a USB-Konfigurationsschnittstelle (lokaler Zugang)
- 3b Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Rückplatte
- 5 Digitaler Gleichstromausgang und Motor-Feedback
- 6 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit oder PROFIsafe)
- 7 SD-Kartenschnittstelle
- 8 Fernzugang, z. B. über das Unternehmensnetzwerk oder das Internet
- 9 Direkter Digitaleingang für Sensoren (Verriegelung, Auslaufbehälter, Auslaufband, Not-Halt-Schaltung)

Bild C.3

Beschreibungen:

- Die Standard-SPS darf Status- und Diagnosedaten von der Sicherheits-SPS empfangen.
- Die Standard-SPS darf Standard-Betriebsparameter an die Sicherheits-SPS senden, wodurch sich unter Umständen der Betriebsmodus der Maschine ändert (z. B. Betriebsmodus, Parkmodus usw.).
- Die Verbindung zwischen der grafischen Anwenderoberfläche und den SPSen wird in erster Linie für Informationen (Status, Alarmer, Meldungen usw.) genutzt, die Sicherheitskonfiguration erfolgt über andere Schnittstellen.
 - Diese einfache Maschine verfügt über keine webbasierten Schnittstellen.
- Sicherheitsfunktionen, die als Maßnahmen zur Risikominderung für eine bestimmte Gefährdung der Maschine festgelegt sind. In diesem Beispiel wird die Sicherheitsfunktion aus EN 415-3:2021, 4.3.10 (vertikale Form-, Füll- und Verschleißmaschine) verwendet:
 - Stoppen der Siegel-, Perforier- und Schneidemechanismen, wenn die verriegelte trennende Schutzeinrichtung geöffnet wird.
 - Verhindern eines unerwarteten Anlaufs der Siegel-, Perforier- und Schneidemechanismen, wenn die verriegelte trennende Schutzeinrichtung geöffnet ist.

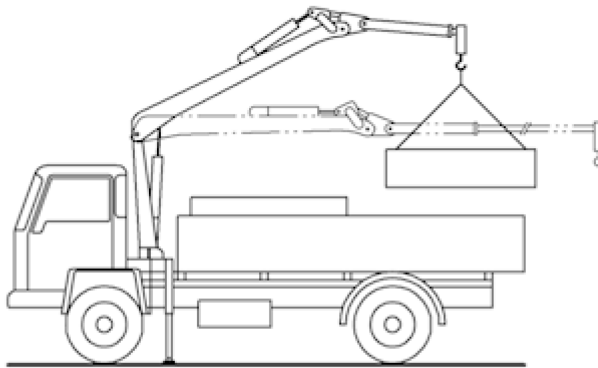
- Trennen und Ableiten der Energie aus dem Entstörer, wenn die verriegelte trennende Schutteinrichtung geöffnet wird.
- Stoppen der Siegel-, Perforier- und Schneidemechanismen, wenn das Auslaufband nicht korrekt platziert ist.
- Stoppen des Transportmechanismus für das Verpackungsmaterial, wenn die verriegelte trennende Schutteinrichtung geöffnet wird.
- Stoppen des Entladebands, wenn die verriegelte trennende Schutteinrichtung geöffnet wird.
- Stoppen aller gefährdenden Prozesse durch den Not-Halt-Schaltkreis.

C.3.3 Beispiel 2: Funksteuerung für Ladekran

Dieses Beispiel soll die Auswirkungen einer vergrößerten Angriffsfläche auf das Bedrohungsmodell aufzeigen, die sowohl auf eine weniger strenge physische Zugangskontrolle als auch auf eine anfälligere Funkkommunikationsschnittstelle zurückzuführen ist.

Der Ladekran ist auf einem Lkw montiert. Er wird in der Regel im Freien eingesetzt, und das Kran-Bauteil kann ferngesteuert werden.

ANMERKUNG Obwohl Funksteuerungssysteme für eine Vielzahl von Kranen verwendet werden, werden in diesem Beispiel nur Ladekrane betrachtet, um das Beispiel einfach und übersichtlich zu halten.



Quelle: ISO/DIS 4306-1:2023, 4.1.10

Bild C.4 – Beispiel für die Funksteuerung eines Ladekrans

Beschreibung:

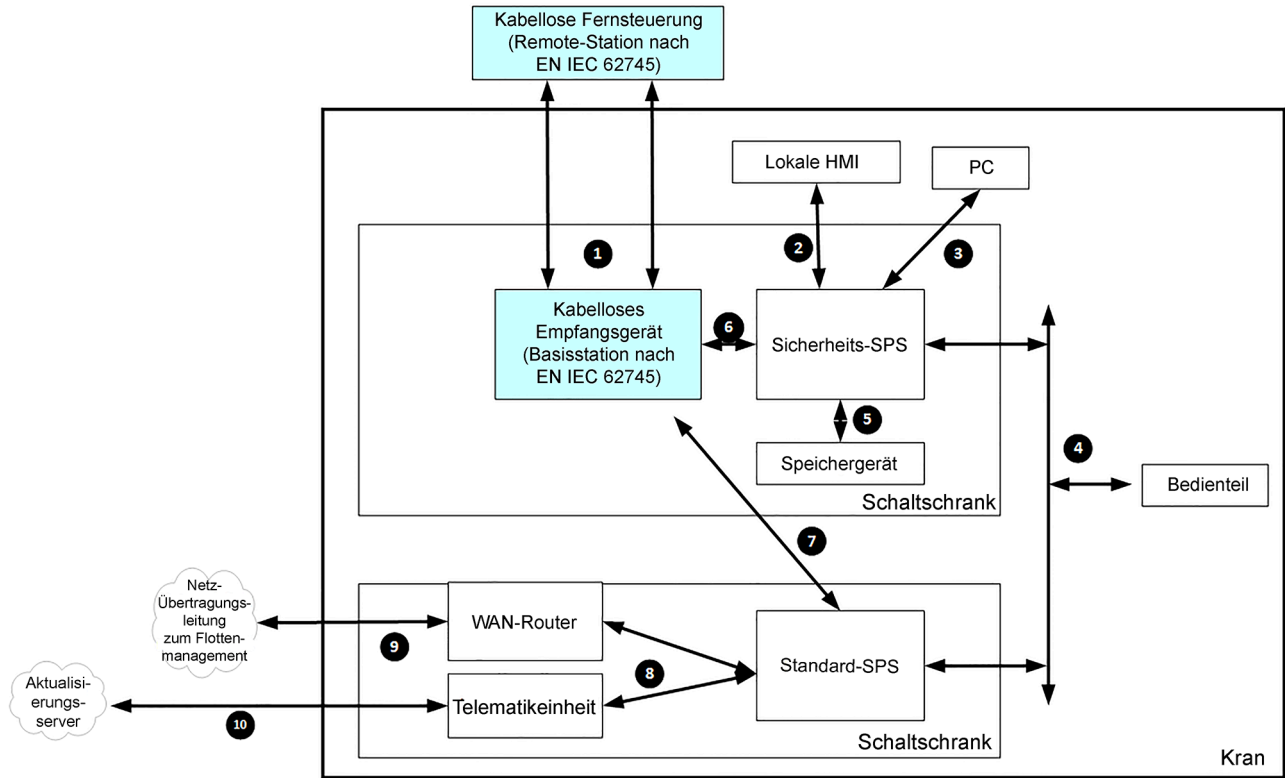
Ladekrane mit kabelloser Steuerung weisen viele branchenspezifische Besonderheiten auf, die durch entsprechende Normen geregelt sind. Dieses Beispiel konzentriert sich auf zwei Elemente, da die internen Gefährdungen bereits in Beispiel 1 beurteilt wurden:

- Die Anbindung der kabellosen Steuerung nach EN 62745 besteht aus
 - einer kabellosen Handsteuerung zum Bedienen des Krans
 - eines Empfangsgeräts für kabellose Handsteuerung
- Die Maschine wird üblicherweise in öffentlich zugänglichen Bereichen ohne Zugangskontrollen wie Parkplätzen, Straßenrändern oder Baustellen eingesetzt.

ANMERKUNG Hersteller von Ladekranen erwerben in der Regel die Fernsteuerungssysteme und erwarten, dass diese unter Berücksichtigung der Sicherheit entwickelt wurden. Daher konzentriert sich dieses Beispiel auf die korrekte Anwendung dieser Geräte.

- Steuerungen werden als „Black Box“ behandelt. Das Bedrohungsmodell muss nur die Probleme umfassen, die durch falsche Anwendung oder Missbrauch entstehen können.

- Zu den Anforderungen gehört die Authentifizierung, so dass sich der Bediener beispielsweise authentifizieren muss, bevor der Kran gesteuert werden kann.

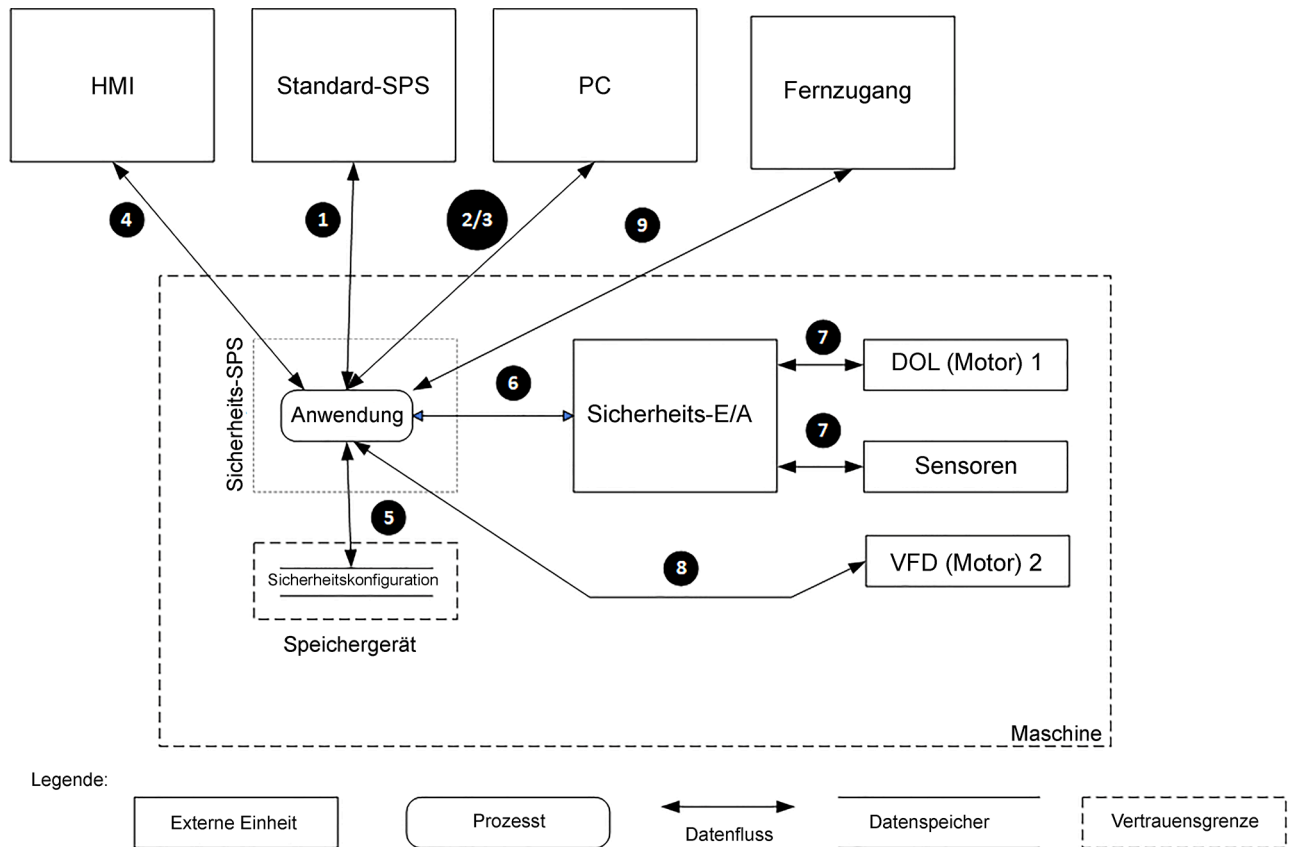


Legende

- 1 kabellose Verbindung
- 2 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 3a USB-Konfigurationsschnittstelle am Verlängerungskabel (lokaler Zugang) oder
- 3b Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit oder PROFIsafe)
- 5 SD-Kartenschnittstelle
- 6 festverdrahteter E/A
- 7 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit oder PROFIsafe)
- 8 Ethernet
- 9 WLAN zum OT-Netzwerk des Unternehmens (Anmerkung: Dies ist nicht üblich für Ladekrane, sondern eher für Flurförderzeuge, die in Lagerhäusern eingesetzt werden. Hier wird es als Beispiel für WAN-Verbindungen mit unterschiedlichen Expositionspegeln aufgeführt).
- 10 WLAN + Router zum Internet oder direkte Internetverbindung (z. B. über LTE)

Bild C.5

ANMERKUNG Die Fernbedienungsfunktion ist in der Abbildung hervorgehoben und wird durch eine Steuereinheit nach EN 62745, Bild A.1 realisiert.



Quelle: EN IEC 62745:2017, Anhang A.

Bild C.6

C.3.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.3.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.4 Vermögenswerte

C.4.1 Allgemeines

Das Ergebnis einer Analyse wird eine Liste von Komponenten (Vermögenswerten) aufzeigen, die Auswirkungen auf die Sicherheit haben (siehe Bild 1, 1.b).

Diese Liste kann Vermögenswerte wie Verriegelungen, Druckmesser, Temperatursensoren und Bewegungssteuerungen enthalten.

ANMERKUNG Die Vermögenswerte werden für alle Anwendungsfälle in allen Lebenszyklusphasen berücksichtigt, wie Inbetriebsetzung, Normalbetrieb, Entsorgung usw. (siehe EN ISO 12100:2010, Tabelle B.3).

C.4.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine

In diesem Beispiel werden die sicherheitsbezogenen Vermögenswerte wie folgt identifiziert:

- Sicherheitskonfigurationsdaten,
- [sicherheitsbezogene Anwendungs-Software](#),
- Konfigurationsspeichergeräte (z. B. SD-Karte in s-SPS),
- sicherheitsbezogene eingebettete Software (Firmware in Sicherheitsgeräten),
- Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...),
- Schalter zum Aktivieren des technischen Modus, der eine Ausgangssimulation oder ähnliches ermöglicht,
- Sicherheitsfunktionen, die als Schadensbegrenzungsmaßnahmen für eine bestimmte Gefährdung der Maschine festgelegt sind.

C.4.3 Beispiel 2: Funksteuerung für Ladekran

In diesem Beispiel werden die sicherheitsbezogenen Vermögenswerte wie folgt identifiziert:

- Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger

ANMERKUNG EN 62745, 4.3 verlangt Maßnahmen gegen zufällige [Verfälschung](#).

- Zugang zur Fernbedienung

ANMERKUNG EN 62745, 4.2.2 verlangt dies ebenfalls.

C.4.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.4.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.5 [Sicherheitsumfeld](#)

C.5.1 Allgemeines

Das [Sicherheitsumfeld](#) hängt vom Verwendungszweck und der Anwendung ab und umfasst unter anderem:

- Schutz der Grenzen des Sicherheitsumfelds, falls zutreffend;
- alle Maßnahmen im Hinblick auf die Interaktion zwischen verschiedenen Funktionseinheiten innerhalb des Sicherheitsumfelds;
- alle anzuwendenden Maßnahmen innerhalb des Sicherheitsumfelds.

Die durch das [Sicherheitsumfeld](#) bereitgestellten Maßnahmen sind wirksam, solange die Annahmen der folgenden Art dokumentiert und erfüllt sind:

- a) physische und logische Zugangsverwaltung für die Zielanwender,
- b) bestimmungsgemäßer Gebrauch und vernünftigerweise vorhersehbarer Missbrauch.
- c) physische Umgebung einschließlich Ausgleichsmaßnahmen,
- d) logische Umgebung einschließlich Ausgleichsmaßnahmen,
- e) Leitlinien und Verfahren.

ANMERKUNG „[Sicherheitsumfeld](#)“ ist das Sicherheitsäquivalent zu „bestimmungsgemäßem Gebrauch“ in der Sicherheitsdomäne.

Im Folgenden finden Sie Beispiele (keine vollständige Liste) und Überlegungen zu den Annahmen im Hinblick auf die Maßnahmen, die im [Sicherheitsumfeld](#) bereitgestellt werden.

- a) physische und logische Zugangsverwaltung für die Ziellanwender
 - alle Beteiligten
 - befugtes Personal
 - Servicetechniker
- b) bestimmungsgemäßer Gebrauch und vernünftigerweise vorhersehbarer Missbrauch
 - Verwendung einer permanenten Ferndiagnoseverbindung zur Überwachung
- c) **physische Umgebung** einschließlich Ausgleichsmaßnahmen
 - Standort
 - im Freien: Landwirtschaft, Forstwirtschaft, Baustellen, ...
 - öffentliche Gebäude, Krankenhäuser, Schulen, ...
 - öffentliche Verkehrsmittel, Flughäfen, Züge, ...
 - Räumlichkeiten mit Zugangsbeschränkungen (Zugang nur für Personen mit Ausweis und Authentifizierung usw.): Industrieanlagen, Logistikzentren, Lagerhäuser, ...
 - besondere Beschränkungen
 - verschlossene Schaltschränke
 - Unterscheidung zwischen Schlössern mit allgemeinen und mit spezifischen Schlüsseln.
 - innerhalb des Maschinengehäuses
 - physischer Standort
 - statisch
 - mobil
 - autonomer Betrieb
- d) **logische Umgebung** einschließlich Ausgleichsmaßnahmen
 - Zugang nur über VPN zulässig?
 - ständige Verbindung oder nur auf Anforderung?
 - ist eine Art Firewall erforderlich, wenn eine Verbindung zu einem nicht vertrauenswürdigen Netzwerk hergestellt wird?
 - Liste mit allen direkten oder indirekten, logischen und physischen Netzwerkverbindungen
 - wie soll das Netzwerk installiert werden (Zugang zu Kabeln, Kommunikationspartner usw.)?
- e) **Leitlinien und Verfahren**
 - z. B. Durchsetzung bestimmter Anforderungen an die Komplexität und Länge von Kennwörtern.

Nach Berücksichtigung aller Überlegungen können die Fähigkeiten des Angreifers nach [Anhang B](#), [Tabelle B.2](#) und [Tabelle B.3](#) für einen erfolgreichen Angriff während eines bestimmten Zeitfensters eingeschätzt werden.

C.5.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine

- Diese Maschine ist für den Einsatz in einer Industrieanlage mit standardmäßiger Zugangskontrolle vorgesehen, so dass sich nur authentifiziertes und autorisiertes Personal der Maschine nähern darf.
- Die SPS befindet sich in einem verschlossenen Schaltschrank mit einem speziellen Schlüssel, der nur an autorisiertes Personal ausgehändigt wird. (EL0 nach [Anhang B](#)).
- Die Netzkabel zwischen Motorantrieb und Sicherheits-SPS befinden sich im Inneren der Maschine und sind von außen nicht zugänglich, ohne dass die Maschine zerlegt wird. (EL0 nach [Anhang B](#)).

- Die Verbindung zu den Konfigurationsschnittstellen wird nur zeitweise hergestellt, und zwar ausschließlich für Servicezwecke und zur Fehlerbehebung.
 - Bei einer direkten Verbindung (Ethernet oder USB) zwischen einem PC und der SPS kann von EL1 ausgegangen werden.
 - Die USB-Schnittstelle, über die die SPS konfiguriert werden kann, ist über ein Verlängerungskabel mit der Kante des Schaltschranks verbunden und somit für Personen mit physischem Zugang zugänglich, wodurch sich der Expositionspegel nach [Anhang B](#) von EL0 auf EL1 erhöht.
 - Die Fernkonfigurationsverbindung wird nur mit einem direkten Ethernet-Kabel oder über ein gesichertes Fernzugangsmittel (z. B. ein VPN) hergestellt.
 - Die gesicherte Fernzugangsverbindung bleibt stromlos, wenn keine Verbindung benötigt wird (wodurch das Zeitfenster verkürzt wird).
 - Wenn ein Fernzugang erforderlich ist, könnte der Expositionspegel beispielsweise EL4 betragen.
 - Dann muss die gesicherte Fernzugangsverbindung Maßnahmen zur Verringerung des Risikos von EL4 mit angemessenen Maßnahmen nach 5.4 bereitstellen.
- Die Verbindung zur Standard-SPS wird für Diagnose- und Standardsteuerungsaktivitäten permanent aufrechterhalten.
- Das Speichergerät, auf dem die Sicherheitskonfiguration gespeichert ist, befindet sich in der SPS im verschlossenen Schaltschrank.

C.5.3 Beispiel 2: Funksteuerung für Ladekran

- Der Ladekran wird üblicherweise im Freien in öffentlich zugänglichen Bereichen ohne physische Zugangskontrollen eingesetzt.
- Die Fernbedienung für den Kran kann im Freien verwendet werden.
- Das Empfangsgerät befindet sich in einem verschlossenen Kasten.
- Wenn der Kran nicht in Betrieb ist, wird das kabellose [Steuerungssystem](#) nicht mit Strom versorgt.
- Wenn der Kran verwendet wird, muss der Bediener den Arm sehen können.

C.5.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.5.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.6 Datenflussdiagramme

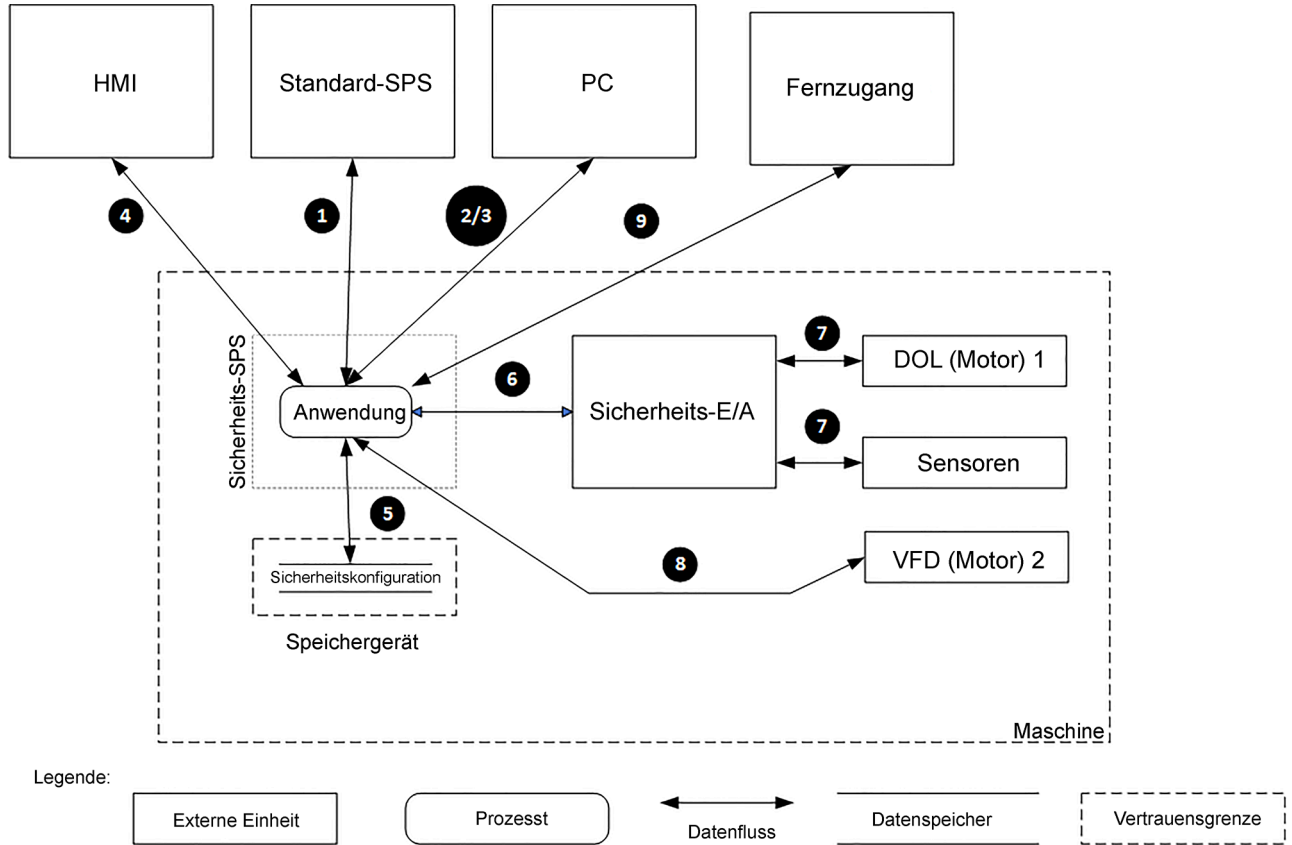
C.6.1 Allgemeines

Es wird ein Datenflussdiagramm gezeichnet, in dem alle Kommunikationswege und Elemente detailliert dargestellt sind.

1. Zeichnung aller Vermögenswerte,
2. Zeichnung aller berücksichtigter Elemente
 - a. Datenspeicher
 - b. Prozesse
 - c. Akteure

- d. Netzwerkgeräte
 - e. Datenflüsse.
3. Zeichnung der logischen und physischen Vertrauensgrenzen (siehe nächster Abschnitt).

C.6.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine

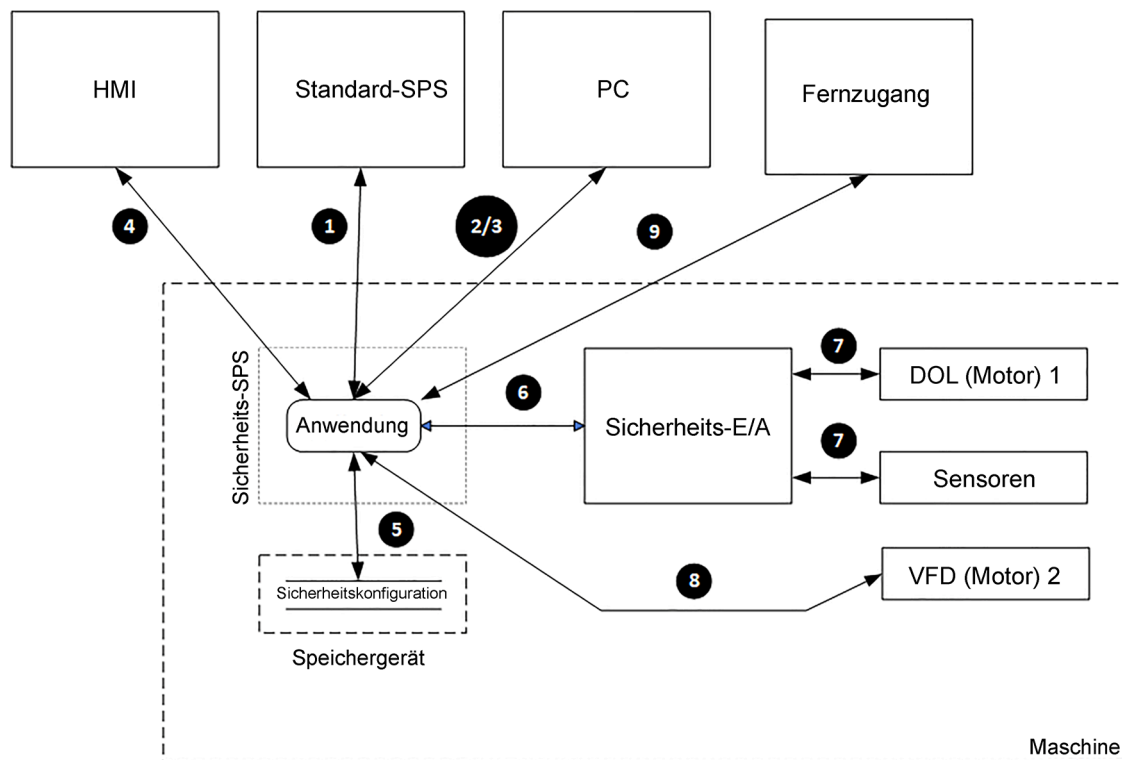


Legende

- 1 Industrial Ethernet (z. B. Ethernet/IP, EtherCAT oder PROFINET)
- 2 USB-Konfigurationsschnittstelle (lokaler Zugang)
- 3 Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Industrial Ethernet (z. B. Ethernet/IP, EtherCAT oder PROFINET)
- 5 SD-Kartenschnittstelle
- 6 Interne Rückplatte
- 7 Digitaler Gleichstrom-E/A, 24 V
Digitaler Gleichstromausgang und Motor-Feedback
Direkter Digitaleingang für Sensoren (Verriegelung, Auslaufbehälter, Auslaufband, Not-Halt-Schaltung)
- 8 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit, FSoE oder PROFIsafe)
- 9 Fernzugang, z. B. über das Unternehmensnetzwerk oder das Internet

Bild C.7

C.6.3 Beispiel 2: Funksteuerung für Ladekran



Legende

- 1 kabellose Verbindung
- 2 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 3a USB-Konfigurationsschnittstelle am Verlängerungskabel (lokaler Zugang) oder
- 3b Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit oder PROFI-safe)
- 5 SD-Kartenschnittstelle
- 6 direkt festverdrahteter E/A
- 7 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 8 Ethernet
- 9 WLAN zum OT-Netzwerk des Unternehmens (Anmerkung: Dies ist nicht üblich für Ladekrane, sondern eher für Flurförderzeuge, die in Lagerhäusern eingesetzt werden. Hier wird es als Beispiel für WAN-Verbindungen mit unterschiedlichen Expositionspegeln aufgeführt.
WLAN + Router zum Internet oder direkte Internetverbindung (z. B. über LTE)

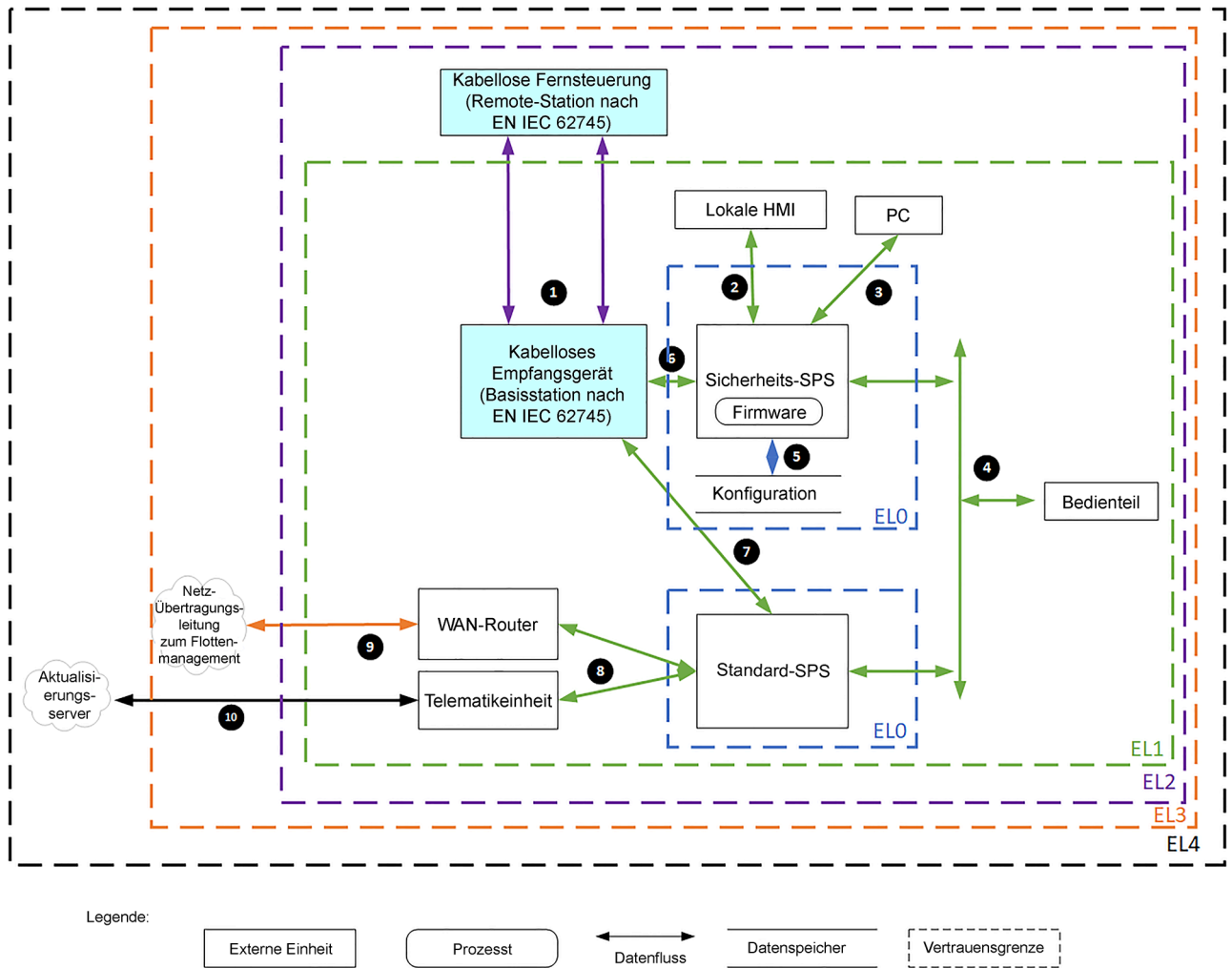


Bild C.8

C.6.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.6.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.7 Vertrauensgrenzen

C.7.1 Allgemeines

Vertrauensgrenzen identifizieren Bereiche mit einem ähnlichen Vertrauensniveau und isolieren sie von anderen Bereichen mit einem anderen Vertrauensniveau. Dies gilt für physische und logische Eigenschaften. Üblicherweise ist dies ein Bestandteil des Datenflussdiagramms, kann jedoch auch als separater Schritt betrachtet werden.

Die Gruppierung von Vermögenswerten in Zonen und Conduits dient dazu, die Anlagen zu identifizieren, die gemeinsamen Sicherheitsanforderungen unterliegen, und die Identifizierung der gemeinsamen Sicherheitsmaßnahmen zur Verringerung des Risikos zu ermöglichen.

ANMERKUNG Das Datenflussdiagramm enthält in der Regel die Vertrauensgrenzen des betrachteten Systems.

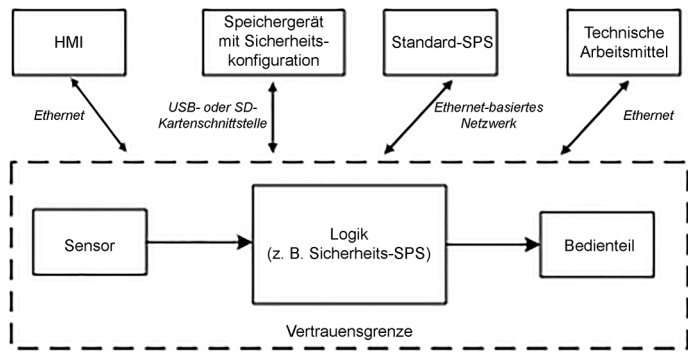


Bild C.9

ANMERKUNG Grenze: Rand
Zone: Bereich innerhalb einer Grenze

In praktischen Beispielen werden mehrere verschiedene Vertrauensgrenzen betrachtet. Diese Vertrauensgrenzen entsprechen den verschiedenen Angriffsflächen und können mit den in [Anhang B](#) festgelegten Expositionspegeln gekennzeichnet werden.

Die Beispiele zeigen, im Hinblick auf die Systemelemente, wie diese von den vertrauenswürdigsten bis zu den am stärksten exponierten Bereichen zu betrachten sind.

C.7.2 Beispiel 1: Einfache Maschine

In diesem Beispiel wird alles innerhalb der Maschine als vollständig vertrauenswürdige Umgebung betrachtet, da für den Zugang eine Art Authentifizierung erforderlich ist, z. B. ein eindeutiger Schlüssel oder ein spezielles Werkzeug zum Öffnen der Maschine oder eine Art Software-Authentifizierung.

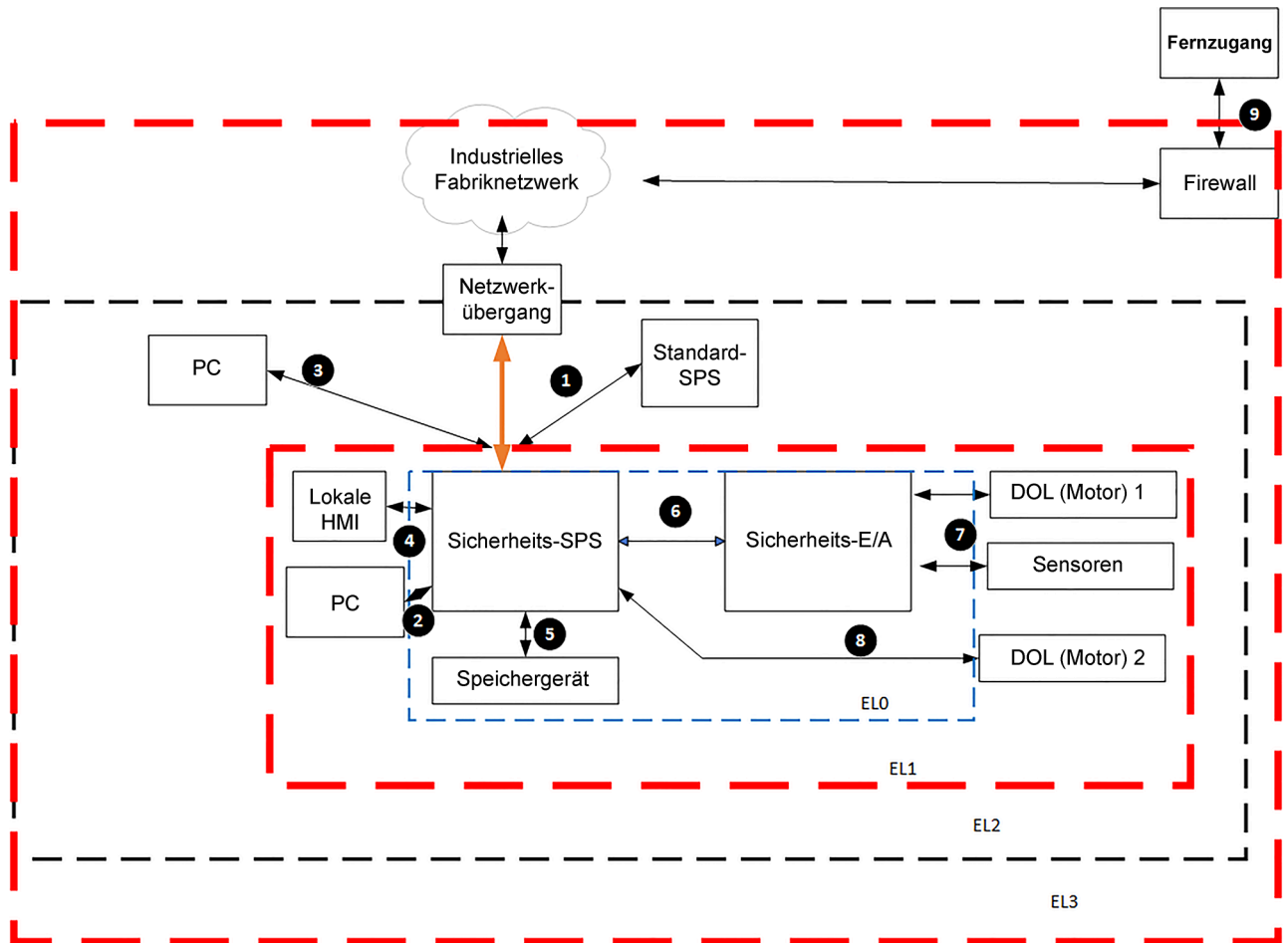
Komponenten, die an der Außenseite der Maschine angebracht sind, wie eine lokale grafische Anwenderoberfläche, die USB-Konfigurationsschnittstelle der Sicherheits-SPS und die Bedienteile, werden in der Kategorie „physischer Zugang“ berücksichtigt.

Die Ethernet-Verbindung ist für die Verwendung mit lokalen Geräten vorgesehen, wie z. B. Feldbus-Sensoren und Bedienteile oder mit anderen SPSen (daher „lokaler Zugang“ als Expositionszone).

Das industrielle Fabriknetzwerk umfasst den Zugang durch technische Werkzeuge und andere Maschinen usw.

Wenn im Abschnitt „Sicherheitsumfeld“ der Nutzungsinformationen beispielsweise beschrieben wird, dass die Feldbusverbindung nur für die lokale Nutzung ausgelegt ist, sind Ausgleichsmaßnahmen erforderlich, um das System bestimmungsgemäß nutzen zu können. In diesem Beispiel ist ein Netzwerkübergangsgerät (wie ein Smart Switch, ein Router mit integrierter Firewall usw.) erforderlich, um es vor einer übermäßigen Exposition zu schützen.

Dies gilt auch für andere Vertrauensgrenzen. Da in unserem Beispiel der Anwender über einen Fernzugang auf die Anwendung zugreifen können soll, muss der Fernzugang durch eine externe [Maßnahme](#) wie eine Firewall oder einen sicheren Kommunikationsendpunkt gesichert werden, um die benachbarte Ebene von der uneingeschränkten Ebene zu trennen.

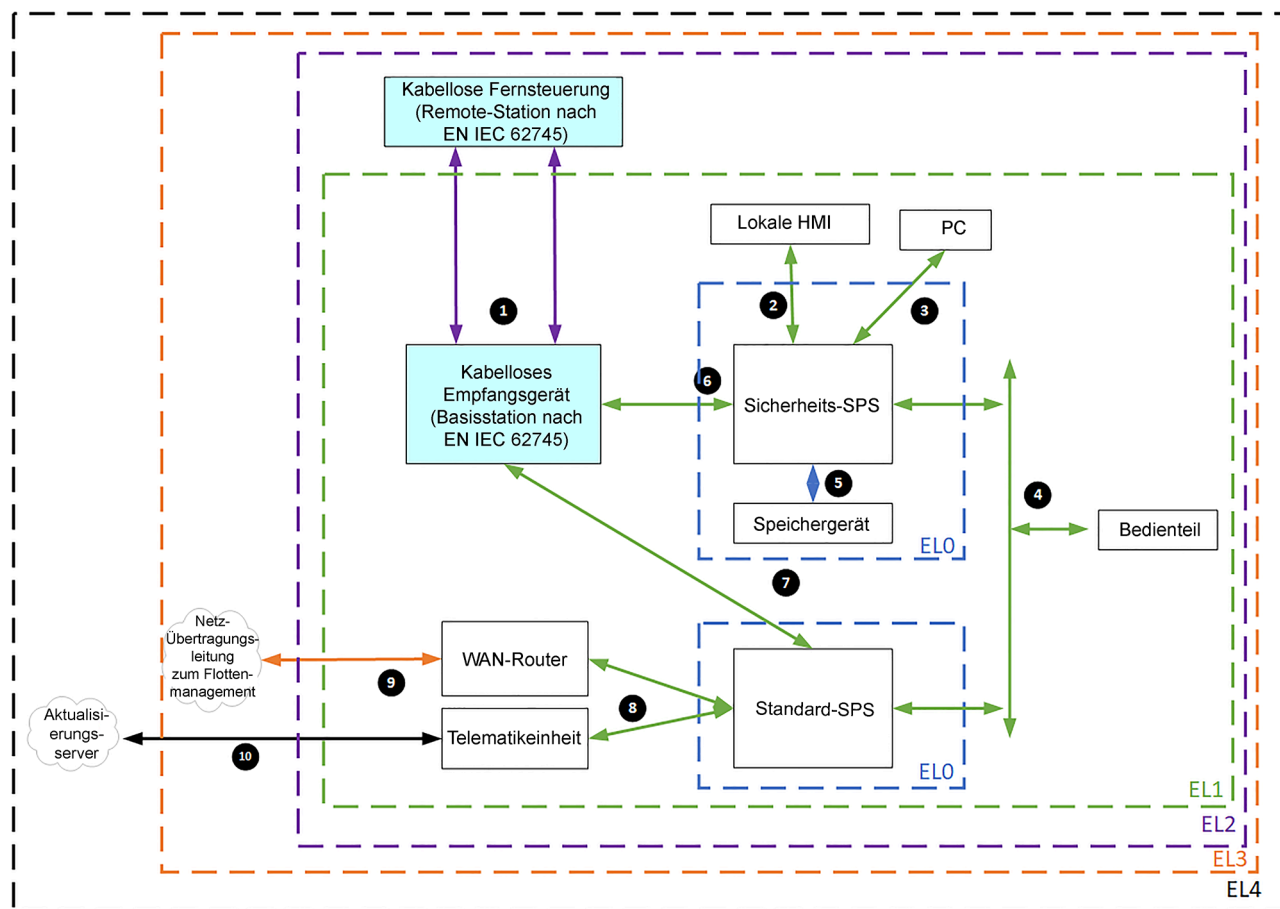


Legende

- 1 Industrial Ethernet (z. B. Ethernet/IP, EtherCAT oder PROFINET)
- 2 USB-Konfigurationsschnittstelle (lokaler Zugang)
- 3 Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Industrial Ethernet (z. B. Ethernet/IP, EtherCAT oder PROFINET)
- 5 SD-Kartenschnittstelle
- 6 Interne Rückplatte
- 7 Digitaler Gleichstrom-E/A, 24 V
Digitaler Gleichstromausgang und Motor-Feedback
- 8 Direkter Digitaleingang für Sensoren (Verriegelung, Auslaufbehälter, Auslaufband, Not-Halt-Schaltung)
- 9 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit, FSoE oder PROFIsafe)
- 9 Fernzugang, z. B. über das Unternehmensnetzwerk oder das Internet

Bild C.10

C.7.3 Beispiel 2: Ladekran mit kabelloser Steuerung



Legende

- 1 Kabellose Verbindung
- 2 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 3a USB-Konfigurationsschnittstelle am Verlängerungskabel (lokaler Zugang) oder
- 3b Ethernet-Konfigurationsschnittstelle (Fernzugang)
- 4 Industrial Ethernet für die Betriebssicherheit (z. B. CIP-Betriebssicherheit oder PROFIsafe)
- 5 SD-Kartenschnittstelle
- 6 Direkt festverdrahteter E/A
- 7 Industrial Ethernet (z. B. Ethernet/IP oder PROFINET)
- 8 Ethernet
- 9 WLAN zum OT-Netzwerk des Unternehmens (Anmerkung: Dies ist nicht üblich für Ladekrane, sondern eher für Flurförderzeuge, die in Lagerhäusern eingesetzt werden. Hier wird es als Beispiel für WAN-Verbindungen mit unterschiedlichen Expositionspegeln aufgeführt.
- 10 WLAN + Router zum Internet oder direkte Internetverbindung (z. B. über LTE)

Bild C.11

ANMERKUNG Das Diagramm kann Herstellern dabei helfen, die Effizienz ihrer Auslegung zu verbessern, so dass die Verbindung zum internetbasierten Update-Server außerhalb der Maschine platziert werden kann:

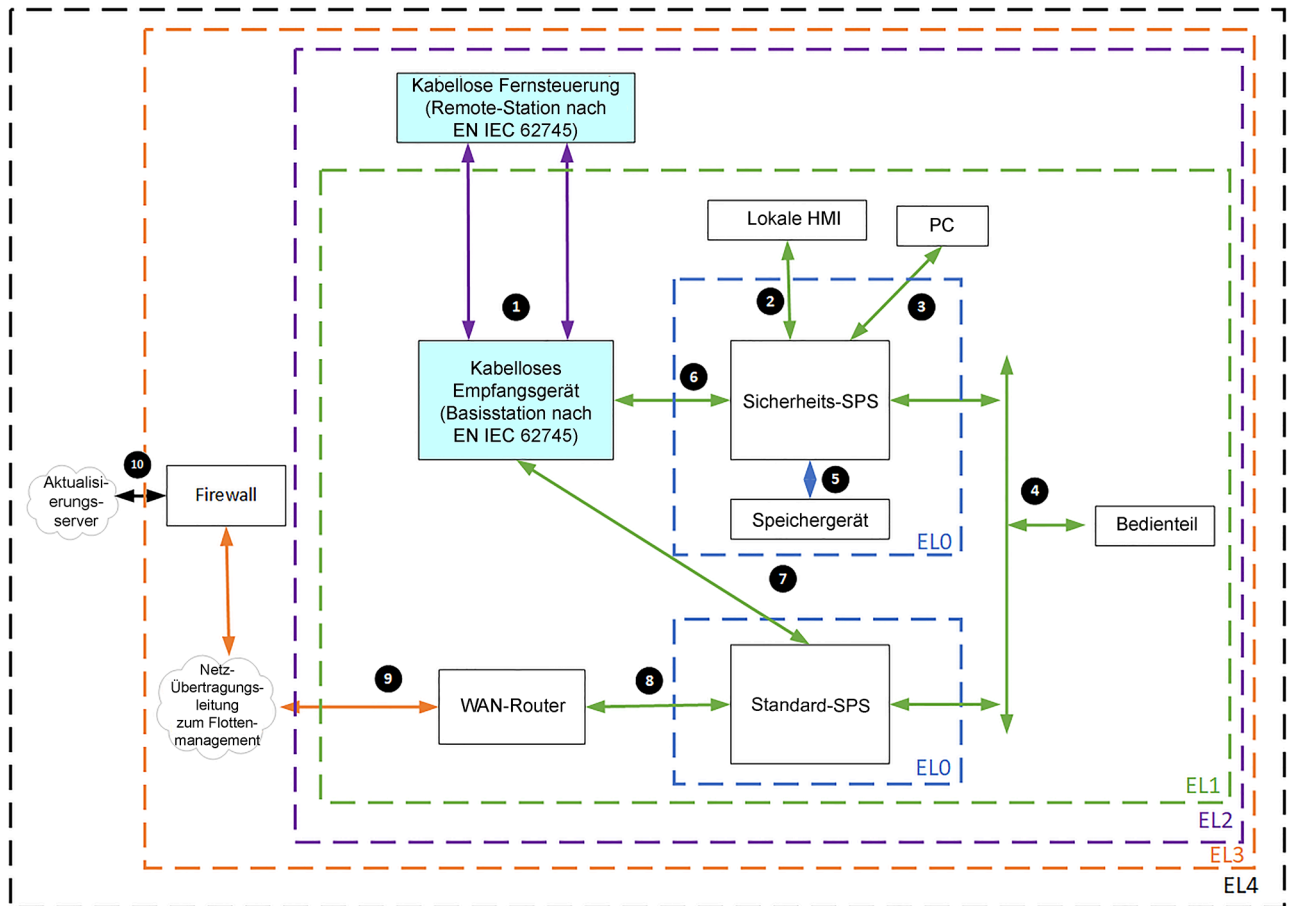


Bild C.12

C.7.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.7.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.8 STRIDE-Analyse

C.8.1 Allgemeines

Beantwortung der Frage: „Wo kann **Verfälschung** (direkt oder indirekt) negative Auswirkungen auf die Risikominderungsmaßnahmen haben (nach EN ISO 12100:2010)?“.

Berücksichtigung der Angriffe auf alle Elemente in Ihrem Datenflussdiagramm.

Missbrauch von Schnittstellen oder Protokollen unter Berücksichtigung der festgelegten Annahmen.

Für solche Überlegungen sollten geeignete Werkzeuge und Techniken wie STRIDE verwendet werden.

Das **Steuerungssystem** besteht aus EINGANG – LOGIKSCHALTUNG – AUSGANG.

Unsere STRIDE-Analyse umfasst das gesamte System, einschließlich:

- Das **Steuerungssystem**, bestehend aus EINGANG – LOGIKSCHALTUNG – AUSGANG,
- Systemschnittstellen,

- Konfiguration von Geräten,
- eigentlicher Betrieb der Geräte.

Vertrauenskettenkonzept: Wenn Datenflüsse nur innerhalb einer vertrauenswürdigen Grenze stattfinden, gibt es

Spoofing (Identitätsverschleierung) – „sich als gültiger Systemanwender oder gültige Ressource ausgeben“, REF1 – Verletzung der Authentifizierung

- Spoofing anderer Daten von Sicherheitskommunikations-Peers, z. B. durch Fälschung von Füllschemata, Zeitstempeln, Zählern, CRCs usw. zwischen Steuerungen, indem man sich als Sicherheitssteuerung ausgibt
- Replay-Angriffe, bei denen gültige Sensordaten auf einem Feldbus simuliert werden
- Ein Angreifer meldet sich als Administrator bei einer Konfigurationsschnittstelle an, um die Sicherheitskonfiguration zu ändern.

Tampering Manipulation – „Änderung von System- oder Anwenderdaten“ REF1 – Verletzung der Integrität

- Jemand ändert sicherheitsbezogene Parameter, Konfigurationen, Firmware oder Anwendersoftware
- Jemand führt einen Man-in-the-Middle-Angriff (MITM-Angriff) durch, um Prozessdaten zu ändern, während er die Maßnahmen des Sicherheitsprotokolls gegen Kommunikationsfehler vortäuscht
- Jemand simuliert/umgeht ein sicherheitsbezogenes Eingabegerät, z. B. einen Not-Halt-Schalter. Die tatsächlichen Not-Halt-Ereignisse werden nicht mehr korrekt erkannt und bewertet.

Repudiation Verleugnung – „Durchführung einer illegalen Operation und Leugnen der Beteiligung“ – Verstoß gegen die Rechenschaftspflicht

- Jemand löscht oder ändert Protokolleinträge, die sich auf die Änderung von sicherheitsbezogenen Parametern, Konfigurationen, Firmware oder Anwendersoftware beziehen.

Information Disclosure (Offenlegung von Informationen) – „Weitergabe von Informationen an Personen, die keinen Zugang haben sollten“ REF1 – Verstoß gegen die Vertraulichkeit

- Wahrscheinlich nicht im Anwendungsbereich, solange die Gesundheits- und Sicherheitseigenschaften der Maschine oder des zugehörigen Produkts unverändert bleiben.

Denial of Service (Dienstverweigerung) – „Das System vorübergehend unzugänglich oder unbrauchbar machen“ REF1 – Verletzung der Verfügbarkeit

- Wahrscheinlich nicht im Anwendungsbereich, solange die Gesundheits- und Sicherheitseigenschaften der Maschine oder des zugehörigen Produkts unverändert bleiben.

Elevation of Privileges (Rechteauserweiterung) – „Nicht privilegierter Anwender erhält privilegierten Zugang“ REF1 – Verletzung der Autorisierung

- Wahrscheinlich nicht im Anwendungsbereich, solange die Gesundheits- und Sicherheitseigenschaften der Maschine oder des zugehörigen Produkts unverändert bleiben.

C.8.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine

Tabelle C.1

Element	Spoofing	Manipulation	Verleugnung	Offenlegung	Dienstverweigerung	Rechteauserweiterung	Anmerkungen
1: Industrial-Ethernet-Protokoll zwischen Standard-SPS und Sicherheits-SPS	AT1S1: Ein Angreifer könnte die Parameter simulieren, die den Betriebsmodus der Sicherheits-SPS ändern AT1S2: Ein Angreifer könnte gefälschte Statusdaten an die Standard-SPS senden, um ein Problem zu verschleiern	AT1T1: Standard-SPS physisch trennen und an einen anderen Netzwerk-knoten anschließen	N/A – keine sicherheits-bezogenen Daten	N/A – keine privaten oder sonstigen geheimen Daten zu erwarten	AT1D1: Durchtrennen des Kabels AT1D2: EMV AT1D3: Jedes Paket, das die Sicherheits-SPS in den sicheren Halt-Zustand versetzt AT1D4: Ein Angreifer überflutet die Prozessdatenschnittstelle mit zahlreichen nutzlosen Paketen und überlastet so die Schnittstelle	N/A	
2: USB-Konfigurationsschnittstelle (lokaler Zugang)	AT2S1: Brute-Force-Angriffe auf Kennwörter AT2S2: Kennwörter werden unter Mitarbeitern unkontrolliert weitergegeben	AT2T1: Anschluss eines USB-Geräts, das Datenverkehr an eine andere Kommunikationsschnittstelle weiterleitet	AT2R1: Jemand ändert die Sicherheitseinstellungen auf unsichere Werte und stellt nach einem Vorfall die sicheren Einstellungen wieder her	AT2I1: Keylogger zum Ausspähen von Kennwörtern auf dem Client-System	AT2D1: Physische Beschädigung des USB-Anschlusses AT2D2: Anschluss eines USB-Geräts mit böswilliger Software, die die Sicherheitskonfiguration überschreibt AT2D3: Verwendung eines „USB-Killers“ mit einem Hochspannungskondensator, um die USB-Stromversorgung zu zerstören	AT2E1: Personen, die eigentlich nur Lesezugang haben sollten, können die Sicherheitskonfiguration ändern	
3: Ethernet-Konfigurationsschnittstelle (Fernzugang)	AT3S1: siehe AT2S1 AT3S2: siehe AT2S2		AT3R1: siehe AT2R1	AT3I1: Ausspähung des Kennworts oder des einfachen Kennwort-Hashs im Netzwerk	AT3D1: Überflutung der Konfigurationsschnittstelle mit zahlreichen nutzlosen Paketen, wodurch die Schnittstelle überlastet wird	AT3E1: siehe AT2E1	

Element	Spoofing	Manipulation	Verleugnung	Offenlegung	Dienstverweigerung	Rechteauserweiterung	Anmerkungen
4: Grafische Anwenderoberfläche und ihre Anschlüsse	AT4S1: Ein Angreifer schließt ein Gerät an, das sich als grafische Anwenderoberfläche ausgibt und zur Simulation von Anwendereingaben an die Maschine verwendet werden kann AT4S2: Ein Angreifer platziert ein Gerät zwischen SPS und grafischer Anwenderoberfläche, das sich als SPS ausgibt, damit die grafische Anwenderoberfläche nur Werte in einwandfreiem Zustand anzeigt und tatsächliche Probleme verborgen werden	N/A – Es ist nicht möglich, sicherheitsbezogene Einstellungen über die grafische Anwenderoberfläche zu ändern	N/A	AT4I1: Identitätsdaten eines legitimen Anwenders werden ausgelesen	AT4D1: Eine Unterbrechung der Verbindung zur grafischen Anwenderoberfläche kann dazu führen, dass Warnungen nicht bemerkt werden	N/A	
5: Speichergerät (z. B. SD-Karte)	N/A	AT5T1: Austausch des Speichergeräts durch ein Gerät mit einer anderen Sicherheitskonfiguration	AT5R1: Ein Angreifer ersetzt das Speichergerät durch ein manipuliertes Gerät und ersetzt es nach einem Vorfall wieder durch das Originalgerät, um die Tat zu verschleiern	AT5I1: Ein Angreifer stiehlt oder kopiert das Speichergerät, um Informationen über die Sicherheitsanwendung zu erhalten	AT5D1: Entwendung des Speichergeräts, SPS startet nicht, sondern verbleibt in sicherem Zustand	AT5E1: Jemand ohne Zugangsrechte könnte ein manipuliertes Speichergerät in die SPS einstecken, und es würde akzeptiert werden	
6: Rückplatte	AT6S1: Aktivierung einer deaktivierten Funktion	AT6T1: Bedingungslose Einstellung auf gefährliche Ausgabewerte	N/A	N/A – nur rohe Prozessdaten, keine geheimen Daten	AT6D1: Durch die Modifizierung von Kommunikationspaketen auf der Rückplatte können die E/A-Sicherheitssignale in den sicheren Stoppzustand versetzt werden, was zu einer Dienstverweigerung für kritische Dienste führt	N/A	

Element	Spoofing	Manipulation	Verleugnung	Offenlegung	Dienstverweigerung	Rechteausweitung	Anmerkungen
7: E/A-Daten	N/A, siehe AT7T1	AT7T1 : Änderung der physischen Verkabelung	N/A	N/A – nur rohe Signale, keine geheimen Daten	Duplizierung auf AT7T1	N/A	
8: Industrial Ethernet zwischen Sicherheits-SPS und VFD	AT8S1 : Die Verfälschung der Motorrückmeldung kann dazu führen, dass die Geschwindigkeit sichere Werte überschreitet oder andere Sicherheitsvorrichtungen fehlerhaft funktionieren, beispielsweise dass eine Sicherheitsverriegelung entriegelt wird	AT8T1 : Schreiben unsicherer Sicherheitsparameter auf den Motorantrieb	N/A	N/A	AT8D1 : Simulation der wiederholten Betätigung des Not-Halt-Schalters	N/A	

C.8.3 Beispiel 2: Funksteuerung für Ladekran

Einige Branchenstandards für kabellose Steuerungen (z. B. IEC 62745, 4.3 oder IEC 61784-3) enthalten Anforderungen für Maßnahmen gegen zufällige Verfälschungen, decken jedoch keine böswilligen Versuche wie Spoofing oder Manipulation ab.

Tabelle C.2

Element	Spoofing	Manipulation	Verleugnung	Offenlegung	Dienstverweigerung	Rechteauserweiterung	Anmerkungen
1: Kabellose Kommunikationsverbindung zwischen Fernbedienung und Empfänger	AT1S1: Ein Angreifer sendet mithilfe einer manipulierten Fernbedienung Sicherheitsdaten, die scheinbar von einer legitimen Fernbedienung stammen AT1S2: Replay-Angriff: Ein Angreifer zeichnet die Kommunikation auf und wiederholt sie zu einem späteren Zeitpunkt	AT1T1: Ein Angreifer nutzt AT1S1, um die Position oder Geschwindigkeit des Krans zu verändern AT1T2: Modifizierung der Sicherheitsfunktionen in der Steuerung mithilfe einer Funkverbindung	AT1R1: AT1T1 ohne Möglichkeit der Rückverfolgung	AT1I1: Verborgene Ausfilterung von Identitätsdaten durch Überwachung der kabellosen Kommunikation, z. B. eines Schlüssels oder Rolling Codes – dient als Sprungbrett für Spoofing bzw. Manipulation, stellt jedoch selbst keine Sicherheitsbedrohung dar	AT1D1: Ein Angreifer stört das Signal AT1D2: Ähnlich wie AT1S2, bei dem der Not-Halt-Befehl wiederholt wird, was dazu führt, dass die Maschine ständig in den sicheren Zustand wechselt	AT1E1: Verwendung eines Betriebsmodus mit anderen Sicherheitsbeschränkungen als den für die betreffende Anwendung vorgesehenen	
2: Funkfernsteuerung	AT2S1: Ein Angreifer entwendet die physische Fernbedienung	AT2T1: Austausch der Firmware über eine Schnittstelle wie Bluetooth oder USB AT2T2: Austausch von Einstellungen/Parametern über eine Schnittstelle wie Bluetooth oder USB	AT2R1: Änderung der Firmware ohne Möglichkeit der Rückverfolgung AT2R2: Änderung von Parametern ohne Möglichkeit der Rückverfolgung	AT2I1: Ausfilterung von Identitätsdaten durch Auslesen von einem Speichergerät	N/A – mögliche Angriffsvektoren bereits in anderen Spalten behandelt	AT2E1: siehe <bold>AT1E1</bold>	
3: Kabelloses Empfangsgerät	AT3S1: Manipulation des Empfängers, um den Bediener glauben zu lassen, dass seine vertrauenswürdige Fernbedienung mit Sicherheitsfunktionen wie dem Not-Halt verbunden ist, obwohl dies in Wirklichkeit nicht der Fall ist. Möglicherweise ein Teil eines MITM-Angriffs	AT3T1: Indirekte Verfälschung durch Controller über Telematikeinheit oder WAN-Router	AT3R1: Herstellung einer Sitzung mit einem Remote-Controller ohne Möglichkeit der Rückverfolgung	AT3I1: Ausfilterung von Identitätsdaten durch Auslesen von einem Speichergerät	N/A – mögliche Angriffsvektoren bereits in anderen Spalten behandelt	AT3E1: Ein Angreifer programmiert mithilfe einer kabellosen Verbindung die Firmware um, um die Steuerung der Maschine vollständig zu übernehmen	

C.8.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.8.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.9 Bedrohungsklassifizierung**C.9.1 Allgemeines**

Alle gefundenen sicherheitsbezogenen Bedrohungen werden in eine neue Tabelle kopiert.

In dieser neuen Tabelle wird folgendes aufgeführt:

- Alle festgestellten Bedrohungen
 - Klassifizierung jeder Bedrohung durch Zuordnung der notwendigen Voraussetzungen für die Ausnutzung
 - Zuordnung jeder Bedrohung zu einer Reihe festgelegter genormter Bedrohungen (siehe zusätzliche Tabelle „Arten von Bedrohungen“)
- Wählen Sie aus dieser Tabelle empfohlene Schadensbegrenzungsmaßnahmen aus

C.9.2 Beispiel 1: einfache Form-, Füll- und Verschleißmaschine

Tabelle C.3

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
1: Industrial-Ethernet-Protokoll zwischen Standard-SPS und Sicherheits-SPS	AT1S1: Ein Angreifer könnte die Parameter simulieren, die den Betriebsmodus der Sicherheits-SPS ändern	Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...)	TPID1: Ein Angreifer hat physischen Zugang zum Netzwerk TPID1.6: Ein Angreifer hat logischen Zugang zum Netzwerk	TTID2.1: Manipulation durch physische Mittel	
	AT1S2: Ein Angreifer könnte gefälschte Statusdaten an die Standard-SPS senden, um ein Problem zu verschleiern	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat physischen Zugang zum Netzwerk TPID1.6: Ein Angreifer hat logischen Zugang zum Netzwerk	TTID2.1: Manipulation durch physische Mittel	
	AT1T1: Standard-SPS physisch trennen und an einen anderen Netzknoten anschließen	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat physischen Zugang zum Netzwerk TPID1.6: Ein Angreifer hat logischen Zugang zum Netzwerk	TTID2.1: Manipulation durch physische Mittel	
	AT1D1: Durchtrennen des Kabels	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat physischen Zugang zum Netzwerk	TTID2.1: Manipulation durch physische Mittel	
	AT1D2: EMV	Genormte Sicherheitsmechanismen führen zu einem sicheren Zustand → bereits behandelt	–	TTID5.1: Störsignale durch elektromagnetische Interferenz, die zu Fehlern oder zu einem (potenziell unsicheren) Systemhalt führen	
	AT1D3: Jedes Paket, das die Sicherheits-SPS in den sicheren Halt-Zustand versetzt	Genormte Sicherheitsmechanismen führen zu einem sicheren Zustand → bereits behandelt	TPID1: Ein Angreifer hat Zugang zum Netzwerk	(Das System wäre nicht nutzbar, aber wenn das System in den sicheren Zustand wechselt, würde dies keine Gefährdungssituation verursachen, was akzeptabel ist)	

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT1D4: Ein Angreifer überflutet die Prozessdatenschnittstelle mit zahlreichen nutzlosen Paketen und überlastet so die Schnittstelle	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat Zugang zum Netzwerk	(Das System wäre nicht nutzbar, aber wenn das System in den sicheren Zustand wechselt, würde dies keine Gefährdungssituation verursachen, was akzeptabel ist)	
2: USB-Konfigurationschnittstelle (lokaler Zugang)	AT2S1: Brute-Force-Angriffe auf Kennwörter		TPID4.1: Ein Angreifer hat Zugang zu physischen Ports des Geräts TPID5: Logischer Zugang zum System	TTID1.2: Brute-Force-Angriff: Versuch und Irrtum zum Knacken von Kennwörtern, Anmeldedaten und Verschlüsselungsschlüsseln	
	AT2S2: Kennwörter werden unter Mitarbeitern unkontrolliert weitergegeben		TPID6: Vernachlässigung bewährter Sicherheitsverfahren durch den Anwender TP5.3: Das System unterscheidet nicht zwischen Anwenderrollen	TTID1.3: Unbefugte Anwender verwenden legitime Anmeldedaten	
	AT2T1: Anschluss eines USB-Geräts, das Datenverkehr an eine andere Kommunikationsschnittstelle weiterleitet		TP6: Vernachlässigung bewährter Sicherheitsverfahren durch den Anwender	TTID6.1: Ein Angreifer ändert die Verbindungsfähigkeiten einer Schnittstelle, um deren Expositionspegel potenziell zu erhöhen.	
	AT2R1: Jemand ändert die Sicherheitseinstellungen auf unsichere Werte und stellt nach einem Vorfall die sicheren Einstellungen wieder her		(Außerhalb des Anwendungsbereichs)	(Außerhalb des Anwendungsbereichs)	
	AT2I1: Keylogger zum Ausspähen von Kennwörtern auf dem Client-System	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	Hardware-Keylogger: TPID4: Ein Angreifer hat physischen Zugang zum Gerät Software-Keylogger: TPID6: Vernachlässigung bewährter Sicherheitsverfahren durch den Anwender	TTID1.3: Unbefugte Anwender verwenden legitime Anmeldedaten	
	AT2D1: Physische Beschädigung des USB-Anschlusses	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TPID5.2: Physische Beschädigung oder Zerstörung	

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT2D2: Anschluss eines USB-Geräts mit böswilliger Software, die die Sicherheitskonfiguration überschreibt	Sicherheitskonfigurationsdaten	TPID4: Ein Angreifer hat physischen Zugang zum Gerät TPID5: Logischer Zugang zum System	TTID2.2: Manipulation von Konfigurationsdaten	
	AT2D3: Verwendung eines „USB-Killers“ mit einem Hochspannungskondensator, um die USB-Stromversorgung zu zerstören	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TTID5.2: Physische Beschädigung oder Zerstörung	
	AT2E1: Personen, die eigentlich nur Lesezugang haben sollten, können die Sicherheitskonfiguration ändern	Sicherheitskonfigurationsdaten	TPID5.3: Das System unterscheidet nicht zwischen Anwenderrollen	TTID2.2: Manipulation von Konfigurationsdaten	
3: Ethernet-Konfigurationsschnittstelle (Fernzugang)	AT3S1: siehe AT2S1: Brute-Force-Angriffe auf Kennwörter	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat Zugang zum Netzwerk TPID5: Logischer Zugang zum System	TTID1.3: Unbefugte Anwender verwenden legitime Anmeldedaten	
	AT3S2: siehe AT2S2: Kennwörter werden unter Mitarbeitern unkontrolliert weitergegeben		TPID6: Vernachlässigung bewährter Sicherheitsverfahren durch den Anwender TPID5.3: Das System unterscheidet nicht zwischen Anwenderrollen	TTID1.3: Unbefugte Anwender verwenden legitime Anmeldedaten	
	AT3R1: siehe AT2R1: Jemand ändert die Sicherheitseinstellungen auf unsichere Werte und stellt nach einem Vorfall die sicheren Einstellungen wieder her		(Außerhalb des Anwendungsbereichs)	(Außerhalb des Anwendungsbereichs)	
	AT3I1: Ausspähung des Kennworts oder des einfachen Kennwort-Hashs im Netzwerk	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.3: Unbefugte Anwender verwenden legitime Anmeldedaten	
	AT3D1: Überflutung der Konfigurationsschnittstelle mit zahlreichen nutzlosen Paketen, wodurch die Schnittstelle überlastet wird	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs (Anmerkung: Bei Verwendung gemeinsamer Komponenten könnte AT1D4 relevant sein!	TPID1: Ein Angreifer hat Zugang zum Netzwerk		

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT3E1: siehe AT2E1: Personen, die eigentlich nur Lesezugang haben sollten, können die Sicherheitskonfiguration ändern	Sicherheitskonfigurationsdaten	TPID5.3: Das System unterscheidet nicht zwischen Anwenderrollen	TTID2.2: Manipulation von Konfigurationsdaten	
4: Grafische Anwenderoberfläche und ihre Anschlüsse	AT4S1: Ein Angreifer schließt ein Gerät an, das sich als grafische Anwenderoberfläche ausgibt und zur Simulation von Anwendereingaben an die Maschine verwendet werden kann	(alle)	TPID5: Logischer Zugang zum System Wenn die grafische Anwenderoberfläche über das Netzwerk verbunden ist: TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	
	AT4S2: Ein Angreifer platziert ein Gerät zwischen SPS und grafischer Anwenderoberfläche, das sich als SPS ausgibt, damit die grafische Anwenderoberfläche nur Werte in einwandfreiem Zustand anzeigt und tatsächliche Probleme verborgen werden	Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...)	TPID5: Logischer Zugang zum System Wenn die grafische Anwenderoberfläche über das Netzwerk verbunden ist: TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	
	AT4I1: Identitätsdaten eines legitimen Anwenders werden ausgelesen	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID4.2: Ein Angreifer hat Zugang zur grafischen Anwenderoberfläche des Geräts	–	
	AT4D1: Eine Unterbrechung der Verbindung zur grafischen Anwenderoberfläche kann dazu führen, dass Warnungen nicht bemerkt werden	Wenn z. B. eine ignorierte Warnung zu einer Gefährdung führen kann, müssen andere Maßnahmen ergriffen werden, siehe sicherheitsrelevante Normen.	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TTID5.3: Störung von Diensten	
5: Speichergerät (z. B. SD-Karte)	AT5T1: Austausch des Speichergeräts durch ein Gerät mit einer anderen Sicherheitskonfiguration	Sicherheitskonfigurationsdaten Sicherheitsbezogene Anwendungs-Software Konfigurationsspeichergeräte (z. B. SD-Karte in s-SPS)	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TTID2.3: Manipulation von Speichergeräten	

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT5R1: Ein Angreifer ersetzt das Speichergerät durch ein manipuliertes Gerät und ersetzt es nach einem Vorfall wieder durch das Originalgerät, um die Tat zu verschleiern	Sicherheitskonfigurationsdaten Sicherheitsbezogene Anwendungs-Software Konfigurationsspeichergeräte (z. B. SD-Karte in s-SPS)	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TTID3.1: Ein Angreifer manipuliert kritische sicherheitsbezogene Daten und stellt sie nach einem Vorfall wieder her, um die Veränderung zu verschleiern	
	AT5I1: Ein Angreifer stiehlt oder kopiert das Speichergerät, um Informationen über die Sicherheitsanwendung zu erhalten	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs (kann allerdings aufgrund von besseren Kenntnissen über das System einen Angriff zweiter Ordnung nach sich ziehen)	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	(kein Angriff aus dem Anwendungsbereich dieses Dokuments)	
	AT5D1: Entwendung des Speichergeräts, SPS startet nicht, sondern verbleibt in sicherem Zustand	Nicht sicherheitsbezogen → außerhalb des Anwendungsbereichs	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	(kein Angriff aus dem Anwendungsbereich dieses Dokuments)	
	AT5E1: Jemand ohne Zugangsrechte könnte ein manipuliertes Speichergerät in die SPS einstecken, und es würde akzeptiert werden	Sicherheitskonfigurationsdaten Sicherheitsbezogene Anwendungs-Software Konfigurationsspeichergeräte (z. B. SD-Karte in s-SPS)	TPID4: Ein Angreifer hat physischen Zugang zum Gerät	TTID2.3: Manipulation von Speichergeräten TTID3.2: Vernichtung von Nachweisen TTID3.3: Beseitigung der Möglichkeit zur Beweissicherung (z. B. Trennung des Speichergeräts für Protokolldaten)	
6: Rückplatte	AT6S1: Aktivierung einer deaktivierten Funktion	N/A – nicht durchführbar, wenn physischer Zugang gewährt wird, stellen andere, einfachere Angriffe ein größeres Risiko dar			
	AT6T1: Bedingungslose Einstellung auf gefährliche Ausgabewerte	N/A – nicht durchführbar, wenn physischer Zugang gewährt wird, stellen andere, einfachere Angriffe ein größeres Risiko dar			

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT6D1: Durch die Modifizierung von Kommunikationspaketen auf der Rückplatte können die E/A-Sicherheitssignale in den sicheren Stopp-Zustand versetzt werden, was zu einer Dienstverweigerung für kritische Dienste führt ANMERKUNG Ein sicherer Zustand bedeutet nicht immer Sicherheit, z. B. wenn ein Prozess zum falschen Zeitpunkt gestoppt wird, kann sich Hitze aufbauen und zu einem Brand führen. Dies muss anwendungsspezifisch berücksichtigt werden. In diesem Szenario (Form- und Füllmaschine) führt ein sicherer Zustand wahrscheinlich nicht zu einer Gefährdungssituation.	Sicherheitsfunktionen, die als Schadensbegrenzungsmaßnahmen für eine bestimmte Gefährdung der Maschine festgelegt sind.	TPID4.3: Ein Angreifer hat Zugang zu Geräten innerhalb des Systems	TTID 2.1: Manipulation durch physische Mittel	
7: E/A-Daten	AT7T1: Änderung der physischen Verkabelung	Sicherheitsfunktionen, die als Schadensbegrenzungsmaßnahmen für eine bestimmte Gefährdung der Maschine festgelegt sind.	TPID4.3: Ein Angreifer hat Zugang zu Geräten innerhalb des Systems	TTID 2.1: Manipulation durch physische Mittel	
8: Industrial Ethernet zwischen Sicherheits-SPS und VFD	AT8S1: Die Verfälschung der Motorrückmeldung kann dazu führen, dass die Geschwindigkeit sichere Werte überschreitet oder andere Sicherheitsvorrichtungen fehlerhaft funktionieren, beispielsweise dass eine Sicherheitsverriegelung entriegelt wird	Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...)	TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	
	AT8T1: Schreiben unsicherer Sicherheitsparameter auf den Motorantrieb	Sicherheitskonfigurationsdaten Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...)	TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	
	AT8D1: Simulation der wiederholten Betätigung des Not-Halt-Schalters Anmerkung: System ist dauerhaft in sicherem Zustand, so dass dieser Angriff keine Gefährdungen mit sich bringt	Prozessdaten zu sicherheitsbezogenen Verbindungen (z. B. Sicherheitsbusse, Sicherheitsfunk...)	TPID1: Ein Angreifer hat Zugang zum Netzwerk	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	

C.9.3 Beispiel 2: Ladekran mit kabelloser Steuerung

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
1: Kabellose Kommunikationsverbindung zwischen Fernbedienung und Empfänger	AT1S1: Ein Angreifer sendet mithilfe einer manipulierten Fernbedienung Sicherheitsdaten, die scheinbar von einer legitimen Fernbedienung stammen	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger	TPID1.5: Ein Angreifer befindet sich in ausreichender Nähe/Reichweite eines kabellosen Empfängers TPID3: Ein Angreifer kennt die Identitätsdaten	TTID1.1: Empfänger nimmt gefälschten Sender als legitimen Anwender an	
	AT1S2: Replay-Angriff: Ein Angreifer zeichnet die Kommunikation auf und wiederholt sie zu einem späteren Zeitpunkt	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT1T1: Ein Angreifer nutzt AT1S1 , um die Position oder Geschwindigkeit des Krans zu verändern	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT1T2: Modifizierung der Sicherheitsfunktionen in der Steuerung mithilfe einer Funkverbindung	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger	Ungeschützter Schreibzugriff vom kabellosen Empfangsgerät zum Sicherheitscontroller		
	AT1R1: AT1T1 ohne Möglichkeit der Rückverfolgung	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT1I1: Verborgene Ausfilterung von Identitätsdaten durch Überwachung der kabellosen Kommunikation, z. B. eines Schlüssels oder Rolling Codes – dient als Sprungbrett für Spoofing bzw. Manipulation, stellt jedoch selbst keine Sicherheitsbedrohung dar	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
	AT1D1: Ein Angreifer stört das Signal	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT1D2: Ähnlich wie AT1S2, bei dem der Not-Halt-Befehl wiederholt wird, was dazu führt, dass die Maschine ständig in den sicheren Zustand wechselt	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT1E1: Verwendung eines Betriebsmodus mit anderen Sicherheitsbeschränkungen als den für die betreffende Anwendung vorgesehenen	Sicherheitsbezogener Datenaustausch zwischen Steuerung und Empfänger			
	AT2S1: Ein Angreifer entwendet die physische Fernbedienung	Zugang zur Fernbedienung	Physischer Zugang		
	AT2T1: Austausch der Firmware über eine Schnittstelle wie Bluetooth oder USB				
	AT2T2: Austausch von Einstellungen/Parametern über eine Schnittstelle wie Bluetooth oder USB				
	AT2R1: Änderung der Firmware ohne Möglichkeit der Rückverfolgung				
	AT2R2: Änderung von Parametern ohne Möglichkeit der Rückverfolgung				
	AT2I1: Ausfilterung von Identitätsdaten durch Auslesen von einem Speichergerät				

Element	Beschreibung der sicherheitsbezogenen Bedrohung	Betreffende Vermögenswerte	Voraussetzungen für die Ausnutzung	Arten von Bedrohungen	Betreffende Mindestanforderungen
3: Kabelloses Empfangsgerät	AT3S1: Manipulation des Empfängers, um den Bediener glauben zu lassen, dass seine vertrauenswürdige Fernbedienung mit Sicherheitsfunktionen wie dem Not-Halt verbunden ist, obwohl dies in Wirklichkeit nicht der Fall ist. Möglicherweise ein Teil eines MITM-Angriffs.				
	AT3T1: Indirekte Verfälschung durch Controller über Telematikeinheit oder WAN-Router.				
	AT3R1: Herstellung einer Sitzung mit einem Remote-Controller ohne Möglichkeit der Rückverfolgung.				
	AT3I1: Ausfilterung von Identitätsdaten durch Auslesen von einem Speichergerät.				
	AT3E1: Ein Angreifer programmiert mithilfe einer kabellosen Verbindung die Firmware um, um die Steuerung der Maschine vollständig zu übernehmen.				

C.9.4 Beispiel 3: Sicherheitssensor

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

C.9.5 Beispiel 4: Sicherheitsvorrichtung mit STO-Sicherheitsfunktion

< Dieser Punkt wird für eine künftige Ausgabe in Betracht gezogen. >

Anhang D
(informativ)

Liste der Bedrohungen und Schadensbegrenzungsmaßnahmen

D.1 Allgemeines

Bedrohungen sollten in erster Linie durch Maßnahmen nach diesem Anhang bekämpft werden. Ist dies aus praktischen Gründen nicht möglich, sollten Ausgleichsmaßnahmen in Betracht gezogen werden.

Schadensbegrenzungsmaßnahmen können sich entweder auf folgende Aspekte auswirken:

- Auswirkung des Angriffs, oder
- Eingriff in den Angriffspfad.

Ziel sollte ein Katalog mit möglichen Schadensbegrenzungsmaßnahmen sein, z. B.

- Validierung von Eingabedaten,
- Prinzip der minimal erforderlichen Rechte,
- sichere Voreinstellungen,
- Kerckhoffs'sches Prinzip: Sicherheit sollte auf einem klar festgelegten Geheimnis beruhen, nicht auf einer undurchsichtigen Auslegung,
- unveränderlicher Anwendungscode,
- getrennter Speicher für Ausführung und Daten,
- Festwertspeicher,
- usw.

Bonus, wenn alle diese Schadensbegrenzungsmaßnahmen Prüfungskriterien erhalten, um sie überprüfbar zu machen.

D.2 Voraussetzungen für die Ausnutzung, Arten von Bedrohungen und Schadensbegrenzungsmaßnahmen

D.2.1 Voraussetzungen für die Ausnutzung

Tabelle D.1 – Voraussetzungen für die Ausnutzung

ID der Voraussetzung für die Bedrohung	Allgemeine Arten von Bedrohungen	Mögliche Schadensbegrenzungsmaßnahmen bei einem Vektor bzw. einem Angriffspfad	Anmerkungen
TPID1	Ein Angreifer hat Zugang zum Netzwerk		
TPID1.1	Ein Angreifer kann die Geräte der Netzwerkinfrastruktur manipulieren	CCM1: Verwendung einer Authentifizierung für Netzwerk-Einrichtung, z. B. verwaltete Switches, Router usw.	
TPID1.2	Ein Angreifer hat physischen Zugang zu Netzkabeln	CCM2: Installation von Kabeln in einer physisch geschützten Umgebung	
TPID1.3	Ein Angreifer hat Zugang zum kabellosen Netzwerk	CCM3: Verschlüsselung des kabellosen Protokolls	

ID der Voraussetzung für die Bedrohung	Allgemeine Arten von Bedrohungen	Mögliche Schadensbegrenzungsmaßnahmen bei einem Vektor bzw. einem Angriffspfad	Anmerkungen
TPID1.4	Ein Angreifer hat Zugang zu ungenutzten Anschlussbuchsen angeschlossener Netzwerkgeräte	CCM4: Verwendung von RJ45-Anschlussverriegelungen CCM5: Verwendung des Produkts nur in einer physisch geschützten Umgebung	
TPID1.5	Ein Angreifer befindet sich in ausreichender Nähe/Reichweite eines kabellosen Empfängers	CCM6: Verringerung der Leistung auf kleinen Bereich CCM7: Verwenden Sie eine Richtantenne	
TPID1.6	Ein Angreifer hat logischen Zugang zum Netzwerk über externe Netzwerke	CCM8: Vermeidung des Routings in nicht vertrauenswürdige Netzwerke CCM9: Verwendung einer Netzwerksegmentierung mit DMZ (Firewall, VPN, IDS usw.) CCM10: Implementierung eines rollenbasierten Zugangs CCM11: Verschlüsselung von Protokollen CCM12: Verwendung von Nachrichten-Authentifizierungs-codes (MAC)	
TPID3	Ein Angreifer kennt die Identitätsdaten		
TPID4	Ein Angreifer hat physischen Zugang zum System	CCM13: Sicherstellung, dass anfällige Bauteile der Maschine vor unbefugtem physischem Zugang geschützt sind (z. B. durch physische Verriegelung, Aufbewahrung in einem verschlossenen Schaltschrank, Verwendung nur in gesperrten Bereichen usw.).	
TPID4.1	Ein Angreifer hat Zugang zu physischen Ports des Systems	CCM14: Sicherstellung, dass anfällige Ports vor unbefugtem physischem Zugang geschützt sind (z. B. durch physische Verriegelung usw.) CCM15: Ggf. Deaktivierung/Entfernung unnötiger Ports	
TPID4.2	Ein Angreifer hat Zugang zur grafischen Anwenderoberfläche des Geräts		
TPID4.3	Ein Angreifer hat Zugang zu Geräten innerhalb des Systems		
TPID5	Logischer Zugang zum System		
TPID5.1	Für das System wurden keine Zugangsbeschränkungen eingerichtet	CCM16: Implementierung einer Methode zur Anwenderauthentifizierung	
TPID5.2	Oberfläche ist aktiviert		
TPID5.3	Das System unterscheidet nicht zwischen Anwenderrollen	CCM17: Implementierung einer Methode zur rollenbasierten Anwenderauthentifizierung mit mehreren Anwender-ebenen	
TPID6	Vernachlässigung bewährter Sicherheitsverfahren durch den Anwender	CCM18: Anwenderinformationen: Hinweise für Anwender zu bewährten Sicherheitsverfahren	

D.2.2 „Arten von Bedrohungen“

Tabelle D.2 – Arten von Bedrohungen

ID der Arten von Bedrohungen (TTID)	Allgemeine Arten von Bedrohungen	Mögliche Schadensbegrenzungsmaßnahmen	Anmerkungen
TTID1	Spoofing der Identität		
TTID 1.1	Empfänger nimmt gefälschten Sender als legitimen Anwender an	CM1: Authentifizierung des Kommunikationspartners, z. B. durch Verwendung von Zertifikaten CM2: Trennung von Netzwerken	
TTID 1.2	Brute-Force-Angriff: Versuch und Irrtum zum Knacken von Kennwörtern, Anmeldedaten und Verschlüsselungsschlüsseln		
TTID 1.3	Unbefugte Anwender verwenden legitime Anmeldedaten	CM3: Hinweise für Anwender in den Anwenderinformationen zum ordnungsgemäßen Umgang mit vertraulichen Daten	
TTID 2	Manipulation		
TTID 2.1	Manipulation durch physische Mittel	CM4: Physischer Zugriff nur mit einem speziellen Schlüssel (nicht mit leicht verfügbaren Werkzeugen wie Schraubendrehern, Schraubenschlüsseln, Sechskantschlüsseln, Zangen) [Quelle: EN ISO 14119]	
TTID 2.2	Manipulation von Konfigurationsdaten		
TTID 2.3	Manipulation von Speichergeräten		
TTID 3	Verleugnung		
TTID 3.1	Ein Angreifer manipuliert kritische sicherheitsbezogene Daten und stellt sie nach einem Vorfall wieder her, um die Veränderung zu verschleiern	CM5: Zusammenstellung von Nachweisen (siehe EN 50742,...)	
TTID 3.2	Vernichtung von Nachweisen		
TTID 3.3	Beseitigung der Möglichkeit zur Beweissicherung (z. B. Trennung des Speichergeräts für Protokolldaten)		
TTID 4	Offenlegung		
	??? Kennwortdiebstahl???		
TTID 5	Dienstverweigerung		

ID der Arten von Bedrohungen (TTID)	Allgemeine Arten von Bedrohungen	Mögliche Schadensbegrenzungsmaßnahmen	Anmerkungen
TTID 5.1	Störsignale durch elektromagnetische Interferenz, die zu Fehlern oder zu einem (potenziell unsicheren) Systemhalt führen		
TTID 5.2	Physische Beschädigung oder Zerstörung	CM6: Sicherstellung, dass das Gerät sicher ausfällt	
TTID 5.3	Störung von Diensten		
TTID 6	Rechteausweitung		
TTID 6.1	Ein Angreifer ändert die Verbindungsfähigkeiten einer Schnittstelle, um deren Expositionspegel potenziell zu erhöhen.		

Anhang ZZ
(informativ)

Zusammenhang zwischen dieser Europäischen
Norm und den grundlegenden Anforderungen
der abzudeckenden Verordnung (EU) 2023/1230

Diese Europäische Norm wurde im Rahmen eines von der Europäischen Kommission erteilten Normungsauftrags C(2025)129 final, Durchführungsbeschluss der Kommission vom 20. Januar 2025, an das Europäische Komitee für Normung und das Europäische Komitee für elektrotechnische Normung im Hinblick auf Maschinen zur Unterstützung der Verordnung (EU) 2023/1230 des Europäischen Parlaments und des Rates (M/605) erstellt, um ein freiwilliges Mittel zur Erfüllung der grundlegenden Anforderungen der Verordnung (EU) 2023/1230 des Europäischen Parlaments und des Rates vom 14. Juni 2023 über Maschinen (ABl. L 165 vom 29. Juni 2023) bereitzustellen.

Sobald diese Norm im Amtsblatt der Europäischen Union im Sinne dieser Verordnung in Bezug genommen worden ist, berechtigt die Übereinstimmung mit den in [Tabelle ZZ.1](#) aufgeführten normativen Abschnitten dieser Norm innerhalb der Grenzen des Anwendungsbereiches dieser Norm zur Vermutung der Konformität mit den entsprechenden grundlegenden Anforderungen dieser Richtlinie und den zugehörigen EFTA-Vorschriften.

Tabelle ZZ.1 – Zusammenhang zwischen dieser Europäischen
Norm und der Verordnung (EU) 2023/1230, Anhang III

Grundlegende Anforderungen der Verordnung (EU) 2023/1230	Abschnitt(e)/Unterabschnitt(e) dieser EN	Erläuterungen/Anmerkungen
1.1.9	4.3, 7.1 , 7.2.1 , 7.3.2 , 7.3.3 , 7.3.4 7.4.2 , 7.4.3 , 7.5 8.3 9	
1.2.1, 2. Absatz, Punkt a)	4.3 7.1 , 7.2.1 , 7.4.2 , 7.4.3	
1.2.1, 2. Absatz, Punkt f)	7.3.2 , 7.3.3 , 7.3.4 , 7.5 8.3 , 8.4	

- WARNHINWEIS 1** – Die Konformitätsvermutung bleibt nur bestehen, so lange die Fundstelle dieser Europäischen Norm in der im Amtsblatt der Europäischen Union veröffentlichten Liste erhalten bleibt. Anwender dieser Norm sollten regelmäßig die im Amtsblatt der Europäischen Union zuletzt veröffentlichte Liste einsehen.
- WARNHINWEIS 2** – Für Produkte, die in den Anwendungsbereich dieser Norm fallen, können weitere Rechtsvorschriften der EU anwendbar sein.

Literaturhinweise

- [1] EN ISO 13849-1:2023, *Sicherheit von Maschinen - Sicherheitsbezogene Teile von Steuerungen - Teil 1: Allgemeine Gestaltungsleitsätze (ISO 13849-1:2023)*
- [2] Algorithms, key size and parameters report <https://www.enisa.europa.eu/publications/algorithms-key-size-and-parameters-report-2014>
- [3] BSI TR-02102-1, *Cryptographic Mechanisms: Recommendations and Key Lengths* Version: 2025-1 https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-TR-02102-1.pdf?__blob=publicationFile
- [4] EN ISO/IEC 19790, *Informationstechnik - Sicherheitstechniken - Sicherheitsanforderungen für kryptografische Module (ISO/IEC 19790:2012, korrigierte Fassung 2015-12)*
- [5] EN 415-3:2021, *Sicherheit von Verpackungsmaschinen - Teil 3: Form-, Füll- und Verschleißmaschinen; Füll- und Verschleißmaschinen*

English Version

Safety of machinery - Protection against corruption

To be completed

To be completed

This draft European Standard is submitted to CENELEC members for enquiry.
Deadline for CENELEC: 2026-02-27.

It has been drawn up by CLC/TC 44X.

If this draft becomes a European Standard, CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CENELEC in three official versions (English, French, German).
A version in any other language made by translation under the responsibility of a CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CENELEC members are the national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, the Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, the Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and the United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Warning : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.



European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique
Europäisches Komitee für Elektrotechnische Normung

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brussels

1	Contents	Page
2	European foreword	3
3	Introduction	4
4	1 Scope	5
5	2 Normative references	5
6	3 Terms and definitions	6
7	4 Protection against corruption	8
8	4.1 General.....	8
9	4.2 Connection of machinery.....	8
10	4.3 General process requirements.....	8
11	5 Process requirements	10
12	5.1 Introduction	10
13	6 Approach B process requirements	10
14	7 Product requirements	11
15	7.1 Interfaces	11
16	7.2 Security measures	11
17	7.2.1 General.....	11
18	7.2.2 Cryptography	11
19	7.3 Information collection	12
20	7.3.1 Types of interventions	12
21	7.3.2 Intervention evidence to be collected	12
22	7.3.3 Logging requirements.....	12
23	7.3.4 Storage duration requirements	13
24	7.3.5 Storage protection requirements	13
25	7.4 Protection measures against corruption	13
26	7.4.1 General.....	13
27	7.4.2 Safety-related Security levels.....	13
28	7.4.3 Security protection requirements	14
29	7.5 Identification of software versions and configuration.....	16
30	8 Approach B product requirements	17
31	8.1 General.....	17
32	8.2 Machinery systems.....	17
33	8.3 Machinery components.....	17
34	8.4 Identification	18
35	8.5 Persistency.....	18
36	9 Information for use	18
37	Annex A (informative) Examples of logging formats	19
38	Annex B (informative) Threat assessment	20
39	Annex C (informative) Threat modelling for safety systems	25
40	Annex D (informative) List of threats and mitigations	62
41	Annex ZZ (informative) Relationship between this European Standard and the essential requirements of Regulation (EU) 2023/1230 aimed to be covered	66
43	Bibliography	67

44 European foreword

45 This document (prEN 50742:2025) has been prepared by CLC/TC 44X "Safety of machinery: electrotechnical
46 aspects".

47 This document is currently submitted to the Enquiry.

48 The following dates are proposed:

- latest date by which the existence of this (doa) dav + 6 months
document has to be announced at national level
- latest date by which this document has to be (dop) dav + 12 months
implemented at national level by publication of
an identical national standard or by
endorsement
- latest date by which the national standards (dow) dav + 36 months
conflicting with this document have to be (to be confirmed or
withdrawn modified when voting)

49 This document has been prepared under a standardization request addressed to CENELEC by the European
50 Commission. The Standing Committee of the EFTA States subsequently approves these requests for its
51 Member States.

52 For the relationship with EU Legislation, see informative Annex ZZ, which is an integral part of this document.

Introduction

Machinery must be safe in order to prevent injuries and loss of life.

The communication with the machine must not lead to hazardous situations.

The manufacturer performs a risk assessment according to EN ISO 12100 to identify all potential hazards.

Vulnerabilities can lead to a corruption of the control system of the machine and hazards can lead to dangerous situations.

By exploitation of vulnerabilities via communication with the machine, the machine could be operated outside safe parameters or degrade safety functions.

Vulnerabilities cannot create new hazards.

The probability that someone will use a vulnerability for a malicious attempt cannot be predicted.

The risk can only be assessed in terms of its impact on functional safety.

Vulnerabilities are divided into several types.

This document provides two approaches:

- Approach A (Clause 5 and 7) has been developed to facilitate compliance for machinery developed without references to EN IEC 62443 series of standards.

- Approach B (Clauses 6 and 8) has been provided to facilitate compliance for machinery developed in the context of the EN IEC 62443-3-3:2019, EN IEC 62443-4-1:2018, EN IEC 62443-4-2:2019.

NOTE 1 The EN IEC 62443 series provides information and a methodology to approach cybersecurity.

This document is intended for use by machinery designers, control system manufacturers and integrators, and others involved in the specification, design and validation of an SCS.

NOTE 2 See EN IEC 62443-4-1:2018; the manufacturer can be a product supplier or system integrator.

This document does not address the role of the user.

1 Scope

This document provides requirements and recommendations for protection against corruption for machinery, related products and partly completed machinery referred to in this document as 'machinery'.

This document provides requirements and recommendations to prevent accidental and intentional (including malicious) corruption of machines resulting in hazardous situations.

This document applies to:

- hardware components, including interfaces to remote devices and control systems, that can transmit signals or data;

- software and data;

if they could influence the safety of the machinery.

NOTE 1 Topics can overlap with the domain of cybersecurity but are not necessarily identical in their coverage.

NOTE 2 This document does not describe functional safety requirements of control systems in machinery.

This document specifies requirements to related risks in all lifecycle steps.

Machinery interfaces to external systems and services are in the scope of this document. External systems and services are out of the scope of this document.

This document does not apply to machinery installed before the date of its publication.

This document specifies requirements related to protection against corruption related risks in all lifecycle steps such as:

- development;

- manufacturing;

- commissioning;

- operation;

- maintenance;

- decommissioning.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

EN ISO 12100:2010, *Safety of machinery - General principles for design - Risk assessment and risk reduction (ISO 12100:2010)*

EN IEC 62443-3-3:2019,¹ *Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels*

EN IEC 62443-4-1:2018, *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*

¹ As impacted by EN IEC 62443-3-3:2019/AC:2019.

EN IEC 62443-4-2:2019,² *Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components*

3 Terms and definitions

For the purposes of this document, the following terms and definitions apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp/>
- IEC Electropedia: available at <https://www.electropedia.org/>

3.1

control system

system which responds to input signals from parts of the machinery, from operators, from external control equipment or any combination of these and generates corresponding output signals to the machinery actuators, causing the machine to perform in the intended manner

3.2

intervention

legitimate or illegitimate action or event that changes the software or data which modifies or interrupts the behaviour, state or operation of the machinery temporarily or permanently

Note 1 to entry: Action taken on safety routines, safety variables, calibration data, firmware updates of safety-related parts of software are considered interventions in the sense of this document.

Note 2 to entry: Normal operational changes to variables, such as opening a safety gate, does not constitute an intervention in the sense of a change to data.

EXAMPLE

- 1) The modification of the installed software on the machinery due to an update or configuration change(s).
- 2) modular PLC, if a PLC module is replaced by an identical spare part it is not considered an intervention; if an additional part is introduced; it is considered a modification.

3.3

modification

change caused by an intervention

Note 1 to entry: Including software version, sensor calibration, configuration data etc.

EXAMPLE Update of safety-related software.

3.4

evidence

anything that allows the detection that an event or action has happened

EXAMPLE log records, broken safety seals (anti-tampering seals) and scratch marks, damage to interface covers e.g. RJ45 cover

3.5

corruption

accidental or illegitimate modification of machinery data potentially resulting in hazardous situations

² As impacted by EN IEC 62443-4-2:2019/AC:2022-09.

- 146 **3.6**
 147 **security context**
 148 security provided to the machinery by the environment in which the machinery is intended to be used
- 149 Note 1 to entry: The security provided to the machinery by its intended environment can effectively restrict the threats that
 150 are applicable to the machinery.
- 151 Note 2 to entry: See Clause C.5.
- 152 [SOURCE: EN IEC 62443-4-1:2018, 3.1.23, modified — removed the word product and substituted with the
 153 word machinery]
- 154 **3.7**
 155 **countermeasure**
 156 action, device, procedure or technique that reduces a threat, a vulnerability or the consequences of an attack
 157 by minimizing the harm the attack can cause or by discovering and reporting it so that corrective action can be
 158 taken
- 159 [SOURCE: EN IEC 62443-4-2 :2019, 3.1.15]
- 160 **3.8**
 161 **compensating countermeasure**
 162 countermeasure employed in lieu of or in addition to inherent security capabilities to comply with one or more
 163 security requirements
- 164 [SOURCE: EN IEC 62443-4-2 :2019, 3.1.9]
- 165 **3.9**
 166 **reasonably practicable**
 167 balancing of risk reduction against time, money and effort
- 168 **3.10**
 169 **tracing log**
 170 collection of data recording interventions that affect the safety related control system
- 171 **3.11**
 172 **vulnerability**
 173 flaw or weakness in a system's design, implementation, or operation and management that could be exploited
 174 to corrupt the system's integrity
- 175 **3.12**
 176 **critical data**
 177 data whose manipulation can result in increase of hazard
- 178 **3.13**
 179 **safety-related application software**
 180 **SRASW**
 181 software specific to the application and generally containing logic sequences, limits and expression that control
 182 the appropriate inputs, outputs, calculations and decisions necessary to meet the safety-related part of a control
 183 system (SRP/CS) requirements
- 184 [SOURCE: EN ISO 13849-1:2023, 3.1.41]
- 185 **3.14**
 186 **safety-related embedded software**
 187 **SRESW**
 188 software that is part of the system supplied by the manufacturer and is not intended for modification by the end-
 189 user

[SOURCE: EN ISO 13849-1:2023, 3.1.42, modified – Note 1 to entry deleted]

3.15

SRSL

Safety-Related Security Requirement

parameter representing the sum of security requirements that are related to a specific safety-related function used in order to protect it against corruption of data

4 Protection against corruption

4.1 General

Either approach A (Clauses 5 and 7) or approach B (Clauses 6 and 8) shall be applied.

4.2 Connection of machinery

The design and the construction of machinery shall not allow hazardous situations via connections.

A connection (physical, logical and indirect) is any link that can exchange information, for example:

- a network link,
- a WIFI connection,
- a single wire,
- wires of the power supply,
- an optical link,
- a card reader interface,
- a connection from a machine to external systems:
 - building networks
 - cloud services
 - service tools

NOTE 1 The connectivity can exist through equipment permanently available on site, or equipment temporarily brought to the location during the installation, operation and maintenance, or decommissioning steps.

NOTE 2 Example of a machinery not to be considered is a simple drilling machine without any possibility of connection.

4.3 General process requirements

Following a risk assessment according to EN ISO 12100:2010, where all potential hazards have previously been identified, the designer shall perform a threat assessment.

The content of the threat assessment can be limited to additional threats that are not covered by the minimum security measures.

The designer shall define the security context for the machine.

The following principles shall be applied in order to protect a machine from threats that can lead to hazardous situation(s):

- a) Where vulnerabilities are present, eliminate those that can lead to hazardous situation(s).

EXAMPLE 1 To eliminate any unnecessary interfaces so that the threats cannot exploit this vulnerability.

EXAMPLE 2 JTAG interface(s) used during development and then disabled.

EXAMPLE 3 Elimination can be a result of redesign using different components (maybe from same vendor).

b) if it is not possible to eliminate vulnerabilities, the designer shall mitigate them.

EXAMPLE Mitigation, implementation of user authentication on an interface.

c) For any vulnerabilities that remain after steps a) and b), information for use shall provide all necessary information for compensating countermeasure by the user. See Annex C.

EXAMPLE Manufacturer states in the instruction for use that the fieldbus connection of the machine is only designed for internal(local) connections to another machine in a trusted network and is not allowed to be connected to an untrusted network.

Vulnerabilities cannot create new hazards, but their exploitation can compromise the protective measures; therefore, a threat assessment shall be performed.

NOTE By exploitation of vulnerabilities via communication with the machine, the machine could be operated outside safe parameters or degrade safety functions. The risk can only be assessed in terms of its impact on functional safety.

Countermeasures shall not negatively affect the functional safety of the machinery.

EXAMPLE When a cryptographic function is implemented, it needs to be verified that it does not lead to hazardous situations due to increased safety function response time.

The probability that someone will try to exploit a specific vulnerability for a malicious attempt cannot be predicted. Therefore, the likelihood of being a target/victim shall not be relevant for the threat assessment.

In order to fulfil the essential requirements and recommendations to prevent accidental and intentional (including malicious) corruption of machines resulting in hazardous situations, designers shall follow approach A in below table.

However, if designers prefer to follow EN IEC 62443-3-3:2019, EN IEC 62443-4-1:2018, EN IEC 62443-4-2:2019 for the security requirements for their machinery, they shall follow approach B.

Table 1 provides an overview of both approaches:

Table 1 — Process requirements overview

Common clauses to be followed:	
— Risk assessment according to EN ISO 12100:2010	
— Clause 4 - Protection against corruption	
— Clause 9 - Information for use	
Specific clauses to be followed:	
Approach A	Approach B
— Clause 5 for process requirements	— Clause 6 for process requirements
— Clause 7 for product requirements	— Clause 8 for product requirements

NOTE Both routes are equally allowed to be followed. The selected route depends to the effort the manufacturer needs to do, as well as the value for the manufacturer, but also their knowledge, field of application, ect.

5 Process requirements

5.1 Introduction

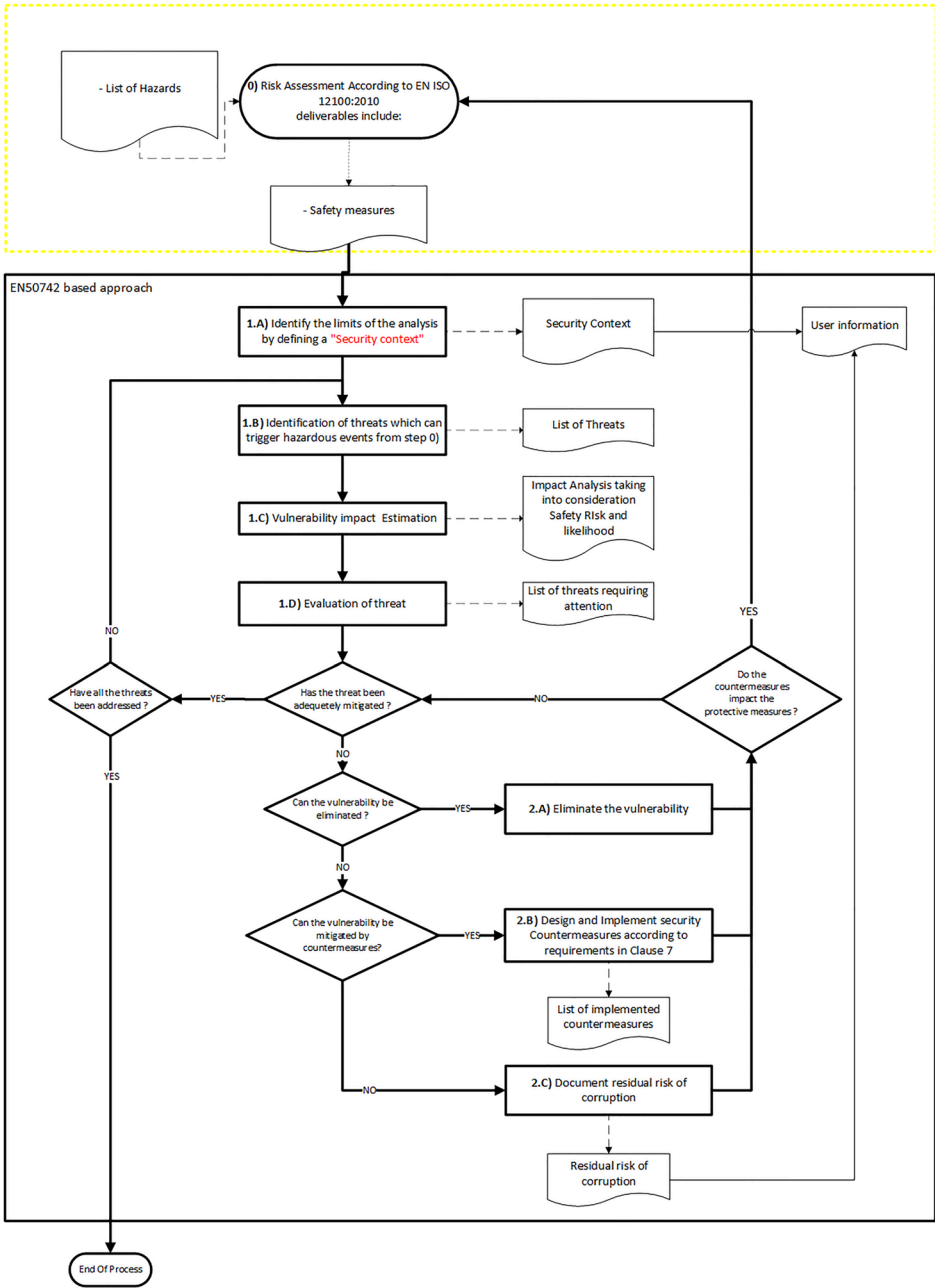


Figure 1 — Risk assessment process including safety and security aspects

6 Approach B process requirements

The requirements of EN IEC 62443-4-1:2018 shall apply.

7 Product requirements

7.1 Interfaces

All machinery interfaces that are accessible and can affect the safety of the machinery shall be identified and protected using countermeasures or compensating countermeasures.

Figure 2 shows an example of machinery interfaces which can be subject to an attack.

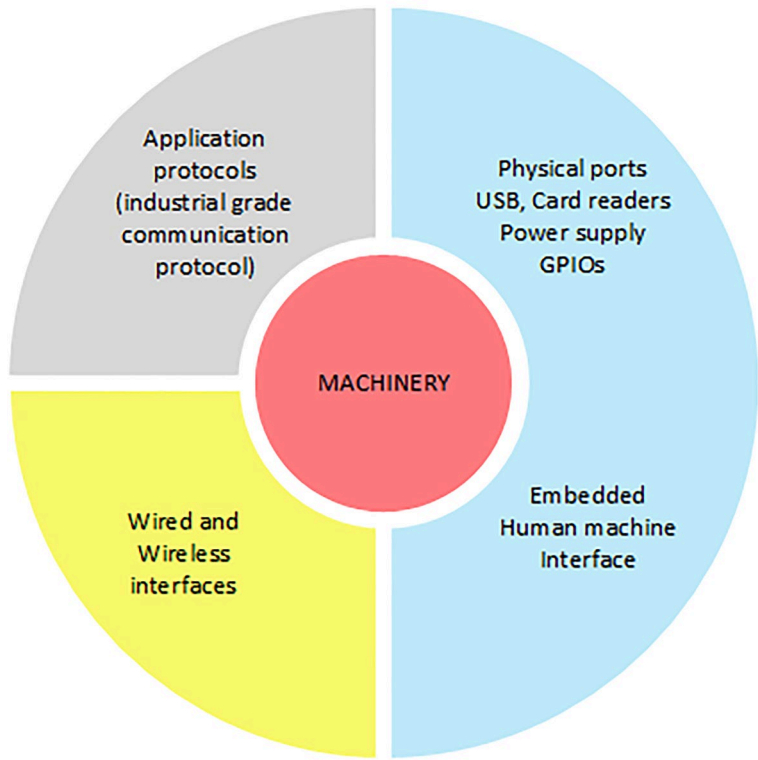


Figure 2 — Machinery interfaces example

Guidelines on second order attack are in Annex C.

7.2 Security measures

7.2.1 General

Security measures to protect against corruption of the machinery leading to hazardous situations shall be selected on a risk-based approach in order to be adequate.

This risk-based approach shall consider both safety risks and threat risks of the machinery's intended use and security context.

Security measures shall not negatively affect the functional safety.

7.2.2 Cryptography

Where cryptographic methods are used, only state of the art algorithm should be selected.

NOTE 1 Information related to state-of-the-art algorithms is available from organizations such as ENISA www.enisa.europa.eu. A list of examples is available in the bibliography [2][3][4].

NOTE 2 When a cryptographic function is implemented, it can be verified that it does not lead to hazardous situations due to increased safety function response time.

7.3 Information collection

7.3.1 Types of interventions

The following list provides types of interventions that shall be considered:

- a. safety parametrization/configuration parameters (via identification means like CRC...),
EXAMPLE connecting or disconnecting flash drive or SD card, when being used for storing configuration data and logging data that is relevant for compliance of machinery
- b. SRESW update/modification (via identification means only, such as version number, CRC, ect...),
- c. SRASW updates/modification (via identification means only, such as version number, CRC, ect...),
- d. parametrization of human-machine interfaces if it can creates hazards,
- e. software relevant for displaying safety instructions.

NOTE 1 Any intervention that does not result in changes of the data listed above does not need to be logged (e.g. successful/unsuccessful authorized interventions).

NOTE 2 Actions on the machine triggering a safe state of the machine e.g. triggering safety light curtain, are not in scope.

NOTE 3 The version of the SRASW binaries or SRESW binaries does not need to be kept in the tracing log.

7.3.2 Intervention evidence to be collected

Digital evidence of a legitimate or illegitimate action or event that changes or interrupts the behaviour, state or operation of the machinery temporarily or permanently, that changes the software or data shall be recorded and shall contain the following data as a minimum:

- a. an indication of the type of intervention that affects software relied on for risk reduction according to the risk assessment,
- b. means to allow correlation of logged events, (e.g. timestamping referring to absolute or relative system time), boot counts, system times, running counters,
- c. deletion of the log file.

NOTE Timestamping can be provided by the device making the log event or the remote log collector.

7.3.3 Logging requirements

The machine shall provide digital or physical means for traceability related to interventions.

Digital evidence of interventions shall be readable and accessible.

The documentation shall provide information on how to access and interpret the recorded evidence.

If a binary format is used, the format should be documented as part of the information for use, so that anyone can program a converter to make the logs intelligible.

Where collection of digital evidence is not reasonably practicable, physical evidence (e.g. tampering of a seal) shall be used.

Evidence collection of interventions is required and shall be done automatically by the machinery or related product.

NOTE See Annex A for examples of recognized industry practice on logging standards.

The log records may be stored in the control system, the components inside the machine or in a component for storing the data external to the machinery (e.g. Network Attached Storage (NAS), local hard drive, etc...).

7.3.4 Storage duration requirements

Log storage shall contain, as a minimum, the evidence of the last intervention of each type.

Tracing log data records of each intervention shall be stored for at least five years.

The tracing log shall be enabled, as a minimum, from the time the machine is put into service.

7.3.5 Storage protection requirements

Logs shall be properly secured to protect against tampering.

Log deletion, if applicable, shall only be possible by an authorized procedure.

7.4 Protection measures against corruption

7.4.1 General

Corruption can compromise the integrity and effectiveness of the risk-reduction measures, leading to potentially hazardous consequences.

To safeguard against such risks, it is essential to first determine the required level of protection.

This involves identifying the vulnerabilities and specific needs of the application in question and defining Safety-related Security levels (SRSL) for the individual risk-reduction measures.

Once the appropriate level of protection is identified, adequate measures can be applied to mitigate the threats effectively.

These measures are intended to preserve the integrity and reliability of the safety control system.

7.4.2 Safety-related Security levels

For each identified safety function, a Safety-related security level (SRSL) shall be determined and documented.

The determination of the SRSL shall be based on the result of the threat assessment and shall correlate to the risk-reduction applied by the protective measure and to the likelihood of a successful threat exploitation.

Four SRSL levels are defined, where SRSL0 gives no specific additional requirements, and SRSL1 to SRSL3 correspond from low to high security levels.

NOTE Annex B provides guidance for the determination of the SRSL. The likelihood of a successful threat exploitation can be expressed as an attack potential (AP) being a function of several parameters such as Attacker Capability (AC), Window of Opportunity (WoO) and Exposure Level (EL).

The measures associated with an appropriate Safety Related Security Level (SRSL) shall be selected to protect safety functions.

Table 2 — SRSL description

SRSL	Description
SRSL0	This level shall be used for completely isolated safety system. (e.g. completely isolated networks within the machine; or where safety functions have no external interfaces.)
SRSL1	This level (or higher) shall be selected to protect safety functions when the attack potential is low, where an attack can only occur under very specific circumstances. When the severity of the harm is reversible, it might also be selected for a moderate attack potential where an attack has a reasonable likelihood of occurring.
SRSL2	This level (or higher) shall be selected to protect safety functions when the attack potential is moderate, where an attack has a reasonable likelihood of occurring. When the severity of the

SRSL	Description
	harm is reversible, it might also be selected for a significant attack potential where an attack has a high likelihood of occurring.
SRSL3	This level (or higher) shall be selected to protect safety functions when the attack potential is significant or critical, where an attack has a high likelihood of occurring or an attack is almost guaranteed to occur. This can be used for connection to untrusted networks e.g. connection to internet.

7.4.3 Security protection requirements

7.4.3.1 General

The machinery shall meet, as a minimum, the security protection requirements listed below corresponding to the determined SRSL.

The security protection requirements shall apply to their respective safety functions and their related interfaces.

NOTE Interface can be “logical interfaces” (Modbus/TCP, Webserver....) on “physical interfaces” (RJ45, USB).

7.4.3.2 Authentication requirements

7.4.3.2.1 Authentication

SRSL0:

None.

SRSL1:

Entities shall be authenticated.

SRSL2:

Entities shall be authenticated.

SRSL3:

Entities shall be uniquely authenticated.

NOTE 1 In this context the word “entities” relates to human users, software processes, device capable of intervention.

NOTE 2 Authentication means include but are not limited to: passwords/ PIN/ dongle/ biometrics/ certificates/ RFID/ NFC/ logical identifiers (e.g. UID, HID, cookies, etc...) or via cryptographic authentication mechanisms such as random challenge, TLS-handshake, X509 certificate, etc

7.4.3.3 Authorization requirements

7.4.3.3.1 Authorization enforcement

SRSL0:

None.

SRSL1:

Interventions shall require authorization.

SRSL2:

Interventions shall require authorization.

SRSL3:

Interventions shall require authorization with specific privileges (e.g. role-based access control).

375 **7.4.3.4 Integrity requirements**

376 **7.4.3.4.1 Software and information integrity**

377 **SRSL0:**

378 None.

379 **SRSL1:**

380 The integrity of software and other critical information such as safety-related configurations, shall be verified at
381 startup (e.g. by use of checksums).

382 **SRSL2:**

383 The integrity of software and other critical information, such as safety-related configurations, shall be verified at
384 startup and periodically (e.g. by use of checksums).

385 **SRSL3:**

386 The integrity of software and other critical information shall be cryptographically verified at startup and
387 periodically during operation (e.g. by use of cryptographic hashes, HMACs, CMACs).

388 **7.4.3.4.2 Integrity of boot process**

389 **SRSL0:**

390 None.

391 **SRSL1:**

392 Integrity of the boot process shall be protected and shall be verified at startup (e.g. checksums).

393 **SRSL2:**

394 Integrity of the boot process shall be protected and shall be verified at startup.

395 **SRSL3:**

396 A secure boot process shall be implemented (e.g. cryptographic signature verification with trusted roots, rollback
397 or safe state upon verification failure).

398 **7.4.3.4.3 Information exchange integrity**

399 **SRSL0:**

400 None.

401 **SRSL1:**

402 The integrity of exchanged information shall be verified.

403 **SRSL2:**

404 The integrity of exchanged information shall be verified.

405 **SRSL3:**

406 The integrity of exchanged information shall be guaranteed by implementing secure cryptographic protocols
407 that detect and reject modified or replayed messages.

408 **7.4.3.4.4 Input data validation**

409 **SRSL0:**

410 None

411 **SRSL1:**

412 Input data shall be validated against defined boundaries.

Invalid input data shall be rejected.

SRSL2:

Input data shall be validated rigorously, including syntax, semantics, format correctness, and data-type verification.

Invalid input data shall be rejected.

SRSL3:

Input data shall be validated rigorously using strict, context-aware validation including syntactical, semantic, boundary, and protocol-specific constraints.

Invalid input data shall be rejected.

7.4.3.4.5 Physical tampering

SRSL0:

None.

SRSL1:

Physical tampering shall be detected e.g. seal breaking.

SRSL2:

Physical tampering shall be detected e.g. seal breaking.

SRSL3:

Physical tampering shall be detected e.g. seal breaking.

7.4.3.5 Authenticity requirements

7.4.3.5.1 Authenticity of SRESW/SRASW

SRSL0:

None.

SRSL1:

None.

SRSL2:

The authenticity of critical data (e.g. SRESW/SRASW, and critical configuration data) shall be verified via e.g. cryptographic signatures or equivalent at installation time.

SRSL3:

The authenticity of critical data (e.g. SRESW/SRASW, and critical configuration data) shall be verified via cryptographic signatures or equivalent at installation time.

7.5 Identification of software versions and configuration

Identification of software versions and configuration information relevant for protection against corruption shall be available on demand. Software identification and configuration information shall be available in human readable form, either by a built-in system or by an external tool.

NOTE 1 A laptop or a mobile phone with a readily available application can be considered as an example of a commonly available tool.

NOTE 2 Distinction needed for machinery identification and related products identification through system (HW).

8 Approach B product requirements

8.1 General

Machinery (as per the definition in the scope of this document) are systems composed of components. EN IEC 62443 series defines requirements for systems and components, as well as for the respective roles of system integrator and product suppliers. The EN IEC 62443 series structure ensures coherence between system and component requirements. This Clause defines the requirements for both machinery systems and machinery components.

8.2 Machinery systems

Machinery systems shall comply with EN IEC 62443-3-3:2019 with the security requirements listed in Table 3 for their safety function(s).

Table 3

Foundational Requirement (FR)	Security Level	Security Requirements
FR 1 – Identification and authentication control (IAC)	SL-C2	SR1.1
FR 2 – Use control (UC)	SL-C2	SR2.1, SR2.8, SR2.9
FR 3 – System integrity (SI)	SL-C2	SR3.1, SR3.4, SR3.5, SR3.6
FR 4 – Data confidentiality	None	None
FR 5 – Restricted data flow (RDF)	SL-C1	SR5.1
FR 6 – Timely response to events (TRE)	SL-C1	SR6.1
FR 7 – Resource availability (RA)	SL-C2	SR7.1, SR7.2

NOTE 1 In Table 3, for each foundational requirement, the listed security requirements are the required subset of the requirements defined by the security level.

NOTE 2 The essential functions as per EN IEC 62443-3-3:2019 include the safety functions of the machinery.

8.3 Machinery components

Machinery components shall comply with EN IEC 62443-4-2:2019 with the security requirements of Table 4 for their safety function(s).

Table 4

Foundational Requirement (FR)	Security Level	Security Requirements
FR 1 – Identification and authentication control (IAC)	SL-C2	CR1.1, CR1.2
FR 2 – Use control (UC)	SL-C2	CR2.1, CR2.6, CR2.8, CR2.9, CR2.12, EDR 2.13
FR 3 – System integrity (SI)	SL-C2	CR3.1, CR3.4, CR3.5, CR3.6, EDR3.2, EDR3.11, EDR3.14
FR 4 – Data confidentiality	None	
FR 5 – Restricted data flow (RDF)	SL-C1	CR 5.1
FR 6 – Timely response to events (TRE)	SL-C1	CR 6.1
FR 7 – Resource availability (RA)	SL-C2	CR 7.1, CR7.2

NOTE 1 In Table 4, for each foundational requirement, the listed security requirements are the required subset of the requirements defined by the security level.

NOTE 2 The essential functions as per EN IEC 62443-4-2:2019 include the safety functions of the machinery.

Machinery components shall comply with EN IEC 62443-4-2:2019, 4.2 support of essential functions (CCSC 1) and 4.4 least privilege (CCSC 3).

Compensating countermeasures implemented in the machinery system may be taken into account for achieving the security requirements of machinery components as per EN IEC 62443-4-2:2019, 4.3 (CCSC2). A machinery component may have a lower SL-C than required in Table 4 if this machinery component is part of a machinery system providing the compensating countermeasures ensuring that this system fulfils the SL-C required in Table 3. In this case, the information for use of the component shall specify the need for compensating countermeasures and shall specify the security requirements the machinery component does not fulfil.

Machinery components used for both safety function and non-safety functions shall also comply with the security levels or security requirements of Table 4.

8.4 Identification

Identification of software versions and configuration information relevant for safety functions shall be available on demand. Software identification and configuration information shall be available in human readable form, either by a built-in system or by an external tool.

NOTE Typical external tools include laptop, portable device or a mobile phone with a readily available application.

8.5 Persistency

Audit records as per EN IEC 62443-4-2:2019, 6.10 (CR 2.8 – Auditable events) shall be persistent for at least 5 years.

NOTE As per definition of the scope, persistency requirement applies to safety functions only.

9 Information for use

Information for use shall include:

- information about the security context for the machine,
- identification of software versions and configuration information relevant for safety function,
- instruction on how to access the information about the software versions and configuration relevant to safety functions and changes to them,
- information about permission and/or prohibition of modifications.

Annex A (informative)

Examples of logging formats

This is an informative annex to provide the reader of the standard further information relating to logging formats. It is however not necessary to follow these examples in order to meet the essential requirements outlined in this document

CLF - Common Log Format: The Common Log Format is a file format that is used for logging web server requests.

NOTE 1 See also RFC 6872; examples can be found here: <https://www.rfc-editor.org/rfc/rfc6872>

Syslog: Syslog is a protocol for recording and transmitting log messages common on a wide range of systems. Many types of network devices, IoT systems, desktops, and servers support the protocol and its standard plaintext format makes messages easy for machines and humans to read.

NOTE 2 See also RFC 5424.

W3C extended Log File Format: the extended log file format is designed to meet the following needs:

- permit control over the data recorded,
- support needs of proxies, clients and servers in a common format,
- provide robust handling of character escaping issues,
- allow exchange of demographic data,
- allow summary data to be expressed.

The log file format described permits customized logfiles to be recorded in a format readable by generic analysis tools.

NOTE 3 Examples can be found here: <https://www.w3.org/TR/WD-logfile>

CEF - Common Event Format: The Common Event Format (CEF) is an industry standard format used in conjunction with syslog messages by many security vendors to enable interoperability of events between different platforms

The Common Event Format (CEF) is a standardized logging format developed by ArcSight (now part of Micro Focus), a security information and event management (SIEM) solution provider. CEF is designed to simplify the process of logging security-related events and making it easier to integrate logs from different sources into a single system. CEF is based on the syslog format, which is a standard for message logging that is supported by most network devices and operating systems.

BSI minimum standard for the logging and detection of cyber attacks: With this minimum standard, the BSI defines a uniform approach to the detection of cyber attacks as required by the 2017 Implementation Plan while establishing a basis for the specification and implementation of organizational and technical measures.

Annex B
(informative)

Threat assessment

To objectively determine the adequate and appropriate requirements, the first steps are to do define Assets, Define Security Context, Trust Boundaries and model the system (e.g. by using a dataflow diagram), for example as described in the relevant parts of Annex C.

The safety-related security level (SRSL) is the key property to decide on the appropriateness and adequacy of protective measures. The level also determines which malicious attempts are reasonably foreseeable and must be guarded against.

The first parameter to define is the Exposure Level (EL), which is proportionate to the attack surface of the interface and connection under consideration.

An effective strategy to reduce the exposure level of safety functions is to perform network segregation between safety relevant and non-safety relevant network parts.

All connections to safety functions need to be evaluated.

If a connection crosses Trust Boundaries (C.6), its exposure level is the higher one. E.G. a connection between EL1 and EL2 will be considered as EL2.

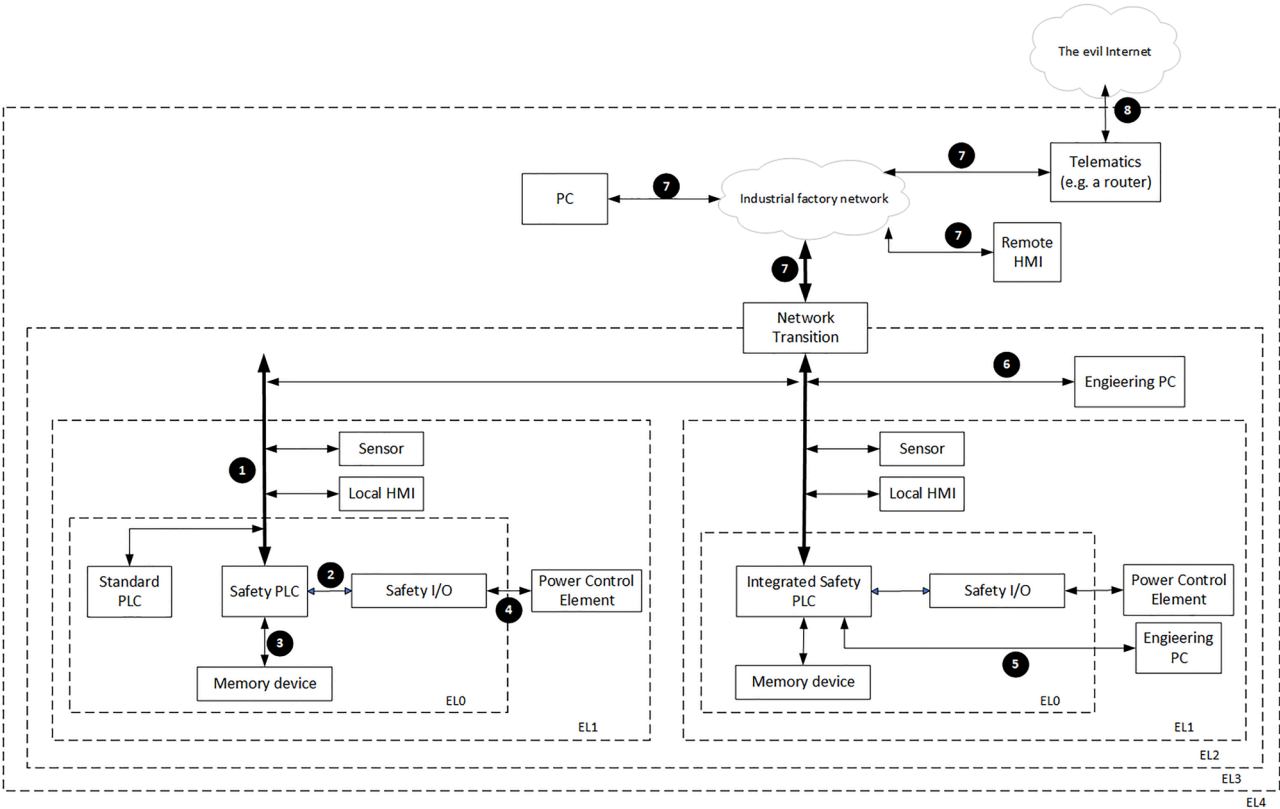
NOTE Further network segmentation inside each EL level are permitted.

Table B.1 — Exposure level

Type of exposure	Exposure level	Description	Guidance
Internal	EL0	Complete trusted environment	Component and networks that are not accessible from outside the machine except with the use of key or tools.
Physical	EL1	Physical access to a trusted environment	Every connection interface placed at the border of EL0 environment which requires to physically touch or manipulate the system. This level may correspond to Levels 0–1 of Purdue Reference Model. Examples: RJ45 connectors, USB interfaces, displays and buttons on the Machinery
Local	EL2	Local OT network access for production control	Bus or any type of industrial network used to exchange data between machines (e.g. to control the physical processes). Similar to Level 2 of the Purdue Reference Model (example supervisory control through SCADA systems)
Adjacent	EL3	Extended industrial factory network with diverse security properties limited to a local premise.	Corresponds to Manufacturing operations systems similar to the Level 3 of the Purdue Model. This level corresponds to the boundary between OT and IT.

Type of exposure	Exposure level	Description	Guidance
Public	EL4	Remote connection of the Machinery with an untrusted network (e.g. the Internet)	Network transition systems for establishing remote access with the premises (EL3) to/from an untrusted network fall into this category.

Example has to be reviewed for a typical machine:



Key

- 1 e.g. Ethernet based industrial network or a fieldbus
- 2 internal backplane between PLC and I/O modules
- 3 connection between PLC and memory device, e.g. SD card interface
- 4 connection between PLC and memory device, e.g. SD card interface
- 5 e.g. USB (temporarily connected for engineering purposes)
- 6 e.g. Ethernet (temporarily connected for engineering purposes)
- 7 e.g. Ethernet based OT network
- 8 connection to other IT systems

Figure B.1 — example of an Exposure Level assignment for a machinery.

The likelihood of attacks can be indicated by the Attack Potential, which comprises both static and dynamic metrics.

EL is an indicator of attack surface thus it is a static metric, while examples of dynamic metrics include Attacker Capability and Window of Opportunity.

Attacker Capability is the ability to use appropriate means to exploit a vulnerability of the system under consideration and depends both on the Attacker technical expertise (skill) and correct use of the knowledge and tools needed.

569
570
571
572
573
574
575
576
577
578
579
580
581

Uncontrolled copies are uncontrolled
group services gubbs
ifm group services gubbs
Lizenzierung für ifm group services gubbs
Nutzung nur gemäß Nutzungsvereinbarung. Alle Rechte vorbehalten.

Attacker Knowledge can change (even drastically) due to major security incidents, like confidential information leaks from inside the manufacturer organization. In this eventuality, the manufacturer should update the Threat-Risk analysis if the machine is still being put to the market (e.g. serial production), since it has changed the boundary conditions of the analysis.

Table B.2 — Attacker capability score

Attacker Capability (AC)	Description	Examples	Value
Extensive knowledge and Advanced Skill	Possessing highly advanced skillset with capability to retrieve and use deep and specialized knowledge of the system (e.g. full product specifications, system architecture)	e.g. Malicious privileged user, highly-trained hacker	1
Moderate knowledge and Specialist Skill	Possessing advanced technical ability; capable of using a variety of attack tools and retrieving information or with good knowledge of the system.	e.g. trained technician/hacker with good access to sensitive information	2
Moderate knowledge and Medium-level Skill	Possessing Intermediate technical ability; capable of using common attack tools and publicly available information or with moderate knowledge of the system.	e.g. skilled hacker	3
Minimal knowledge and Basic Skills	Possessing trivial skills only, like use of basic tools and with basic knowledge (e.g. standard operating procedures).	e.g. script kiddies, unskilled hackers with general knowledge	4

The designer defines a Security Context (Clause 5, Additional info given in Annex C, C.5), which both defines the validity limits of the analysis and gives the user recommendations for a secure use of the machine.

It is possible to derive a measure of the Window of Opportunity for an attacker (a priori likelihood) to carry a successful attack, i.e. a measure of exploitability linked to time availability.

Window of Opportunity is estimated for the whole machinery and may depend on how and how often servicing activities are carried-out during the lifetime of the machine, and how predictable they are:

Table B.3 — Window of opportunity score

Window of Opportunity (WoO)	Description	Multiplier
Very Restricted	Rarely accessible or under constant surveillance; very limited practical access.	0,6
Moderately Restricted	Occasional, predictable opportunity windows (e.g. monthly maintenance windows, with moderate access control).	0,8
Limited	Regular opportunities (weekly/daily scheduled access with low access control).	0,9
Unlimited	Open, frequent, or unlimited opportunity.	1

Exposure Levels (ELs), as they have been defined above:

582

Table B.4 — Exposure level score

Type of Exposure	Value
EL0 – Internal	0
EL1 - Physical	2
EL2 – Local	5
EL3 - Adjacent	16
EL4 – Public	24

583 The safety-impact caused by corruption of a safety risk-reduction measure, multiplied by the attack potential,
584 gives the required safety-related security level to apply to the measure itself.

585 NOTE 1 For machinery SILs and PLRs, which define the measure of risk-reduction to be applied by the control-system,
586 are commonly used; therefore, since the analysis has already been done in a separate safety risk assessment, it is possible
587 to use PLRs to express the safety impact, including the relation to the H&S of the user. (for the mapping between SIL and
588 PLr refer to Annex A of EN ISO 13849).

589 NOTE 2 Other standards might be used to define the right level of the safety functions, e.g. reference to ISO 25119.

590 When doing the threat modelling according to Annex C, Par. A.4 requires to list all safety-related assets. The
591 SRSLs apply per safety function, per interface.

592 **AP= (EL*WoO) +AC**

593 where

- 594 EL Exposure Level (per interface, per connection)
- 595 WoO: Window of Opportunity (for the whole machinery, depending on Security Context)
- 596 AC Attacker Capability

597

Table B.5 — Attack potential score

Attack Potential Score	Label	Description	Interpretation
0–5	AP0	Very Low	Minimal attack potential; highly unlikely to occur
5.1–10	AP1	Low	Low attack potential; can occur under very specific circumstances
10.1–15	AP2	Medium	Moderate Attack Potential; Has a reasonable likelihood of occurring
15.1–20	AP3	High	Significant Attack Potential; Has a high likelihood of occurring
> 20	AP4	Very High	Critical Attack Potential; An attack is almost guaranteed to occur,

598 EXAMPLE

599 (picture of simple machine in above picture)

600 Supposing a moderately restricted access to the machine → WO = 0,8 multiplier

601 Considering the bus connection between the Safety PLC and the Normal PLC/HMI/Sensors which is between EL1 and EL2
602 → choosing EL2

603 Considering Minimal knowledge and Basic Skills to exploit the vulnerability (4)

604 $AP = (5*0,8) + 4 = 8 \rightarrow AP1$

Table B.6 — Definition of SRSLs mapping according to safety functions and Attack Potential

		Attack Potential (AP)				
		AP0	AP1	AP2	AP3	AP4
Severity Level	low/e.g. reversible	SRSL0	SRSL1	SRSL1	SRSL2	SRSL3
	high/e.g. non reversible	SRSL0	SRSL1	SRSL2	SRSL3	SRSL3

Annex C (informative)

Threat modelling for safety systems

C.1 General

This annex provides examples of a process to determine appropriate and adequate countermeasures to protect a machine against corruption.

C.2 Risk based security evaluation

Figure C.1 below explains the process of risk-based security evaluation using the STRIDE threat modelling methodology; other threat modelling are anyhow valid.

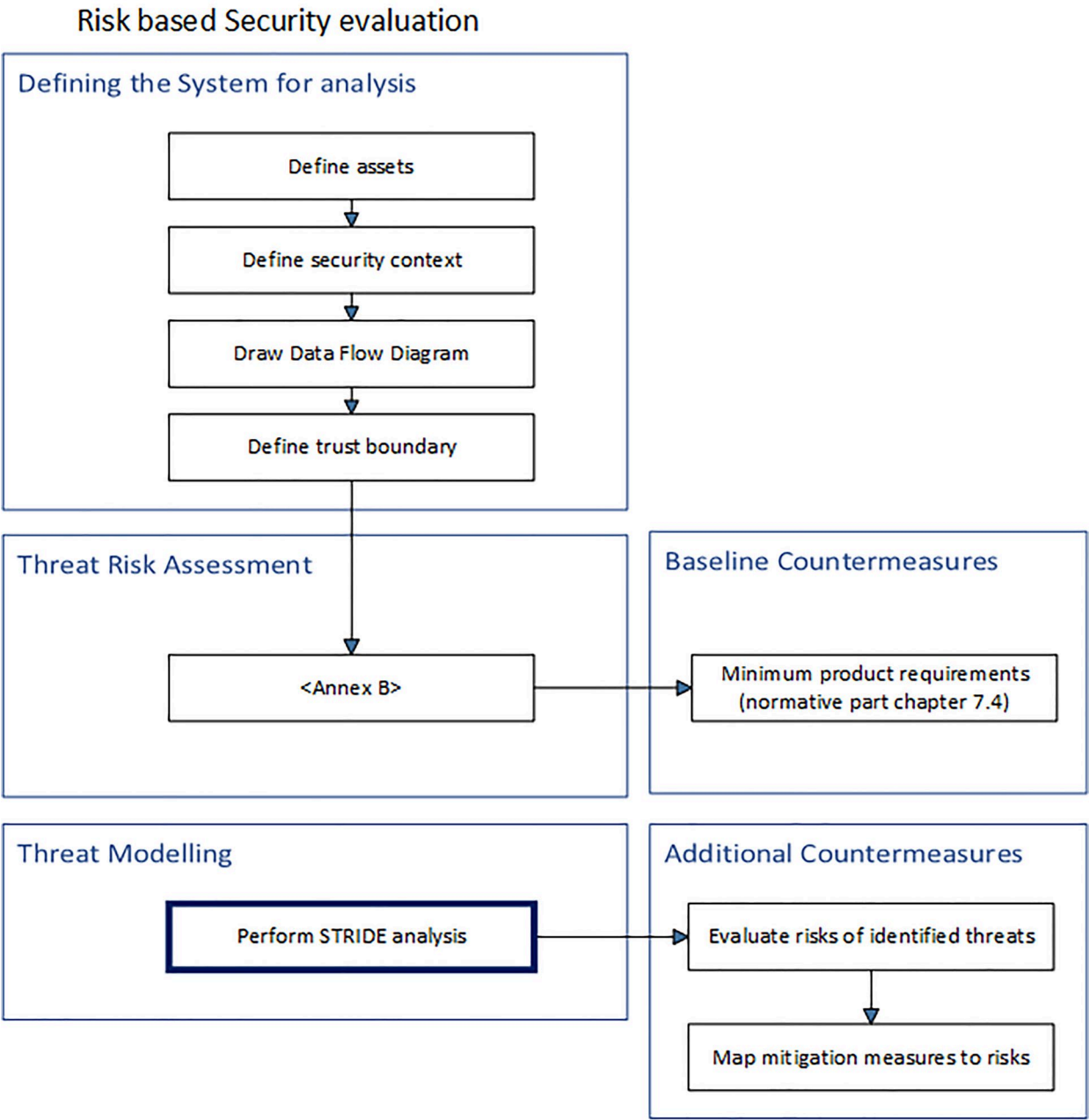


Figure C.1

The highlighted box in Figure C.1 is specific for using STRIDE approach described in this annex. This may be replaced by other suitable methods than STRIDE to identify threats to achieve the same objectives.

C.3 Introduction to examples

C.3.1 General

This procedure will be illustrated by two different examples for machinery, focusing on the prevention of corruption of safety functions.

C.3.2 Example 1: simple form-filling machinery

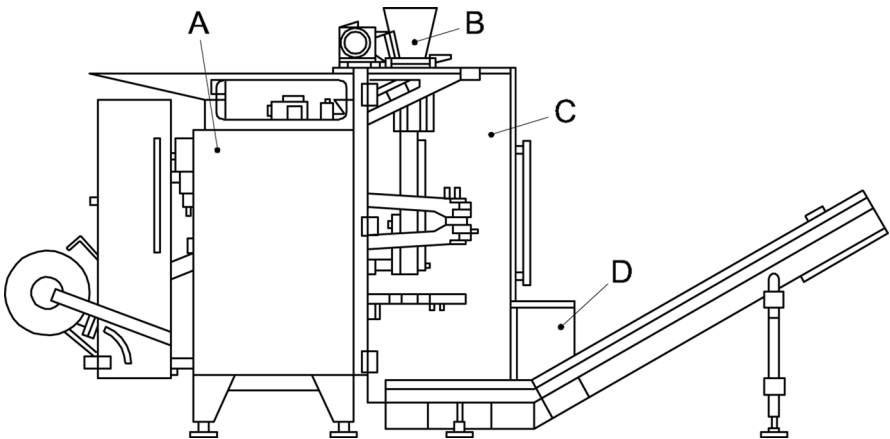
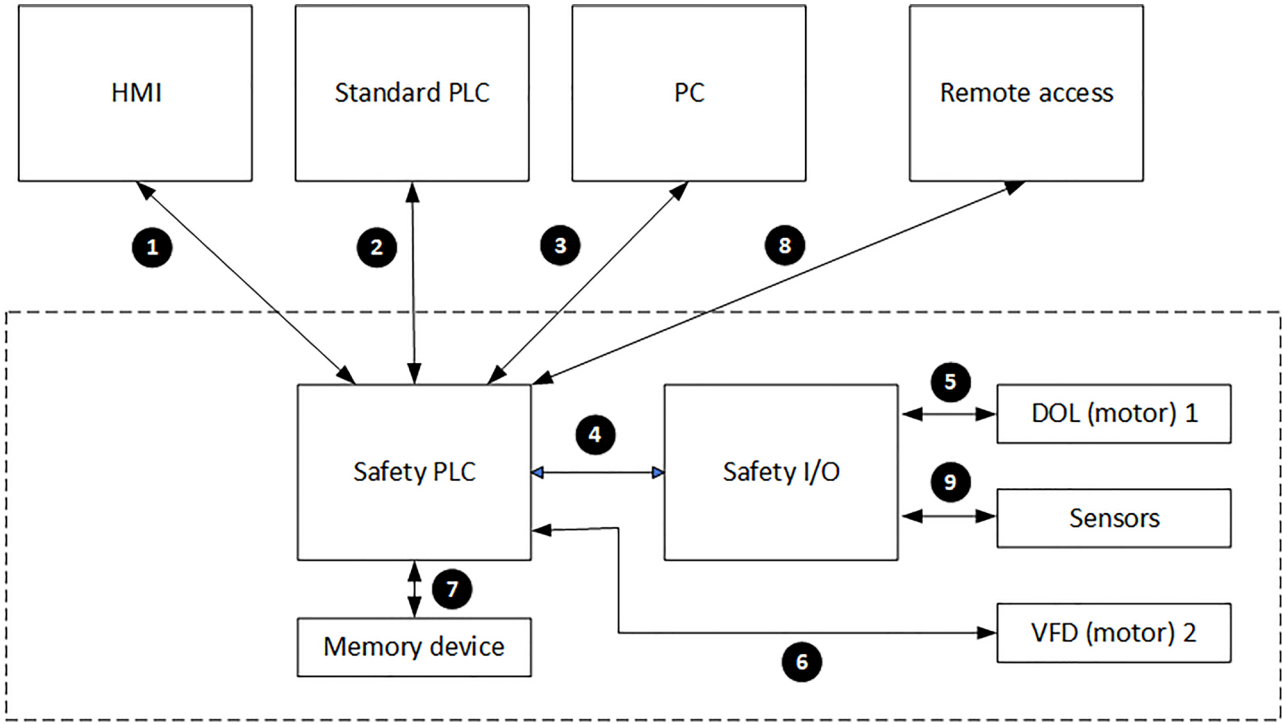


Figure C.2 — Example of typical vertical form fill and seal machine

Source EN 415-3:2022, Figure 21.

A simple form-fill machine consisting of a safety PLC and a motor, which is used indoors in an industrial facility.



Key

- 1 e.g. Industrial Ethernet or internal
- 2 Industrial Ethernet (e.g. EtherNet/IP or PROFINET)
- 3a USB configuration interface (local)
- 3b Ethernet configuration interface (remote)
- 4 backplane
- 5 Direct digital output and motor feedback
- 6 Industrial Ethernet for safety (e.g. CIP Safety or PROFIsafe)
- 7 SD card interface
- 8 remote access, e.g. via the company network or the Internet

9 Direct digital input for sensors (Interlock, discharge bin, discharge conveyor, emergency stop circuit)

Figure C.3

Descriptions:

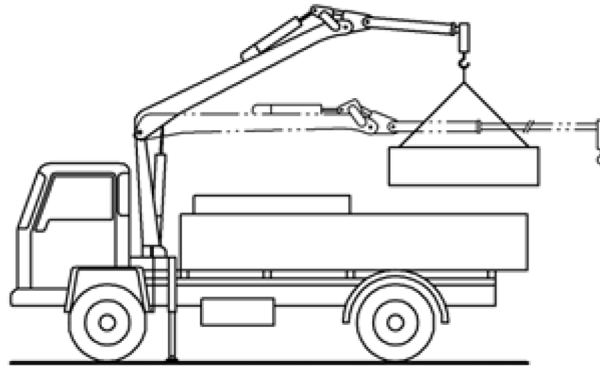
- The standard PLC may receive status and diagnostic data from the safety PLC
- The standard PLC may send standard operating parameters to the safety PLC, which may change the operating mode of the machine (e.g. run mode, parking mode, etc.)
- The connection between HMI and PLCs is used primarily for information (status, alarms, messages etc.), safety configuration is performed via other interfaces
- This simple machine does not include any web-based interfaces
- Safety functions intended as risk-reduction measures defined for a particular hazard of the machine. For the purpose of this example the safety function is used from EN 415-3:2021, 4.3.10 (vertical form, fill and seal machine):
 - Stopping sealing, perforating and cutting mechanisms when the interlocking guard is opened.
 - Preventing unexpected start-up of sealing, perforating and cutting mechanisms when the interlocking guard is open.
 - Disconnecting and dissipating energy from the static eliminator when the interlocking guard is opened.
 - Stopping the sealing, perforating and cutting mechanisms when the discharge conveyor is not in place.
 - Stopping the packaging material transport mechanism when the interlocking guard is opened.
 - Stopping the discharge conveyor when the interlocking guard is opened.
 - Stopping all hazardous processes by the emergency stop circuit.

C.3.3 Example 2: wireless controller for loader crane

This example intends to show the effects on the threat model of an increased attack surface due to both a less strict physical access control scheme and a more vulnerable wireless communication interface.

The loader crane is a crane mounted to a truck. It is typically used outdoors, and the crane part can be controlled remotely

NOTE Although wireless control systems are used for a wide variety of cranes, this example considers only loader cranes to keep the example simple and concise.



667

668 Source: ISO/DIS 4306-1:2023, 4.1.10

669 **Figure C.4 — Example of wireless controlled loader crane**

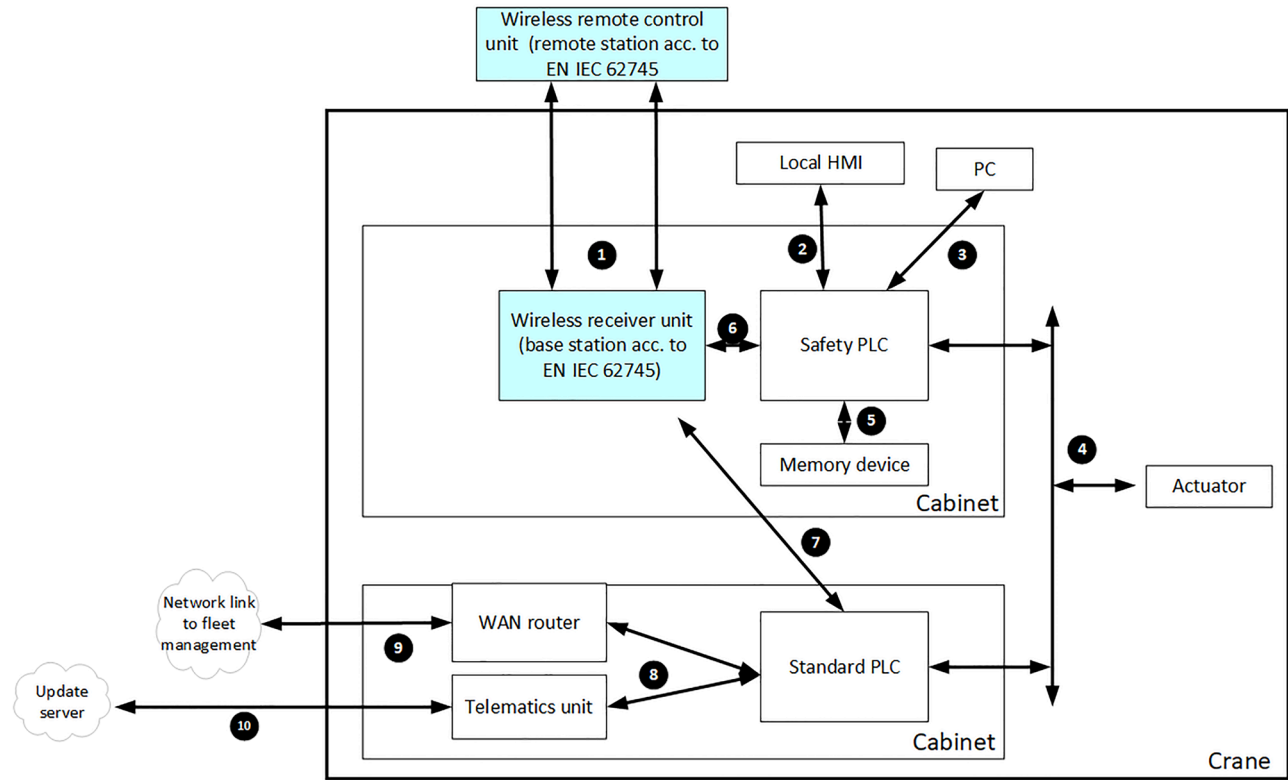
670 Description:

671 Cableless controlled loader cranes contain many sector specifics that are handled by respective standards. This
 672 example will focus on two elements as the internal threats are already assessed in example 1:

- 673 — The cableless controller connection according to EN 62745, consisting of
 - 674 — a cableless hand-held controller to operate the crane
 - 675 — a receiver unit for the cableless hand-held controller
- 676 — The machine is typically used in public accessible areas without access controls like parking lots, the
 677 roadside or construction sites.

678 NOTE Manufacturers of loader cranes usually acquire remote control systems and expect them to be designed with
 679 security in mind. So this example will focus on the correct application of those devices.

- 680 — Controllers are treated as black box, threat model shall include only problems that can be introduced by
 681 incorrect application or misuse
- 682 — Requirements will include authentication, e.g. before being able to control the crane, you have to
 683 authenticate.

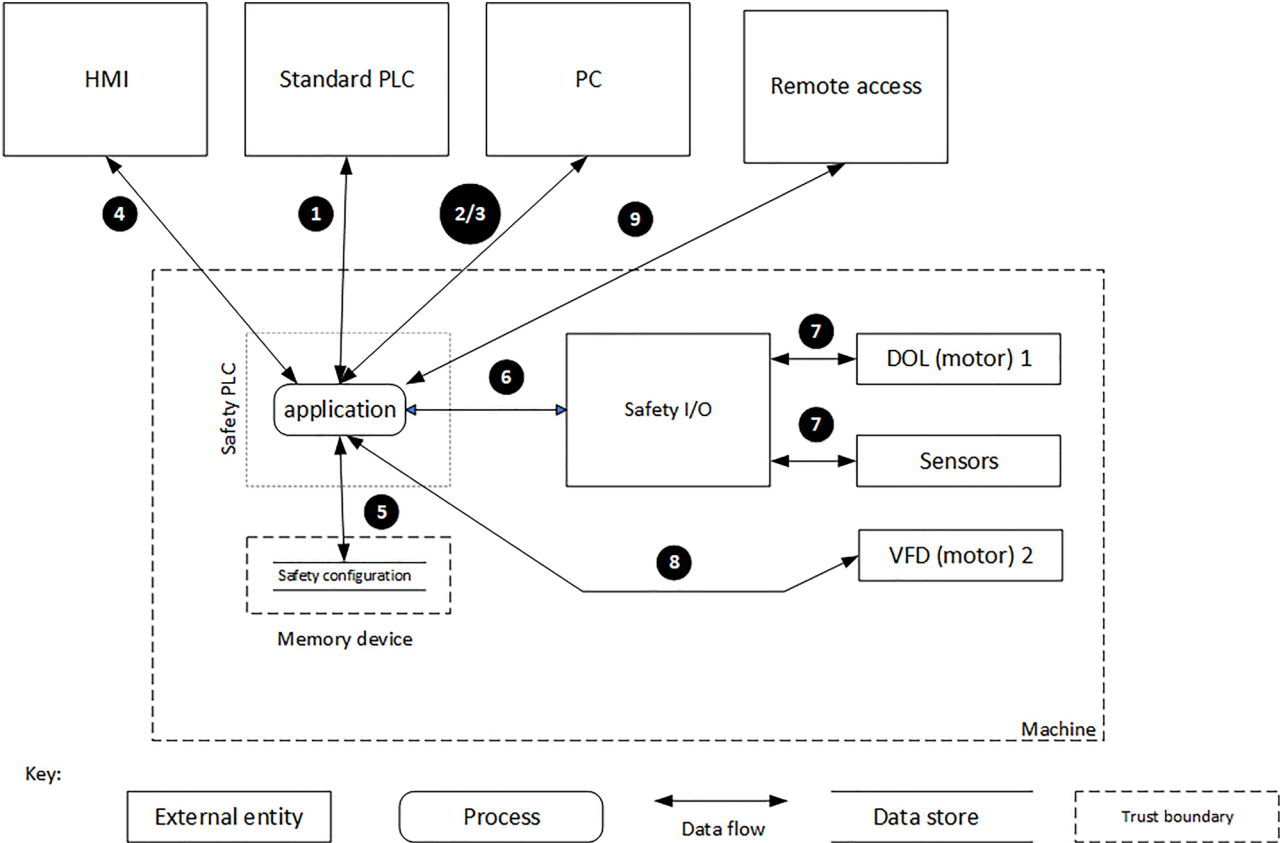


Key

- 1 wireless connection
- 2 industrial Ethernet (e.g. EtherNet/IP or PROFINET)
- 3a USB configuration interface on extension cord (local) or
- 3b Ethernet configuration interface (remote)
- 4 industrial Ethernet for safety (e.g. CIP Safety or PROFI-safe)
- 5 SD card interface
- 6 hardwired I/O
- 7 industrial Ethernet for safety (e.g. CIP Safety or PROFI-safe)
- 8 Ethernet
- 9 WIFI to the company OT network (Note: this is not common for loader cranes but rather for industrial trucks used inside warehouses, here it is included as an illustration for WAN connections of diverse exposure levels)
- 10 WIFI + router to the Internet or direct Internet connection (e.g. via LTE)

Figure C.5

NOTE The remote control function is highlighted in the diagram and realized by a control unit according to EN 62745, Figure A.1.



Source EN IEC 62745:2017, Annex A.

Figure C.6

C.3.4 Example 3: Safety Sensor

< this clause is under consideration for a future revision >

C.3.5 Example 4: Safety device with STO safety function

< this clause is under consideration for a future revision >

C.4 Assets

C.4.1 General

The outcome of an analysis will point out a list of components (assets) that have an implication on safety. (see 1.b of Figure 1).

This list can include assets such as interlocks, pressure meters, temperature sensors, motion controllers.

NOTE Consider the assets for all use cases in all life cycle phases, such as commissioning, normal operation, disposal, etc. (see Table B.3 of EN ISO 12100:2010).

C.4.2 Example 1: simple form-filling machine

In this example the safety related assets are identified as:

- safety configuration data,
- safety-related application software,

- configuration memory devices (e.g. SD card in s-PLC),
- safety-related embedded software (Firmware in safety devices),
- process data on safety related connections (e.g safety buses, safety wireless ...),
- switch to activate engineering mode that allows output simulation etc.,
- safety functions intended as mitigation defined for a particular hazard of the machine.

C.4.3 Example 2: wireless controller for loader crane

In this example the safety related assets are identified as:

- The safety related data exchanged between controller and receiver

NOTE EN 62745, 4.3 requires measures against random corruption.

- Access to the remote controller

NOTE EN 62745, 4.2.2 requires this as well.

C.4.4 Example 3: Safety sensor

< this clause is under consideration for a future revision >

C.4.5 Example 4: Safety device with STO safety function

< this clause is under consideration for a future revision >

C.5 Security context

C.5.1 General

The security context depends on the intended use and application and includes, but is not limited to:

- Protection of the perimeters of the security context, if applicable;
- all countermeasures concerning the interaction between different functional units inside the security context;
- all countermeasures to be applied within the security context.

The countermeasures provided by security context are effective as long as assumptions of the following kind are documented and fulfilled:

- a) physical and logical access management for the target users,
- b) intended use and foreseeable misuse.
- c) physical environment including compensating countermeasure,
- d) logical environment including compensating countermeasure,
- e) policies and procedures,

NOTE "Security context" is the security equivalent of "intended use" in the safety domain.

- 749 The following are examples (not comprehensive list) and consideration of the assumptions related to the
 750 countermeasures provided by security context.
- 751 a) physical and logical access management for the target users
- 752 — everybody
- 753 — authorized personnel
- 754 — service technician
- 755 b) intended use and foreseeable misuse
- 756 — use remote diagnostic connection permanently to supervise
- 757 c) Physical environment including compensating countermeasure
- 758 — location
- 759 — outdoors: agriculture, forest, construction sites, ...
- 760 — public buildings, hospitals, schools ...
- 761 — public transportation, airports, trains, ...
- 762 — premises with access restrictions (access only allowed to people with a badge and authentication
 763 etc.): Industrial facilities, logistic hubs, warehouses, ...
- 764 — special restrictions
- 765 — locked cabinets
- 766 — distinguish between locks with generic keys and unique keys.
- 767 — inside a machine's housing
- 768 — physical position
- 769 — static
- 770 — mobile
- 771 — autonomously moving around
- 772 d) logical environment including compensating countermeasure
- 773 — allow only access via VPN?
- 774 — continuous connection or on demand only
- 775 — is some type of a firewall required if connected to a untrusted network?
- 776 — list all network connections, direct or indirect, logical and physical
- 777 — how is the network supposed to be installed (access to cables, communication partners, etc.)
- 778 e) policies and procedures.

- e.g. enforce certain complexity and length for passwords.

After considering all assumptions, you can estimate an attacker capability score according to Table B.2 and Table B.3 in Annex B for “Window of Opportunity” for a successful attack

C.5.2 Example 1: simple form-filling machine

- This machine is supposed to be used inside an industrial facility with standard access control, so only authenticated and authorized personnel is allowed to near the machine.
- The PLC is housed inside a locked cabinet with a unique key, which is handed to authorized personnel only. (EL0 according to Annex B)
- The network cables between motor drive and safety PLC are inside the machine and not accessible from the outside without disassembling the machine. (EL0 according to Annex B)
- Connection to the configuration interfaces is established only intermittently, only for service cases and trouble shooting.
- For a direct connection (Ethernet or USB) between a PC and the PLC, EL1 can be assumed.
- The USB interface that allows for configuration of the PLC is connected to the edge of the cabinet via a extension cable and thus can be accessed by people with physical access, elevating the Exposure level from EL0 to EL1 according to Annex B
- The remote configuration connection is used only with a direct Ethernet cable or via a secured means of remote access (e.g. a VPN)
- The secured remote access connection is left unpowered if no connection is needed (reducing the “Window of Opportunity”)
- If remote access is desired, the Exposure Level might be for example EL4.
- Then the secured remote access connection needs to provide measures to reduce the risk from EL4 with adequate measures as laid out in 5.4.

- Connection to the standard PLC is kept up permanently for diagnosis and standard control activities

- The memory device holding the safety configuration is placed inside the PLC inside the locked cabinet

C.5.3 Example 2: wireless controller for loader crane

- The loader crane is typically used outdoors in public accessible areas without physical access controls.
- The remote control unit for the crane can be used outdoors.
- The receiver unit is inside a locked box.
- If the crane is not in use, the wireless control system is not powered.
- If the crane is used, the operator has to see the arm.

C.5.4 Example 3: Safety sensor

< this clause is under consideration for a future revision >

812 **C.5.5 Example 4: Safety device with STO safety function**

813 < this clause is under consideration for a future revision >

814 **C.6 Data flow diagram**

815 **C.6.1 General**

816 Draw a data flow diagram detailing all communication and elements.

817 1. Draw all assets.

818 2. Draw all elements considering

819 a. data stores

820 b. processes

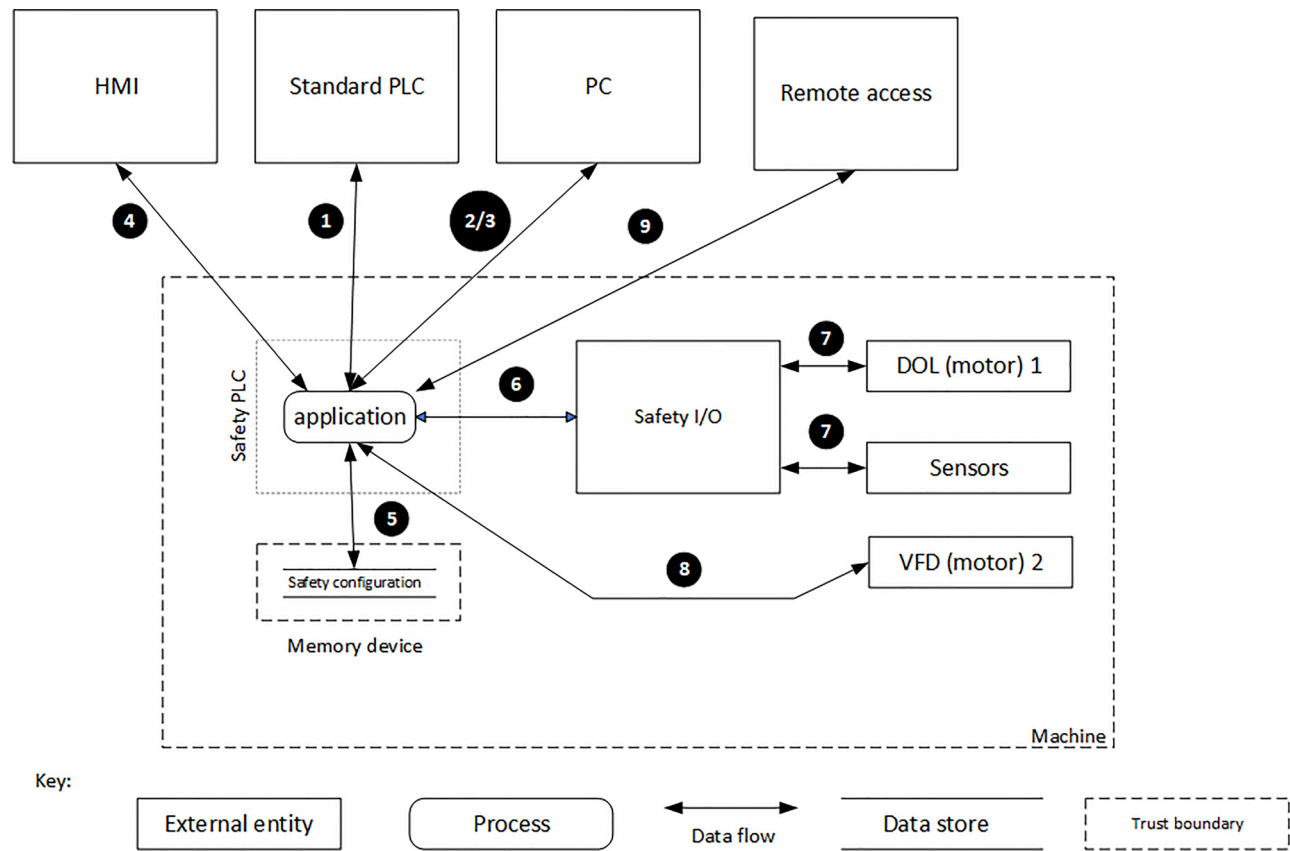
821 c. actors

822 d. network equipment

823 e. data flows –.

824 3. Draw the trust boundaries, logical and physical (see next clause).

C.6.2 EXAMPLE 1: simple form-filling machine

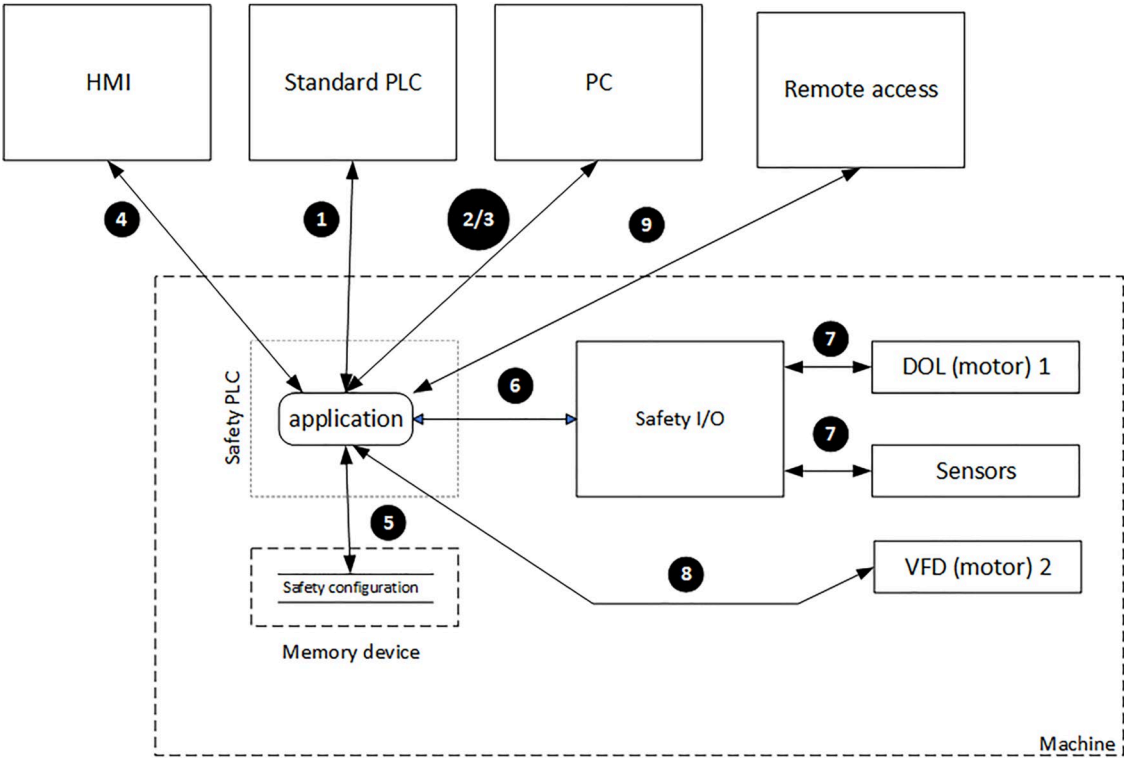


Key

- 1 Industrial Ethernet prototol (e.g. EtherNet/IP, EtherCAT, or PROFINET)
- 2 USB configuration interface (local)
- 3 Ethernet configuration interface (remote)
- 4 Industrial Ethernet prototol (e.g. EtherNet/IP, EtherCAT, or PROFINET)
- 5 SD card interface
- 6 Internal backplane
- 7 Direct digital I/O, 24V
- 8 Direct digital output and motor feedback
- 9 Direct digital input for sensors (Interlock, discharge bin, discharge conveyor, emergency stop circuit)
- 10 Industrial Ethernet for safety (e.g. CIP Safety, FSoE, or PROFIsafe)
- 11 remote access, e.g. via the company network or the Internet

Figure C.7

C.6.3 EXAMPLE 2: wireless controller for loader crane



Key

- 1 wireless connection
- 2 industrial Ethernet (e.g. EtherNet/IP or PROFINET)
- 3a USB configuration interface on extension cord (local) or
- 3b Ethernet configuration interface (remote)
- 4 industrial Ethernet for safety (e.g. CIP Safety or PROFIsafe)
- 5 SD card interface
- 6 directly hardwired I/O
- 7 industrial Ethernet (e.g. EtherNet/IP or PROFINET)
- 8 Ethernet
- 9 WIFI to the company OT network (Note: this is not common for loader cranes but rather for industrial trucks used inside warehouses, here it is included as an illustration for WAN connections of diverse exposure levels)
- WIFI + router to the Internet or direct Internet connection (e.g. via LTE)

Printed copies are uncontrolled

855

856

857

858

859

860

861

862

863

864

865

866

867

868

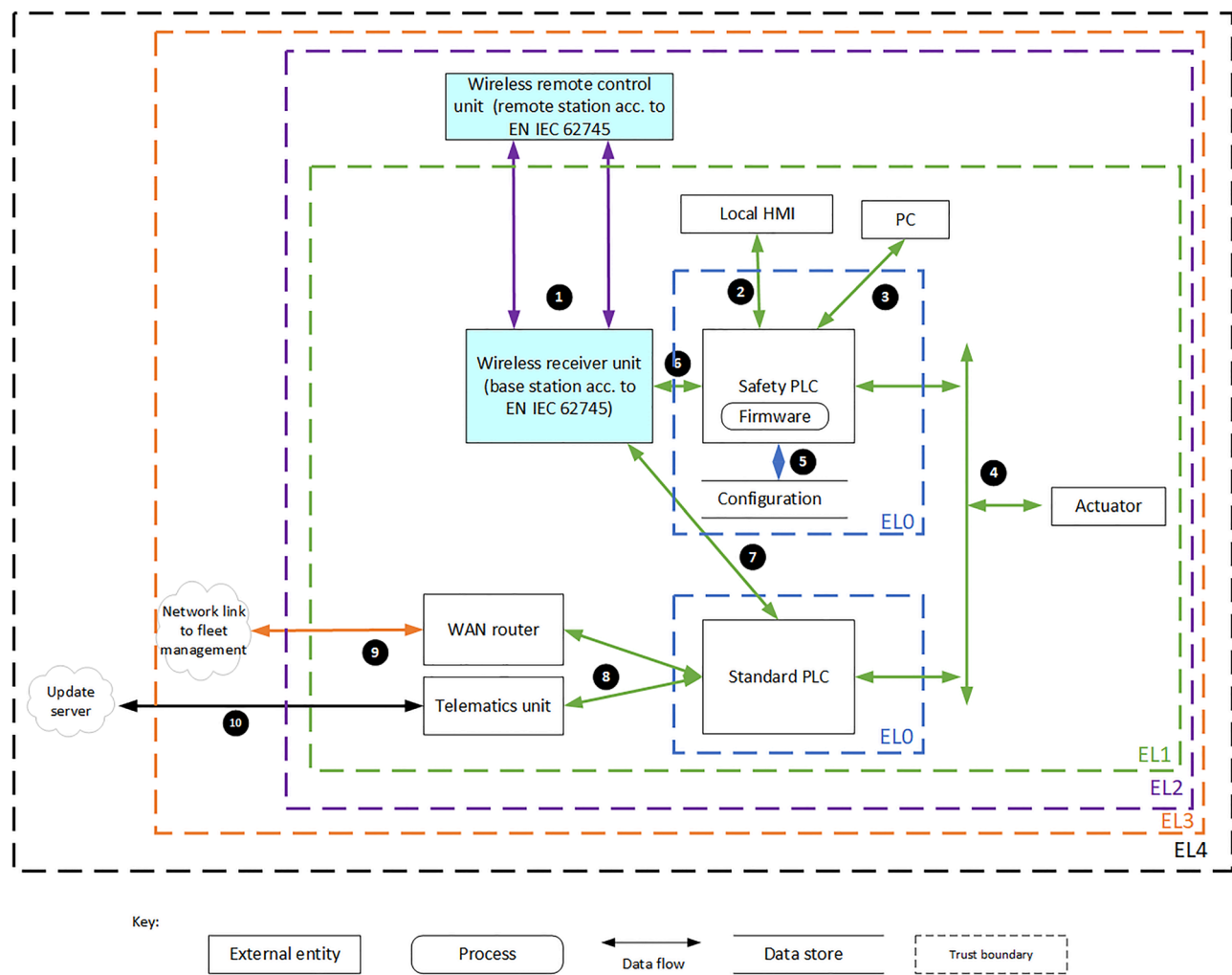


Figure C.8

C.6.4 Example 3: Safety Sensor

< this clause is under consideration for a future revision >

C.6.5 Example 4: Safety device with STO safety function

< this clause is under consideration for a future revision >

C.7 Trust boundaries

C.7.1 General

Trust Boundaries identify areas at a similar level of trust and isolate them from other areas at a different level of trust. This applies to physical and logical properties. This is normally part of the data flow diagram, however it can be considered a separate step as well.

The intention of grouping assets into zones and conduits is to identify those assets which share common security requirements and to permit the identification of common security measures required to mitigate risk.

NOTE The data flow diagram usually includes the trust boundaries of the system under consideration.

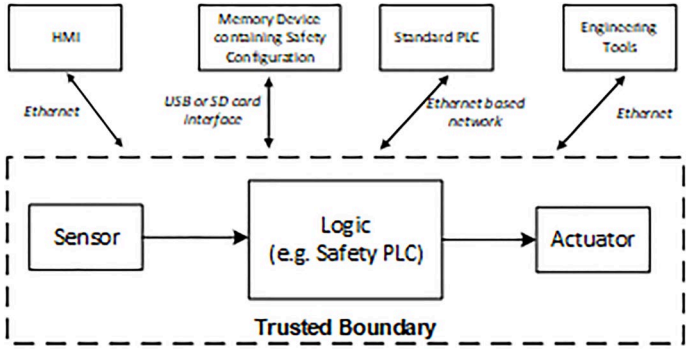


Figure C.9

NOTE

Boundary: edge

Zone: area inside a boundary

Practical examples consider, several different trust boundaries. Those trust boundaries correspond with the different attack surfaces and can be labelled with the “Exposure Levels” defined in Annex B.

The examples show how to regard the system elements from the most trusted areas to the most exposed ones.

C.7.2 Example 1: Simple machine

This example considers everything inside the machine as a fully trusted environment, because it requires some sort of authentication to access, e.g. a unique key or a special tool to open the machine, or some sort of software authentication.

Components attached to the outside of the machine like a local HMI, the USB configuration interface of the Safety PLC, and actuators are considered in the “physical access” category.

The Ethernet connection is intended to be used with local devices, such as fieldbus sensors and actuators or other PLCs (thus “local access” exposure zone).

The industrial factory network contains access by engineering tools and other machines etc.

If the security context section in the information of use describes e.g. that the fieldbus connection is designed to be used locally only, then compensating countermeasures are necessary to use the system in the intended manner. This example mandates a network transition device (like a smart switch, a router with integrated firewall etc.) to keep it separated from more exposure than allowed.

The same is true for other trust boundaries. As in our example the user shall be able to access the application remotely, the remote access shall be secured by an external measure such as a firewall or a secure communication end point to keep the adjacent level separated from the unrestricted level.

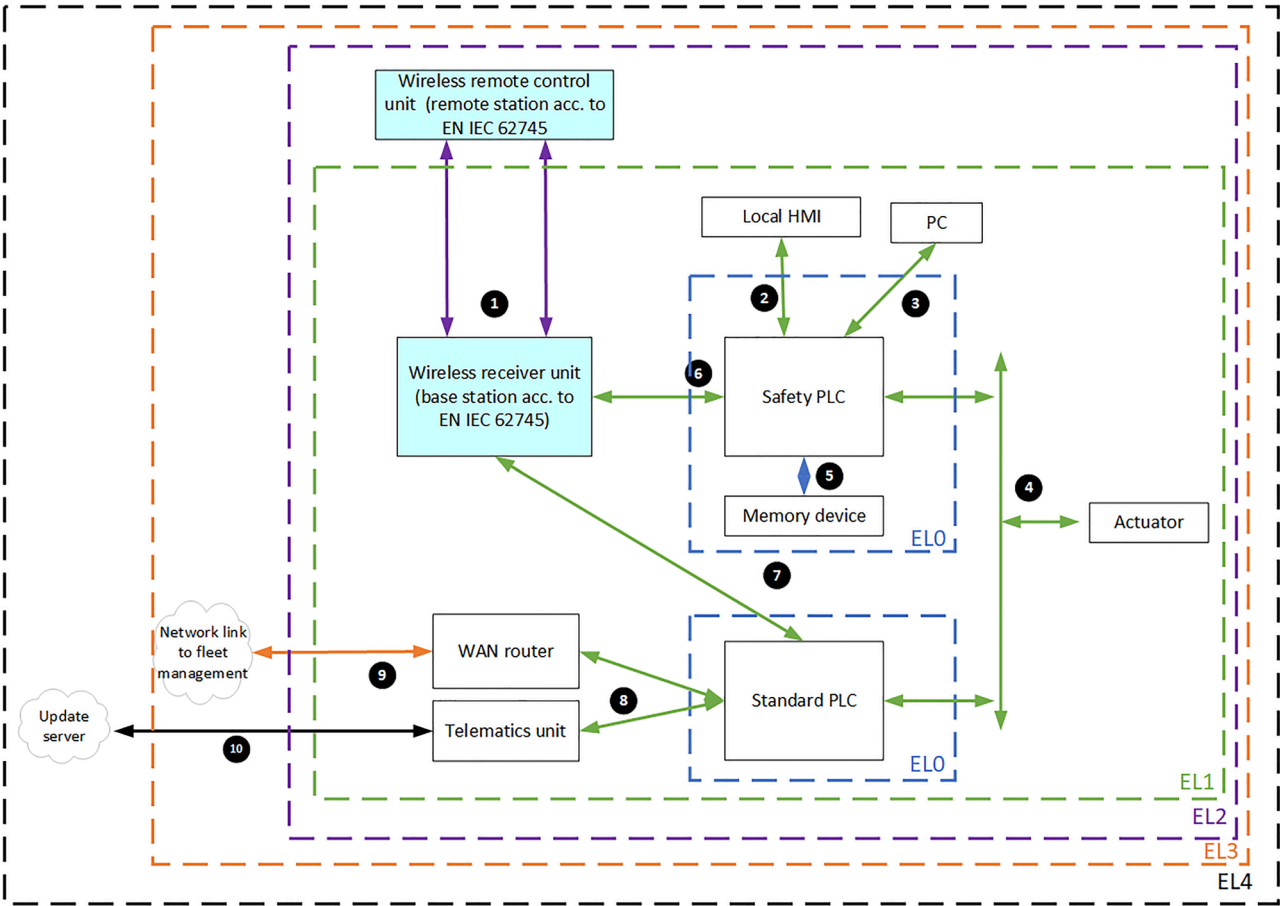


894

- 895
896
897
898
899
900
901
902
903
904
905

906

C.7.3 Example 2: Cableless loader crane controller



- Key**
- 1 Wireless connection
 - 2 Industrial Ethernet (e.g. EtherNet/IP or PROFINET)
 - 3a USB configuration interface on extension cord (local) or
 - 3b Ethernet configuration interface (remote)
 - 4 Industrial Ethernet for safety (e.g. CIP Safety or PROFIsafe)
 - 5 SD card interface
 - 6 Directly hardwired I/O
 - 7 Industrial Ethernet (e.g. EtherNet/IP or PROFINET)
 - 8 Ethernet
 - 9 WIFI to the company OT network (Note: this is not common for loader cranes but rather for industrial trucks used inside warehouses, here it is included as an illustration for WAN connections of diverse exposure levels)
 - 10 WIFI + router to the Internet or direct Internet connection (e.g. via LTE)

Figure C.11

NOTE The diagram can help manufacturers to improve the efficiency of their security design, so the connection to the Internet based update server can be placed outside the machinery:

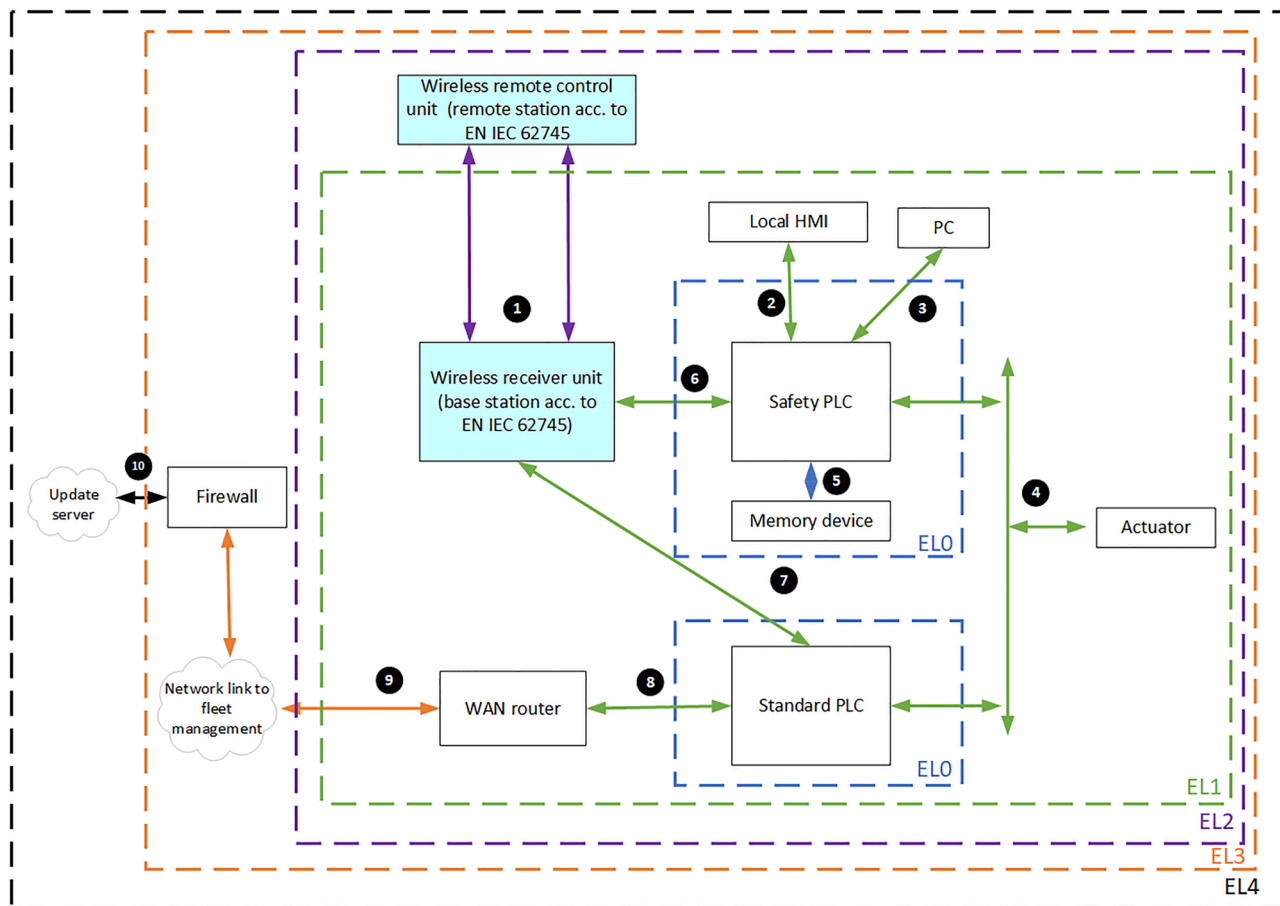


Figure C.12

C.7.4 Example 3: Safety sensor

< this clause is under consideration for a future revision >

C.7.5 Example 4: Safety device with STO safety function

< this clause is under consideration for a future revision >

C.8 STRIDE analysis

C.8.1 General

Answer the question: "Where can corruption cause adverse effects (directly or indirectly) on the risk reduction measures (according to EN ISO 12100:2010)?".

Consider attacks on all elements in your data flow diagram.

How can the interfaces or protocols be misused considering the defined assumptions?

You should use appropriate tools and techniques such as STRIDE for such a consideration.

Control system consists of INPUT – LOGIC – OUTPUT.

Our STRIDE analysis encompasses the whole system, including:

- the control system consisting of INPUT – LOGIC – OUTPUT,
- system interfaces,

- 942 — configuration of devices,
- 943 — actual operation of the devices.
- 944 Chain of trust concept: If data flows happen in a trusted boundary only, there
- 945 **Spoofing** – “impersonate a valid system user or resource” REF1 – violating authentication
- 946 — Spoof another safety communication peer data, e.g. by faking stuffing scheme, time stamps, counters,
- 947 CRCs etc. between controllers, impersonating safety controllers
- 948 — Replay attacks, simulating valid sensor data on a fieldbus
- 949 — An attacker logs into a configuration interface as an administrator to modify safety configuration
- 950 **Tampering** – “Modifying system or user data” REF1 – violating integrity
- 951 — Somebody modifies safety related parameters, configuration, firmware, or user software
- 952 — Somebody performs a man-in-the-middle attack to modify process data while faking safety protocol’s
- 953 measures against communication errors
- 954 — Somebody simulates/bypasses a safety input device, such as an E-Stop. The real E-Stop events are not
- 955 detected/evaluated correctly anymore.
- 956 **Repudiation** – “performing an illegal operation and denying involvement.”– violating accountability
- 957 — Somebody deletes or modifies log entries related to modification of safety related parameters,
- 958 configuration, firmware, or user software
- 959 **Information Disclosure** – “expose information to individuals who are not supposed to see it” REF1 – violating
- 960 confidentiality
- 961 — Probably not in scope as long as health and safety properties of the machine or related product remain
- 962 unchanged
- 963 **Denial of Service** – “Making the system temporarily unavailable or unusable” REF1 – violating availability
- 964 — Probably not in scope as long as health and safety properties of the machine or related product remain
- 965 unchanged
- 966 **Elevation of Privileges** – “unprivileged user gains privileged access” REF1 – violating authorization
- 967 — Probably not in scope as long as health and safety properties of the machine or related product remain
- 968 unchanged.

C.8.2 Example 1: simple form-filling machine

Table C.1

Element	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	Notes
1: Industrial Ethernet protocol between standard PLC and Safety PLC	AT1S1: Attacker could simulate the parameters that change operating mode on the safety PLC AT1S2: Attacker could send fake status data to the standard PLC to mask a problem	AT1T1: Physically disconnect standard PLC and connect to another network node	N/A – no safety relevant data	N/A – no private or otherwise secret data expected here	AT1D1: Cutting the cable AT1D2: EMC AT1D3: Any packet causing the safety PLC to enter the safe stop state AT1D4: Attacker floods the process data interface with many useless packets, saturating the interface.	N/A	
2: USB configuration interface (local)	AT2S1: Brute-forcing passwords AT2S2: Passwords are shared uncontrolled among staff	AT2T1: Connecting a USB device that routes traffic into another communication interface	AT2R1: Somebody modifies the safety configuration to some unsafe settings and restores safe settings after an accident.	AT2I1: Keylogger to sniff password on the client	AT2D1: Physical damage of USB port AT2D2: Connecting USB device with malicious software, overwriting safety configuration AT2D3: use something like “USB killer” with a high voltage capacitor to destroy the USB power supply circuit	AT2E1: People who are supposed to have read-only access, are able to change safety configuration	

Element	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	Notes
3: Ethernet configuration interface (remote)	AT3S1: see AT2S1 AT3S2: see AT2S2		AT3R1: see AT2R1	AT3I1: Sniffing the password or simple password hash on the network	AT3D1: Flooding the configuration interface with many useless packets, saturating the interface.	AT3E1: see AT2E1	
4: HMI and HMI connection	AT4S1: Attacker connects a device that impersonates a HMI and can be used to simulate user input to the machine AT4S2: Attacker puts device between PLC and HMI that impersonates the PLC to let the HMI show only values of a good condition to hide actual problems	N/A – not possible to modify safety related settings via HMI	N/A	AT4I1: Read out identity information of a legitimate user	AT4D1: Disrupt connection to HMI could lead to warning not being noticed	N/A	
5: Memory device (e.g. SD card)	N/A	AT5T1: Replace memory device with one containing another safety configuration.	AT5R1: Attacker replaces the memory device with a corrupted one and replaces it with the original one after an accident to hide the deed	AT5I1: Attacker steals or copies memory device in order to get information about safety application	AT5D1: Steal the memory device, PLC will not boot but stay in safe state	AT5E1; Somebody with no access rights might put a corrupted memory device into the PLC and it would be accepted	
6: backplane	AT6S1: enable some disabled function	AT6T1; Force outputs to hazardous values	N/A	N/A – just raw process data, no secrets	AT6D1: By modifying communication packets on the backplane can make	N/A	

Element	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	Notes
					the safety IO signals enter the safe stop state leading to denial of service for critical services.		
7: I/O data	N/A, see AT7T1	AT7T1 : Change physical cabling	N/A	N/A – just raw signals, no secrets	Duplicate to AT7T1	N/A	
8: Industrial Ethernet between safety PLC and VFD	AT8S1 : Faking the motor feedback information can cause the speed to exceed safe values or cause other safety devices to misbehave, such as a safety lock to be unlocked	AT8T1 : Write unsafe safety parameters into the motor driver	N/A	N/A	AT8D1 : Simulate the activation of a emergency stop button repeatedly	N/A	

971

972 **C.8.3 Example 2: wireless controller for loader crane**

973 Some sector standards for cableless control units (e.g. IEC 62745, 4.3, or IEC 61784-3) contain requirements for measures against random corruption, but
974 do not cover malicious attempts such as spoofing or tampering.

975 **Table C.2**

Element	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	Notes
1: Wireless communication link between remote controller and receiver	AT1S1: An attacker sends safety data with a fake remote controller which seems to come from the legit remote controller AT1S2: Replay attack, Attacker records communication and repeats it at a later time	AT1T1: An attacker uses AT1S1 to change the crane's position or speed AT1T2: Modification of safety functions in the controller via remote link	AT1R1: AT1T1 without a trace	AT1I1: Secret exfiltration of identity information by monitoring the wireless communication, such as a key or rolling code – serving as a stepping stone toward spoofing and/or tampering but itself not a safety threat	AT1D1: An attacker jams the signal AT1D2: Like AT1S2 replaying E-Stop command, leading to machine entering the safe state all the time	AT1E1: Use a mode with other safety restrictions in place than intended for the application under consideration	
2: Cableless remote control unit	AT2S1: Attacker steals the remote controller physically	AT2T1: Replace firmware via an interface such as Bluetooth or USB AT2T2: Replace settings/parameters via an interface such as Bluetooth or USB	AT2R1: Firmware modification without a trace AT2R2: Parameter modification without a trace	AT2I1: Exfiltration of identity information by reading it from device memory	N/A – any possible attack vectors already covered in other columns	AT2E1: see AT1E1	

Element	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege	Notes
3: Cableless receiver unit	AT3S1: Fake the receiver to make the operator believe that his/her trusted remote control unit is connected to safety functions like e-stop while in fact it is not. This might be part of a MITM attack	AT3T1: Indirect corruption through controller via telematics unit or WAN router	AT3R1: Session established to a remote controller without a trace	AT3I1: Exfiltration of identity information by reading it from device memory	N/A – any possible attack vectors already covered in other columns	AT3E1: Attacker reprograms the firmware via cableless link to gain full control of the machine	

- 976 **C.8.4 Example 3: Safety sensor**
- 977 < this clause is under consideration for a future revision >
- 978 **C.8.5 Example 4: Safety device with STO safety function**
- 979 < this clause is under consideration for a future revision >
- 980 **C.9 Threat classification**
- 981 **C.9.1 General**
- 982 Copy all safety-related threats that have been found to a new table.
- 983 Into the new table, list:
- 984 — All found threats
- 985 — Classify each threat by assigning the necessary preconditions for exploit
- 986 — Map each threat to a set of defined standard threats (see extra table “threat types”)
- 987 — Choose recommended mitigations from that table

C.9.2 Example 1: simple form-filling machine

Table C.3

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
1: Industrial Ethernet protocol between standard PLC and Safety PLC	AT1S1: Attacker could simulate the parameters that change operating mode on the safety PLC	Process data on safety related connections (e.g safety buses, safety wireless ...)	TPID1: Attacker has physical access to the network TPID1.6: Attacker has logical access to the network	TTID2.1: Manipulation via physical means	
	AT1S2: Attacker could send fake status data to the standard PLC to mask a problem	Not safety related → out of scope	TPID1: Attacker has physical access to the network TPID1.6: Attacker has logical access to the network	TTID2.1: Manipulation via physical means	
	AT1T1: Physically disconnect standard PLC and connect to another network node	Not safety related → out of scope	TPID1: Attacker has physical access to the network TPID1.6: Attacker has logical access to the network	TTID2.1: Manipulation via physical means	
	AT1D1: Cutting the cable	Not safety related → out of scope	TPID1: Attacker has physical access to the network	TTID2.1: Manipulation via physical means	

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT1D2: EMC	Normal safety mechanisms will lead to a safe state → already covered	–	TTID5.1: Disturb signals via electromagnetic interference leading to errors or (potentially unsafe) system stop	
	AT1D3: Any packet causing the safety PLC to enter the safe stop state	Normal safety mechanisms will lead to a safe state → already covered.	TPID1: Attacker has access to the network	(System would not be usable, however when the system enters safe state, it would not cause a hazardous situation which is acceptable)	
	AT1D4: Attacker floods the process data interface with many useless packets, saturating the interface.	Not safety related → out of scope	TPID1: Attacker has access to the network	(System would not be usable, however when the system enters safe state, it would not cause a hazardous situation which is acceptable)	
2: USB configuration interface (local)	AT2S1: Brute-forcing passwords		TPID4.1: Attacker has access to physical ports of the device TPID5: Logical access to the system	TTID1.2: Brute force attack: trial and error to crack passwords, login credentials, and encryption keys	
	AT2S2: Passwords are shared uncontrolled among staff		TPID6: Negligence of security best practices by the user TP5.3: The system does not distinguish between user roles	TTID1.3: Unauthorized users use legitimate credentials	

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT2T1: Connecting a USB device that routes traffic into another communication interface		TP6: Negligence of security best practices by the user	TTID6.1: Attacker changes the connection capabilities of an interface to potentially increase its Exposure Level	
	AT2R1: Somebody modifies the safety configuration to some unsafe settings and restores safe settings after an accident.		(out of scope)	(out of scope)	
	AT2I1: Keylogger to sniff password on the client	Not safety related → out of scope	Hardware keylogger: TPID4: Attacker has physical access to the device Software Keylogger: TPID6: Negligence of security best practices by the user	TTID1.3: Unauthorized users use legitimate credentials	
	AT2D1: Physical damage of USB port	Not safety related → out of scope	TPID4: Attacker has physical access to the device	TPID5.2: Physical damage or destruction	
	AT2D2: Connecting USB device with malicious software, overwriting safety configuration	Safety configuration data	TPID4: Attacker has physical access to the device TPID5: Logical access to the system	TTID2.2: Manipulating configuration data	
	AT2D3: use something like “USB killer” with a high voltage capacitor to destroy the USB power supply circuit	Not safety related → out of scope	TPID4: Attacker has physical access to the device	TTID5.2: Physical damage or destruction	

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT2E1: People who are supposed to have read-only access, are able to change safety configuration	Safety configuration data	TPID5.3: The system does not distinguish between user roles	TTID2.2: Manipulating configuration data	
3: Ethernet configuration interface (remote)	AT3S1: see AT2S1: Brute-forcing passwords	Not safety related → out of scope	TPID1: Attacker has access to the network TPID5: Logical access to the system	TTID1.3: Unauthorized users use legitimate credentials	
	AT3S2: see AT2S2: Passwords are shared uncontrolled among staff		TPID6: Negligence of security best practices by the user TPID5.3: The system does not distinguish between user roles	TTID1.3: Unauthorized users use legitimate credentials	
	AT3R1: see AT2R1: Somebody modifies the safety configuration to some unsafe settings and restores safe settings after an accident.		(out of scope)	(out of scope)	
	AT3I1: Sniffing the password or simple password hash on the network	Not safety related → out of scope	TPID1: Attacker has access to the network	TTID1.3: Unauthorized users use legitimate credentials	
	AT3D1: Flooding the configuration interface with many useless packets, saturating the interface.	Not safety related → out of scope (note: if shared components are used, AT1D4 might be relevant!)	TPID1: Attacker has access to the network		

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT3E1: see AT2E1: People who are supposed to have read-only access, are able to change safety configuration	Safety configuration data	TPID5.3: The system does not distinguish between user roles	TTID2.2: Manipulating configuration data	
4: HMI and HMI connection	AT4S1: Attacker connects a device that impersonates an HMI and can be used to simulate user input to the machine	(any)	TPID5: Logical access to the system If HMI is connected via network: TPID1: Attacker has access to the network	TTID1.1: Receiver accepts a fake sender as a legit one	
	AT4S2: Attacker puts device between PLC and HMI that impersonates the PLC to let the HMI show only values of a good condition to hide actual problems	Process data on safety related connections (e.g safety buses, safety wireless ...)	TPID5: Logical access to the system If HMI is connected via network: TPID1: Attacker has access to the network	TTID1.1: Receiver accepts a fake sender as a legit one	
	AT4I1: Read out identity information of a legitimate user	Not safety related → out of scope	TPID4.2: Attacker has access to HMI of the device	–	

prEN 50742:2025 (E)

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT4D1: Disrupt connection to HMI could lead to warning not being noticed	If e.g. an ignored warning can lead to a hazard, other measures must be taken, see safety-related standards	TPID4: Attacker has physical access to the device	TTID5.3: Disruption of services	
5: Memory device (e.g. SD card)	AT5T1: Replace memory device with one containing another safety configuration.	Safety configuration data Safety-related application software Configuration memory devices (e.g. SD card in s-PLC)	TPID4: Attacker has physical access to the device	TTID2.3: Manipulating memory device	
	AT5R1: Attacker replaces the memory device with a corrupted one and replaces it with the original one after an accident to hide the deed	Safety configuration data Safety-related application software Configuration memory devices (e.g. SD card in s-PLC)	TPID4: Attacker has physical access to the device	TTID3.1: An attacker manipulates critical safety-related data and restores it after an incident to conceal the alteration	
	AT5I1: Attacker steals or copies memory device in order to get information about safety application	Not safety related → out of scope (however it can enable a second-order attack by knowing the system better)	TPID4: Attacker has physical access to the device	(not an attack in our scope)	
	AT5D1: Steal the memory device, PLC will not boot but stay in safe state	Not safety related → out of scope	TPID4: Attacker has physical access to the device	(not an attack in our scope)	

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT5E1 ; Somebody with no access rights might put a corrupted memory device into the PLC and it would be accepted	Safety configuration data Safety-related application software Configuration memory devices (e.g. SD card in s-PLC)	TPID4 : Attacker has physical access to the device	TTID2.3 : Manipulating memory device TTID3.2 : Destroying evidence TTID3.3 : Destroy the ability to collect evidence (e.g. disconnecting storage device for log data)	
6: backplane	AT6S1 : enable some disabled function	N/A – not feasible, if physical access is given, other, simpler attacks pose more risks			
	AT6T1 ; Force outputs to hazardous values	N/A – not feasible, if physical access is given, other, simpler attacks pose more risks			
	AT6D1 : By modifying communication packets on the backplane can make the safety IO signals enter the safe stop state leading to denial of service for critical services. NOTE A safe state does not always mean safety, e.g. when a process is stopped at a wrong time, heat can build up and result in a fire. This must be considered application specific. For this scenario (form-filling machine), a safe stop state probably does not result in a hazardous situation.	Safety functions intended as mitigation defined for a particular hazard of the machine.	TPID4.3 : Attacker has access to devices inside the system	TTID 2.1 : Manipulation via physical means	

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
7: I/O data	AT7T1: Change physical cabling	Safety functions intended as mitigation defined for a particular hazard of the machine.	TPID4.3: Attacker has access to devices inside the system	TTID 2.1: Manipulation via physical means	
8: Industrial Ethernet between safety PLC and VFD	AT8S1: Faking the motor feedback information can cause the speed to exceed safe values or cause other safety devices to misbehave, such as a safety lock to be unlocked	Process data on safety related connections (e.g safety buses, safety wireless ...)	TPID1: Attacker has access to the network	TTID1.1: Receiver accepts a fake sender as a legit one	
	AT8T1: Write unsafe safety parameters into the motor driver	Safety configuration data Process data on safety related connections (e.g safety buses, safety wireless ...)	TPID1: Attacker has access to the network	TTID1.1: Receiver accepts a fake sender as a legit one	
	AT8D1: Simulate the activation of a emergency stop button repeatedly Note: System is continually in a safe state, so this attack does not lead to hazards	Process data on safety related connections (e.g safety buses, safety wireless ...)	TPID1: Attacker has access to the network	TTID1.1: Receiver accepts a fake sender as a legit one	

991 C.9.3 Example 2: Cableless loader crane controller

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
1: Wireless communication link between remote controller and receiver	AT1S1: An attacker sends safety data with a fake remote controller which seems to come from the legit remote controller	The safety related data exchanged between controller and receiver	TPID1.5: Attacker is close enough / within reach of a cableless receiver TPID3: Attacker knows the identity information	TTID1.1: Receiver accepts a fake sender as a legit one	
	AT1S2: Replay attack, Attacker records communication and repeats it at a later time	The safety related data exchanged between controller and receiver			
	AT1T1: An attacker uses AT1S1 to change the crane's position or speed	The safety related data exchanged between controller and receiver			
	AT1T2: Modification of safety functions in the controller via remote link	The safety related data exchanged between controller and receiver	Unprotected write-access path from wireless receiver unit to safety controller		

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	AT1R1: AT1T1 without a trace	The safety related data exchanged between controller and receiver			
	AT1I1: Secret exfiltration of identity information by monitoring the wireless communication, such as a key or rolling code	The safety related data exchanged between controller and receiver			
	AT1D1: An attacker jams the signal	The safety related data exchanged between controller and receiver			
	AT1D2: Like AT1S2 replaying E-Stop command, leading to machine entering the safe state all the time	The safety related data exchanged between controller and receiver			
	AT1E1: Use a mode with other safety restrictions in place than intended for the	The safety related data exchanged between			

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	application under consideration	controller and receiver			
	AT2S1: Attacker steals the remote controller physically	Access to the remote controller	Physical access		
	AT2T1: Replace firmware via an interface such as Bluetooth or USB				
	AT2T2: Replace settings/parameters via an interface such as Bluetooth or USB				
	AT2R1: Firmware modification without a trace				
	AT2R2: Parameter modification without a trace				
	AT2I1: Exfiltration of identity information by reading it from device memory				
3: Cableless receiver unit	AT3S1: Fake the receiver to make the operator believe that his/her trusted remote control unit is connected to safety functions like e-stop				

Element	Safety related Threat description	Affected Assets	Preconditions for exploit	Threat types	Relevant minimum requirements
	while in fact it is not. This might be part of a MITM attack				
	AT3T1: Indirect corruption through controller via telematics unit or WAN router				
	AT3R1: Session established to a remote controller without a trace				
	AT3I1: Exfiltration of identity information by reading it from device memory				
	AT3E1: Attacker reprograms the firmware via cableless link to gain full control of the machine				

- 993 **C.9.4 Example 3: Safety sensor**
- 994 < this clause is under consideration for a future revision >
- 995 **C.9.5 Example 4: Safety device with STO safety function**
- 996 < this clause is under consideration for a future revision >

997
998
999
1000
1001
1002
1003
1004
1005
1006
1007
1008
1009
1010
1011
1012
1013
1014
1015
1016
1017
1018
1019

Alle Kopien sind unkontrolliert
Nutzung nur gemäß Nutzungsvertrag. Alle Rechte vorbehalten.

Annex D
(informative)

List of threats and mitigations

D.1 General

Threats should be countered primarily by countermeasures by this annex and if that is not practically reasonable, compensating countermeasures should be considered.

Mitigations can either have an effect on

- the impact of the attack,
- or disrupt the attack path.

Goal should be a catalogue of possible mitigations, e.g.

- input validation,
- least privilege principle,
- secure defaults,
- kerckhoff principle, security should hinge on a well-defined secret, not on obscure design,
- immutable application code,
- separate memory for execution and data,
- read-only memory,
- etc.

Bonus if all of these mitigations get test criteria to make them verifiable.

D.2 Pre-condition for exploitation, threat types and mitigation

D.2.1 Preconditions for exploit

Table D.1 — “Preconditions for exploit”

Threat precondition ID	Common threat types	Possible mitigations on the vector / attack path	Notes
TPID1	Attacker has access to the network		
TPID1.1	Attacker can manipulate the network infrastructure devices	CCM1 Use authentication for network equipment, such as managed switches, routers etc.	
TPID1.2	Attacker has physical access to the network cables	CCM2 Install cables in a physically protected environment	

TPID1.3	Attacker has access to the wireless network	CCM3 Encryption of wireless protocol	
TPID1.4	Attacker has access to unused connector jacks of attached network equipment	CCM4 Use RJ45 port locks CCM5 use product only in physically protected environment	
TPID1.5	Attacker is close enough / within reach of a cableless receiver	CCM6 Reduce power to an small area CCM7 Use a directed antenna	
TPID1.6	Attacker has logical access to the network via external networks	CCM8 Avoid routing into untrusted networks CCM9 Use network segmentation with DMZ (firewall, VPN, IDS etc.) CCM10 Implement role based access CCM11 Encrypt protocols CCM12 Use Message Authentication Code (MAC)	
TPID3	Attacker knows the identity information		
TPID4	Attacker has physical access to the system	CCM13 Allow the vulnerable parts of the machine to be protected against unauthorized physical access (e.g. physical lock, placement inside a locked cabinet, use in restricted areas only, etc.)	
TPID4.1	Attacker has access to physical ports of the system	CCM14 Allow the vulnerable ports to be protected against unauthorized physical access (e.g. physical lock, etc.) CCM15 Consider removing/disabling unnecessary ports	
TPID4.2	Attacker has access to HMI of the system		
TPID4.3	Attacker has access to devices inside the system		
TPID5	Logical access to the system		
TPID5.1	The system has no access restrictions in place	CCM16 Implement a user authentication method	
TPID5.2	Interface is activated		
TPID5.3	The system does not distinguish between user roles	CCM17 Implement a role-based user authentication method with multiple user levels	
TPID6	Negligence of security best practices by the user	CCM18 Information of use: advice user on security best practices	

D.2.2 “threat types”

Table D.2 — Threat types

Threat type ID (TTID)	Common threat types	Possible mitigations	Notes
TTID1	Spoofing Identity		
TTID 1.1	Receiver accepts a fake sender as a legit one	CM1 Authentication of communication partner, e.g. by using certificates. CM2 Separation of networks	
TTID 1.2	Brute force attack: trial and error to crack passwords, login credentials, and encryption keys		
TTID 1.3	Unauthorized users use legitimate credentials	CM3 Advice user in information of use to correctly manage sensitive information	
TTID 2	Tampering		
TTID 2.1	Manipulation via physical means	CM4 allow physical access only with a special key (not via readily available tools, such as screwdrivers, wrenches, hexagon keys, pliers) [source: From ISO 14119]	
TTID 2.2	Manipulating configuration data		
TTID 2.3	Manipulating memory device		
TTID 3	Repudiation		
TTID 3.1	An attacker manipulates critical safety-related data and restores it after an incident to conceal the alteration	CM5 Collection of evidence (see clauses ... of EN50742)	
TTID 3.2	Destroying evidence		
TTID 3.3	Destroy the ability to collect evidence (e.g. disconnecting storage device for log data)		
TTID 4	Information disclosure		
	??? Password theft ???		
TTID 5	Denial of service		
TTID 5.1	Disturb signals via electromagnetic interference leading to errors or (potentially unsafe) system stop		
TTID 5.2	Physical damage or destruction	CM6 Ensure that device fails safely	

TTID 5.3	Disruption of services		
TTID 6	Elevation of privilege		
TTID 6.1	Attacker changes the connection capabilities of an interface to potentially increase its Exposure Level		

1022

Relationship between this European Standard and the essential requirements of Regulation (EU) 2023/1230 aimed to be covered

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZZ.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential requirements of that Regulation, and associated EFTA regulations.

The relevant Essential Requirements of Regulation (EU) 2023/1230	Clause(s)/subclause(s) of this EN	Remarks/Notes
1.1.9	4.3, 7.1, 7.2.1, 7.3.2, 7.3.3, 7.3.4 7.4.2, 7.4.3, 7.5 8.3 9	
1.2.1, 2nd paragraph, letter a)	4.3 7.1, 7.2.1, 7.4.2, 7.4.3	
1.2.1, 2nd paragraph, letter f)	7.3.2, 7.3.3, 7.3.4, 7.5 8.3, 8.4	

WARNING 2 — Other Union legislation may be applicable to the product(s) falling within the scope of this standard.

1045

Bibliography

1046 [1] EN ISO 13849-1:2023, *Safety of machinery - Safety-related parts of control systems - Part 1: General*
1047 *principles for design (ISO 13849-1:2023)*

1048 [2] Algorithms, key size and parameters report [https://www.enisa.europa.eu/publications/algorithms-key-](https://www.enisa.europa.eu/publications/algorithms-key-size-and-parameters-report-2014)
1049 [size-and-parameters-report-2014](https://www.enisa.europa.eu/publications/algorithms-key-size-and-parameters-report-2014)

1050 [3] BSI TR-02102-1 *Cryptographic Mechanisms: Recommendations and Key Lengths” Version: 2025-1*
1051 [https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-](https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-TR-02102-1.pdf?__blob=publicationFile)
1052 [TR-02102-1.pdf?__blob=publicationFile](https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-TR-02102-1.pdf?__blob=publicationFile)

1053 [4] EN ISO/IEC 19790, *Information technology - Security techniques - Security requirements for*
1054 *cryptographic modules (ISO/IEC 19790:2012, including corrected version 2015-12)*

1055 [5] EN 415-3:2021, *Safety of packaging machines - Part 3: Form, fill and seal machines; fill and seal*
1056 *machines*

1057